ESEN

CIBERSEGURIDAD

Catálogo de Empresas

Escenarios del Proyecto Final

Veintisiete organizaciones con su Grupo de Implementación asignado por perfil de riesgo

CIS Controls v8.1 · NIST CSF 2.0 · ISO/IEC 27001:2022 · ISO 22301:2019

Fuente obligatoria de los casos del Proyecto Final y de la asignación BIA

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Para qué sirve este catálogo 3
2. Los Grupos de Implementación del CIS v8.1 3
3. Asignación del Grupo de Implementación por perfil de riesgo 4
4. Perfiles de las veintisiete organizaciones 5
4.1 Banca Unida de Centroamérica (BUNICA) 5
4.2 Red Hospitalaria Metropolitana (RHM) 10
4.3 ComunicaTel El Salvador 14
4.4 Energía Nacional S.A. de C.V. (ENSA) 18
4.5 Dirección General de Identificación Nacional (DGIN) 24
4.6 LogiPort CA (Puerto Logístico Centroamericano) 28
4.7 Innovatec Pharma 33
4.8 Aseguradora Confianza Total 37
4.9 Mercado Digital Centroamérica (MerdiCA) 41
4.10 Universidad Tecnológica de Centroamérica (UNITEC-CA) 46
4.11 AeroComponentes de El Salvador (AESA) 50
4.12 Supermercados El Ahorro 54
4.13 OmniSource Solutions 59
4.14 GestioPyme Cloud 62
4.15 Alas Centroamericanas (ALACA) 67
4.16 Capitalia Gestores de Patrimonio 71
4.17 Centro Judicial Digital de El Salvador (CJDES) 75
4.18 GeoExplora El Salvador 79
4.19 Global Media Group (GMG) - División El Salvador 83
4.20 Constructora Horizonte 87
4.21 Central Azucarera El Gigante (CENAZU) 91
4.22 Express Logistics International (ELI) 95
4.23 Raíces Bienes Raíces 99
4.24 Cacao del Sol 102
4.25 CrediRápido S.A. 106
4.26 Consultores Legales Corpolex 110
4.27 Instituto Salvadoreño de Investigación Genómica 114
5. Reglas de selección y bloqueo de duplicados 118
6. Glosario 118
7. Referencias 119

1. Para qué sirve este catálogo

Este catálogo reúne veintisiete organizaciones que operan en El Salvador y en la región centroamericana, cada una con su modelo de negocio, sus procesos críticos y su infraestructura tecnológica de partida. Cada equipo del curso elige una de ellas y trabaja sobre ese escenario durante todo el ciclo: el análisis de impacto en el negocio, el análisis de riesgos, la línea base de controles y el plan de implementación se construyen sobre la misma organización, de modo que las decisiones de una etapa alimenten a la siguiente.

Los perfiles describen organizaciones cuyo estado inicial de seguridad es bajo. Ese punto de partida es deliberado: el trabajo del curso consiste en llevar a la organización desde ese estado hasta una línea base defendible, y para eso hace falta que exista una brecha real que cerrar. Cada perfil declara la madurez actual con sus carencias concretas, y esas carencias son el insumo del análisis de brechas del Proyecto Final.

Dónde se usa cada parte del perfil

Parte del perfil	Entregable del curso que la consume
Sector, tamaño, ubicación y estructura organizacional	Alcance del proyecto y mapa de partes interesadas del levantamiento.
Misión y visión	Justificación de la criticidad ante la dirección en el informe ejecutivo.
Servicios principales y clientes	Inventario de procesos del BIA.
Procesos críticos declarados	Fichas BIA por proceso, con sus métricas de tiempo y su impacto.
Dependencia tecnológica	Mapa de dependencias y recursos mínimos.
Sistemas, red y comunicaciones	Inventario de activos y análisis de la superficie de exposición.
Madurez y controles actuales	Análisis de brechas contra el Grupo de Implementación asignado.

2. Los Grupos de Implementación del CIS v8.1

Los Controles Críticos de Seguridad del CIS en su versión **v8.1** organizan la defensa en dieciocho controles que contienen ciento cincuenta y tres salvaguardas. Una salvaguarda es una acción concreta y medible, redactada de modo que sea posible verificar si está implementada. Los Grupos de Implementación ordenan esas salvaguardas por prioridad, de manera que una organización sepa por dónde empezar y qué añadir después.

Grupo	Definición	Salvaguardas	Perfil de la organización
IG1	Higiene cibernética esencial: la defensa mínima que toda organización aplica.	56	Recursos de seguridad limitados, tecnología de la información fuera de la función principal, exposición a ataques oportunistas.
IG2	Gestión de riesgos dirigidos: se apoya en IG1 y añade setenta y cuatro salvaguardas.	130	Varios departamentos con perfiles de riesgo distintos, infraestructura compleja, datos sensibles de clientes u operación.
IG3	Resiliencia contra amenazas avanzadas: añade veintitrés salvaguardas sobre IG2.	153	Especialistas de seguridad dedicados, datos regulados de alta sensibilidad, adversarios sofisticados y consecuencias públicas.

Los grupos son acumulativos: IG2 contiene a IG1, e IG3 contiene a IG1 y a IG2. La asignación es una autoevaluación de la organización y el CIS propone cinco factores para resolverla: tamaño y complejidad, tipos de dato que se manejan, recursos y tecnología disponibles, tipos de amenaza que enfrenta y riesgo que la organización acepta.

3. Asignación del Grupo de Implementación por perfil de riesgo

El Grupo de Implementación de cada organización se asigna por su perfil de riesgo inherente, con los cinco factores del CIS aplicados al perfil que el catálogo declara. El resultado es uniforme: las veintisiete organizaciones quedan en **IG3**. El catálogo está construido para ello, porque el Proyecto Final evalúa el diseño completo de la línea base de una organización expuesta a amenazas avanzadas, y el alcance de ciento cincuenta y tres salvaguardas es el mismo para todos los equipos.

El perfil de riesgo inherente y la madurez actual son cosas distintas. Una organización con madurez nula puede pertenecer a IG3 porque los datos que custodia y los adversarios que la buscan lo exigen; la distancia entre lo que debería tener y lo que tiene es, precisamente, el trabajo del proyecto. La madurez baja de todos los perfiles del catálogo describe el punto de partida, y el Grupo de Implementación describe el destino.

Cómo se aplicaron los cinco factores

- **Tipos de dato.** Datos financieros regulados, información de salud, biometría, expedientes judiciales, datos genómicos y propiedad intelectual empujan hacia IG3 aunque la plantilla sea pequeña.
- **Tipos de amenaza.** La exposición a adversarios dirigidos y con recursos —incluidos actores estatales— separa IG3 de IG2, donde predomina el ataque oportunista y el dirigido de menor sofisticación.
- **Tamaño y complejidad.** Varios departamentos con perfiles de riesgo distintos, operación distribuida o tecnología de operación amplían la superficie de ataque y sostienen la asignación aunque la plantilla de tecnología sea reducida.
- **Recursos y tecnología.** La ausencia de una función de seguridad dedicada describe la madurez actual, no el destino: en todos estos perfiles el proyecto la crea como parte del diseño de la línea base.
- **Riesgo.** Las consecuencias sobre terceros ajenos a la organización —pacientes, usuarios del sistema eléctrico, pasajeros, ciudadanía— elevan la asignación con independencia del tamaño.

La tabla siguiente resume la asignación de las veintisiete organizaciones. El perfil de cada una, en la sección 4, desarrolla la justificación de su Grupo de Implementación.

N.º	Organización	Sector	IG
1	Banca Unida de Centroamérica (BUNICA)	Servicios Financieros y Banca	**IG3**
2	Red Hospitalaria Metropolitana (RHM)	Salud	**IG3**
3	ComunicaTel El Salvador	Telecomunicaciones	**IG3**
4	Energía Nacional S.A. de C.V. (ENSA)	Energía y Servicios Públicos	**IG3**
5	Dirección General de Identificación Nacional (DGIN)	Gobierno	**IG3**
6	LogiPort CA (Puerto Logístico Centroamericano)	Logística y Transporte Marítimo	**IG3**
7	Innovatec Pharma	Farmacéutica y Biotecnología	**IG3**
8	Aseguradora Confianza Total	Seguros	**IG3**

N.°	Organización	Sector	IG
9	Mercado Digital Centroamérica (MerdiCA)	Comercio Electrónico y FinTech	**IG3**
10	Universidad Tecnológica de Centroamérica (UNITEC-CA)	Educación Superior e Investigación	**IG3**
11	AeroComponentes de El Salvador (AESA)	Manufactura Avanzada (Aeroespacial)	**IG3**
12	Supermercados El Ahorro	Retail y Consumo Masivo	**IG3**
13	OmniSource Solutions	BPO (Business Process Outsourcing) y Centros de Contacto	**IG3**
14	GestioPyme Cloud	Software como Servicio (SaaS)	**IG3**
15	Alas Centroamericanas (ALACA)	Aviación y Transporte	**IG3**
16	Capitalia Gestores de Patrimonio	Gestión de Inversiones y Banca Privada	**IG3**
17	Centro Judicial Digital de El Salvador (CJDES)	Gobierno / Justicia	**IG3**
18	GeoExplora El Salvador	Minería y Recursos Naturales	**IG3**
19	Global Media Group (GMG) - División El Salvador	Medios y Entretenimiento	**IG3**
20	Constructora Horizonte	Construcción e Ingeniería Civil	**IG3**
21	Central Azucarera El Gigante (CENAZU)	Agroindustria (Producción de Azúcar)	**IG3**
22	Express Logistics International (ELI)	Logística y Transporte de Carga	**IG3**
23	Raíces Bienes Raíces	Inmobiliario y Desarrollo	**IG3**
24	Cacao del Sol	Alimentos y Bebidas (Chocolate Premium)	**IG3**
25	CrediRápido S.A.	FinTech (Microcréditos)	**IG3**
26	Consultores Legales Corpolex	Servicios Legales Corporativos	**IG3**
27	Instituto Salvadoreño de Investigación Genómica	Investigación Científica y Biotecnología	**IG3**

4. Perfiles de las veintisiete organizaciones

Cada perfil reúne tres bloques —datos básicos, modelo de negocio con sus procesos críticos e infraestructura tecnológica con su madurez actual— y el Grupo de Implementación asignado con su justificación y la ficha de datos del cliente. El perfil y la ficha son el dato de partida del proyecto: el equipo los toma tal como están escritos, calcula con los datos de la ficha y documenta como supuesto solo lo que ni el perfil ni la ficha traen (por ejemplo, el costo estimado de una solución que propone). Un dato que la ficha trae nunca se sustituye por un supuesto.

4.1 Banca Unida de Centroamérica (BUNICA)

Grupo de Implementación asignado: IG3. Datos financieros regulados, participación en la compensación interbancaria y condición de objetivo dirigido permanente.

Datos básicos de la empresa

- **Sector:** Servicios Financieros y Banca.
- **Tamaño:** Grande (1,200 empleados).

- **Ubicación:** Oficinas centrales en San Salvador, El Salvador, con sucursales en todo el país.
- **Misión:** Ser el pilar financiero de nuestros clientes, ofreciendo soluciones bancarias seguras, innovadoras y accesibles que impulsen el desarrollo económico regional.
- **Visión:** Liderar la transformación de la banca centroamericana a través de la tecnología y la confianza, garantizando la integridad del patrimonio de nuestros clientes.
- **Estructura Organizacional Básica:** Junta Directiva, Presidencia, Banca de Personas, Banca Corporativa, Operaciones y Tecnología, Riesgos y Cumplimiento, Finanzas, Recursos Humanos.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Cuentas de ahorro y corrientes, tarjetas de crédito/débito, préstamos corporativos y personales, transferencias internacionales.
- **Clientes:** Particulares, PYMES y grandes corporaciones (B2C y B2B).

Procesos Críticos (4):

  - **1. Procesamiento del Core Bancario:** Ejecución y registro de todas las transacciones financieras en tiempo real.
  - **2. Gestión de Canales Digitales:** Operación 24/7 de la banca en línea y la aplicación móvil.
  - **3. Compensación y Liquidación de Pagos:** Procesamiento de transferencias interbancarias y transacciones con tarjetas.
  - **4. Cumplimiento Normativo (AML/KYC):** Monitoreo de transacciones para la prevención de lavado de dinero y verificación de identidad de clientes.

- **Dependencia Tecnológica:** Crítica y absoluta. Una interrupción afecta directamente la economía y la confianza pública.

Infraestructura tecnológica inicial

- **Sistemas:** Core bancario AS/400 (legacy), CRM de Salesforce, plataforma de banca en línea desarrollada a medida, Microsoft 365.
- **Red y Comunicaciones:** Centro de datos principal y sitio de contingencia en El Salvador. Redes MPLS conectan las sucursales. Infraestructura híbrida con servicios en Azure.
- **Madurez y Controles Actuales:** Nivel intermedio-bajo. Cuentan con firewalls perimetrales, antivirus corporativo y realizan backups. Sin embargo, carecen de un SIEM centralizado, no tienen un programa formal de gestión de vulnerabilidades y la segmentación de la red es deficiente, representando un alto riesgo para los datos sensibles que manejan.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales (intereses y comisiones)	USD 210 M	190–230 M	Banca de Personas 55 %, Banca Corporativa 45 %
Margen neto	14 %	11–17 %	Utilidad neta sobre ingresos

Dato	Valor probable	Rango	Detalle
Temporada alta	Días de pago de planilla (15 y último de cada mes) y diciembre (aguinaldo)	—	Transacciones del día frente al día promedio: quincena 2,2 (1,8–2,6); diciembre 1,6 (1,4–1,9)
Volumen de transacciones	180 000 por día en el core	150 000–210 000	38 millones de transacciones con tarjeta al año; el banco emite tarjetas y cumple PCI DSS como emisor
Clientes y datos personales	650 000 clientes	600 000–700 000	420 000 usuarios activos de banca en línea y app
Costo de notificar a un cliente	USD 0,30	0,20–0,45	Cotización vigente de mensajería y correo certificado
Costo de reposición del core	USD 1,2 M	1,0–1,5 M	Servidor IBM Power y licencias del core
Fraude por canales digitales	USD 85 000 al año	60 000–120 000	Pérdida reconocida a clientes por toma de cuentas

Operación por proceso

Proceso	Procesamiento del core bancario
Horario	24 horas; cierre diario de 22:00 a 2:00; sucursales de lunes a viernes de 8:00 a 17:00 y sábados de 8:00 a 12:00
Personal en turno y costo	420 personas en sucursales y operaciones por turno; costo cargado USD 7,50 por hora (±15 %)
Procedimiento alterno	Atención en sucursal con consulta de saldos en reportes impresos y retiros hasta un límite; costo adicional USD 2 500 por hora
Penalizaciones	Toda interrupción de servicio se reporta a la Superintendencia del Sistema Financiero, que puede sancionar; compensación a comercios afiliados por rechazos
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sucursales sin operar en línea; filas y reclamos; reporte a la Superintendencia · 24 h: sin cierre diario; pagos de planilla de empresas clientes retrasados; cobertura en medios · 72 h: retiro de depósitos por pérdida de confianza; intervención del supervisor · 1 semana: pérdida de clientes corporativos; riesgo de liquidez · 1 mes: daño a la reputación que la Presidencia considera irreversible

Proceso	Gestión de canales digitales (banca en línea y app)
Horario	24 horas, todos los días
Personal en turno y costo	60 personas de canales y soporte por turno; costo cargado USD 9,00 por hora
Procedimiento alterno	Centro de llamadas para consultas y transferencias urgentes; costo adicional USD 800 por hora
Penalizaciones	Reporte a la Superintendencia cuando la caída supera el umbral de su norma; reembolso de comisiones

Proceso	Gestión de canales digitales (banca en línea y app)
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: clientes no pueden pagar ni transferir; reclamos en redes · 24 h: saturación de sucursales y del centro de llamadas · 72 h: clientes abren cuentas en otros bancos · 1 semana: pérdida de usuarios digitales y de comercios que cobran con el banco · 1 mes: retroceso del plan de transformación digital

Proceso	Compensación y liquidación de pagos
Horario	Ventanas del sistema de pagos del Banco Central de Reserva en días hábiles, de 8:00 a 17:00; tarjetas 24 horas
Personal en turno y costo	25 personas de tesorería y operaciones; costo cargado USD 10,00 por hora
Procedimiento alterno	Envío manual de lotes por el portal del sistema de pagos, con doble control; costo adicional USD 400 por hora
Penalizaciones	Una liquidación fuera de ventana obliga a fondeo nocturno a tasa de mercado; comercios afiliados reclaman los depósitos tardíos
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: transferencias interbancarias del día en cola; reclamos de empresas · 24 h: se pierde la ventana de liquidación; costo de fondeo y reclamos formales · 72 h: incumplimiento con otras entidades del sistema de pagos; intervención del Banco Central · 1 semana: suspensión de servicios de pago a clientes corporativos · 1 mes: pérdida de clientes corporativos y de la licencia de adquirencia

Proceso	Cumplimiento normativo (AML/KYC)
Horario	Monitoreo diario en horario de oficina; reportes con plazo fijo a la Unidad de Investigación Financiera
Personal en turno y costo	18 personas de Cumplimiento; costo cargado USD 11,00 por hora
Procedimiento alterno	Revisión manual de alertas por muestreo y apertura de cuentas con verificación presencial
Penalizaciones	Multa de la autoridad por reportes fuera de plazo o por cuentas abiertas sin verificación
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: alertas del día sin revisar; sin efecto en clientes · 24 h: apertura de cuentas detenida; retraso en reportes diarios · 72 h: reportes con plazo vencido; riesgo de multa · 1 semana: observación formal del supervisor · 1 mes: riesgo de sanción y de pérdida de bancos corresponsales en el exterior

Tecnología

Elemento	Situación actual
Core bancario	IBM i 7.4 en servidor IBM Power (AS/400), aplicación propia de más de 20 años
Canales digitales	Banca en línea y app desarrolladas a medida en Java sobre Red Hat Enterprise Linux 8, con base de datos Oracle 19c
CRM y oficina	Salesforce; Microsoft 365; Active Directory en Windows Server 2019 sincronizado con Microsoft Entra ID; estaciones con Windows 11

Elemento	Situación actual
Red	Centro de datos principal y sitio de contingencia en El Salvador; red MPLS a todas las sucursales; cortafuegos perimetrales Palo Alto; servicios híbridos en Azure
Tarjetas	Procesador de tarjetas externo; cajeros automáticos conectados por la red MPLS

Respaldos y continuidad

Sistema	Situación actual
Core bancario	Respaldo diario a cinta que se guarda en el sitio de contingencia; réplica asíncrona cada hora
Canales digitales	Base de datos Oracle con réplica al sitio de contingencia cada 15 minutos
Última prueba de recuperación	Hace 18 meses, parcial (solo el core); tardó 11 horas
Sitio de contingencia	Existe, en otra zona de San Salvador; la conmutación es manual

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Denegación de servicio contra la banca en línea	5 horas	Reclamos y reporte al supervisor
2024	Toma de cuentas de clientes por phishing	Tres semanas de campaña	USD 85 000 reembolsados a clientes
2025	Falla eléctrica en el centro de datos principal con conmutación manual	2 horas	Sucursales sin operar en línea
2026	Malware en una estación de sucursal, contenido por el antivirus	1 día	Sin pérdida económica

Organización y presupuesto

Dato	Valor
Organigrama	Junta Directiva con Comité de Auditoría; Presidencia; Banca de Personas; Banca Corporativa; Operaciones y Tecnología (TI con 85 personas); Riesgos y Cumplimiento (incluye la Gerencia Legal y un oficial de seguridad de la información); Finanzas; Recursos Humanos. Auditoría Interna reporta al Comité de Auditoría
Presupuesto aprobado para seguridad	2027: USD 2,4 M (1,5 M de inversión y 0,9 M de operación). 2028 y 2029: +5 % anual, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por la Presidencia para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Normas técnicas del Banco Central de Reserva sobre seguridad de la información y continuidad, supervisadas por la Superintendencia del Sistema Financiero; PCI DSS como emisor; Ley para la Protección de Datos Personales; prevención de lavado de dinero

Controles que ya existen

Familia	Estado actual
Perímetro	Cortafuegos perimetrales administrados por TI
Antimalware	Antivirus corporativo en estaciones y servidores Windows
Respaldos	Diarios, con copia en el sitio de contingencia; pruebas parciales y poco frecuentes
Monitoreo	Sin SIEM ni monitoreo centralizado
Vulnerabilidades	Sin programa formal; parches aplicados cuando el proveedor lo pide
Segmentación	Red interna plana entre sucursales y centro de datos, salvo el entorno de tarjetas
Accesos	Segundo factor solo para la banca en línea de clientes; no para administradores

4.2 Red Hospitalaria Metropolitana (RHM)

Grupo de Implementación asignado: IG3. Información de salud del paciente, equipo médico conectado y consecuencias directas sobre la seguridad de las personas.

Datos básicos de la empresa

- **Sector:** Salud.
- **Tamaño:** Grande (950 empleados, incluyendo personal médico).
- **Ubicación:** Hospital principal en San Salvador y 3 clínicas especializadas en Santa Ana y San Miguel.
- **Misión:** Proporcionar atención médica de excelencia, integrando tecnología de vanguardia y un enfoque humano para salvaguardar la salud y el bienestar de nuestros pacientes.
- **Visión:** Ser la institución hospitalaria líder en Centroamérica, reconocida por su innovación, seguridad del paciente y resultados clínicos.
- **Estructura Organizacional Básica:** Dirección General, Dirección Médica, Administración, Finanzas, Departamento de TI, Operaciones, Calidad y Seguridad del Paciente.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Servicios hospitalarios completos, cirugía, cuidados intensivos, diagnósticos por imagen, laboratorio clínico.
- **Clientes:** Pacientes particulares y afiliados a compañías de seguros.

Procesos Críticos (4):

  - **1. Gestión de Expedientes Clínicos Electrónicos (EHR):** Administración y protección de la información de salud del paciente.
  - **2. Operación de Equipo Médico Conectado (IoMT):** Funcionamiento de monitores de signos vitales, bombas de infusión y equipos de diagnóstico en red.
  - **3. Sistema de Admisión y Facturación:** Registro de pacientes y procesamiento de cobros a seguros y particulares.
  - **4. Gestión de Farmacia y Laboratorio (LIS):** Control de inventario de medicamentos y procesamiento de resultados de laboratorio.

- **Dependencia Tecnológica:** Crítica. Fallos tecnológicos pueden poner en riesgo directo la vida de los pacientes.

Infraestructura tecnológica inicial

- **Sistemas:** Sistema EHR/HIS de Cerner, sistema de imágenes (PACS), sistema de información de laboratorio (LIS), Microsoft 365.
- **Red y Comunicaciones:** Centro de datos local con alta virtualización (VMware). Red segmentada de forma básica (administrativa, médica, invitados), pero con controles de acceso laxos entre segmentos.
- **Madurez y Controles Actuales:** Nivel bajo. Se enfocan en la disponibilidad pero descuidan la confidencialidad e integridad. No hay un inventario de dispositivos médicos en red (IoMT), el software de los equipos rara vez se actualiza y no hay monitoreo de seguridad activo, lo que los expone a ataques dirigidos.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales	USD 62 M	55–70 M	Hospitalización y cirugía 55 %, diagnóstico por imagen y laboratorio 25 %, consulta 20 %; 60 % se factura a aseguradoras
Margen operativo	9 %	6–12 %	Sobre ingresos
Temporada alta	Temporada de lluvias (junio a octubre) por dengue y enfermedades respiratorias	—	Ocupación frente al promedio: 1,3 (1,2–1,5)
Cirugías programadas	22 por día hábil, en un horario de quirófano de 10 horas	18–26	Ingreso promedio por cirugía USD 3 800 (3 200–4 400); una cirugía cancelada no se recupera ese día
Pacientes con expediente clínico	310 000	280 000–340 000	Datos de salud: categoría sensible de la LPDP
Costo de notificar a un paciente	USD 0,40	0,30–0,60	Cotización vigente de mensajería y correo
Costo de reposición del entorno del expediente clínico	USD 800 000	650 000–950 000	Servidores, licencias, migración y validación clínica
Dispositivos médicos conectados	Entre 350 y 500, según Biomédica	—	No existe inventario; el número no es exacto

Operación por proceso

Proceso	Gestión de expedientes clínicos electrónicos (EHR)
Horario	24 horas, todos los días; quirófanos de 7:00 a 17:00
Personal en turno y costo	260 personas clínicas en turno que dependen del expediente; costo cargado USD 12,00 por hora (±15 %)
Procedimiento alterno	Registro en papel con formularios preimpresos, sostenible hasta 8 horas según la Dirección Médica; costo adicional USD 500 por hora; lo registrado en papel se reintroduce después
Penalizaciones	Ninguna contractual; las cirugías canceladas se reprograman sin cobro

Proceso	Gestión de expedientes clínicos electrónicos (EHR)
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: médicos deciden sin historial de alergias ni medicación; se cancelan cirugías programadas · 24 h: se desvían ingresos de emergencia a otros hospitales; errores de medicación posibles · 72 h: queja formal ante el Consejo Superior de Salud Pública; cobertura en medios · 1 semana: aseguradoras suspenden autorizaciones; pérdida de pacientes · 1 mes: riesgo para la habilitación del hospital

Proceso	Operación de equipo médico conectado (IoMT)
Horario	24 horas, todos los días
Personal en turno y costo	Mismo personal clínico; 6 técnicos de Biomédica por turno
Procedimiento alterno	Vigilancia manual de signos vitales por enfermería y bombas en modo local; eleva la carga de enfermería
Penalizaciones	Ninguna contractual
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: vigilancia manual en cuidados intensivos; riesgo directo para pacientes críticos · 24 h: traslado de pacientes críticos a otros hospitales · 72 h: cierre temporal de cuidados intensivos · 1 semana: investigación del Ministerio de Salud · 1 mes: pérdida de la acreditación de cuidados intensivos

Proceso	Admisión y facturación
Horario	24 horas en emergencia; admisión programada de 6:00 a 20:00
Personal en turno y costo	45 personas por turno; costo cargado USD 6,00 por hora
Procedimiento alterno	Admisión en papel y facturación diferida
Penalizaciones	Las aseguradoras rechazan cobros presentados después de 30 días
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: filas en admisión; facturación diferida · 24 h: cobros a aseguradoras detenidos · 72 h: flujo de caja afectado · 1 semana: cobros cerca del plazo de 30 días · 1 mes: rechazos de aseguradoras por cobros vencidos

Proceso	Farmacia y laboratorio (LIS)
Horario	24 horas, todos los días
Personal en turno y costo	70 personas por turno; costo cargado USD 8,00 por hora
Procedimiento alterno	Dispensación con recetas en papel y resultados de laboratorio entregados en papel
Penalizaciones	Ninguna contractual; muestras que vencen se repiten sin cobro
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: resultados en papel más lentos; retrasos en diagnósticos · 24 h: control de medicamentos controlados en riesgo · 72 h: faltantes de medicamentos por inventario sin registrar · 1 semana: observación del regulador de medicamentos · 1 mes: descuadre de inventario y pérdidas por vencimiento

Tecnología

Elemento	Situación actual
Expediente clínico y gestión hospitalaria	Cerner Millennium (Oracle Health) en servidores locales virtualizados
Imágenes y laboratorio	PACS para diagnóstico por imagen; sistema de información de laboratorio (LIS) integrado al expediente
Virtualización y centro de datos	Centro de datos local en el hospital principal con VMware vSphere 7.0; almacenamiento primario sin réplica
Oficina e identidad	Microsoft 365; Active Directory en Windows Server 2016; estaciones con Windows 10 y Windows 11
Red	Red segmentada en administrativa, médica e invitados, con reglas de acceso laxas entre segmentos; enlaces dedicados a las tres clínicas
Equipo médico	Monitores de signos vitales, bombas de infusión y equipos de diagnóstico de varios fabricantes, con software que rara vez se actualiza

Respaldos y continuidad

Sistema	Situación actual
Expediente clínico	Respaldo nocturno de las máquinas virtuales a un NAS en el mismo centro de datos; última restauración de prueba hace más de dos años
PACS	Respaldo semanal de imágenes a discos externos
Laboratorio y farmacia	Respaldo nocturno junto con el expediente
Sitio alterno	No existe

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Ransomware en una clínica de Santa Ana, contenido en dos estaciones	3 días de trabajo manual en la clínica	USD 25 000
2024	Falla del almacenamiento primario	6 horas con registro en papel	Cirugías del día reprogramadas
2025	Fuga de resultados de laboratorio por correo enviado a un destinatario equivocado	—	Queja de un paciente; sin sanción
2026	Bomba de infusión con software desactualizado desconectada por falla de red	2 horas	Sin daño al paciente

Organización y presupuesto

Dato	Valor
Organigrama	Dirección General; Dirección Médica; Administración; Finanzas; Departamento de TI (12 personas); Operaciones; Calidad y Seguridad del Paciente. RR. HH. depende de Administración. Asesoría legal externa; sin auditoría interna propia
Presupuesto aprobado para seguridad	2027: USD 420 000 (250 000 de inversión y 170 000 de operación). 2028 y 2029: mismo nivel, sujeto a aprobación

Dato	Valor
Arranque del programa de seguridad	Aprobado por la Dirección General para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Regulación sanitaria del Ministerio de Salud y del Consejo Superior de Salud Pública; Ley para la Protección de Datos Personales (datos de salud); contratos con aseguradoras

Controles que ya existen

Familia	Estado actual
Disponibilidad	Virtualización con alta disponibilidad de servidores; sin réplica del almacenamiento
Inventario	No hay inventario de dispositivos médicos en red
Parches	El software de los equipos médicos rara vez se actualiza; los servidores, cada trimestre
Monitoreo	Sin monitoreo de seguridad
Segmentación	Tres segmentos con reglas laxas entre ellos
Antimalware	Antivirus en estaciones y servidores Windows

4.3 ComunicaTel El Salvador

Grupo de Implementación asignado: IG3. Infraestructura crítica de telecomunicaciones, datos de tráfico de abonados y obligación de continuidad nacional.

Datos básicos de la empresa

- **Sector:** Telecomunicaciones.
- **Tamaño:** Grande (800 empleados).
- **Ubicación:** Oficinas corporativas en Santa Tecla y varios centros de datos y radiobases a nivel nacional.
- **Misión:** Conectar a El Salvador a través de servicios de comunicación confiables, rápidos y seguros, promoviendo el desarrollo digital del país.
- **Visión:** Ser la empresa de telecomunicaciones preferida, impulsando la innovación en servicios móviles, de internet y corporativos.
- **Estructura Organizacional Básica:** Dirección Ejecutiva, Unidad de Negocio Móvil, Unidad de Negocio Corporativo, Ingeniería y Operaciones de Red, TI, Finanzas.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Telefonía móvil (4G/5G), internet de fibra óptica (FTTH), soluciones de conectividad para empresas.
- **Clientes:** Mercado masivo (B2C) y clientes corporativos (B2B).

Procesos Críticos (3):

  - **1. Operación y Mantenimiento del Core de Red:** Garantizar la disponibilidad y estabilidad de los servicios de voz y datos a nivel nacional.
  - **2. Sistemas de Facturación y Cobro (BSS):** Procesamiento de datos de consumo de millones de usuarios y generación de facturas.

  - **3. Gestión de la Infraestructura Crítica:** Monitoreo y protección de radiobases, fibra óptica y centros de datos.
- **Dependencia Tecnológica:** Crítica. Es parte de la infraestructura esencial del país.

Infraestructura tecnológica inicial

- **Sistemas:** Plataformas de red de Ericsson y Huawei, sistemas de soporte al negocio (BSS/OSS), bases de datos Oracle masivas, entorno de virtualización para servicios de TI.
- **Red y Comunicaciones:** Red IP/MPLS a nivel nacional, múltiples centros de datos distribuidos.
- **Madurez y Controles Actuales:** Nivel intermedio. Poseen equipos de seguridad de red robustos (Firewalls, IPS), pero el monitoreo de seguridad se centra en la disponibilidad de la red, no en amenazas avanzadas. La seguridad de las aplicaciones internas y la gestión de acceso privilegiado son áreas muy débiles.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales	USD 290 M	260–320 M	Móvil 62 % (prepago 35 %, pospago 27 %), fibra FTTH 18 %, soluciones corporativas 20 % (USD 58 M)
Margen EBITDA	31 %	27–35 %	Sobre ingresos; margen neto 7 % (5–9 %)
Temporada alta	Diciembre y Semana Santa; temporada de lluvias para la infraestructura	—	Tráfico de datos frente al mes promedio: diciembre 1,3 (1,2–1,5). Recargas prepago en quincena frente al día promedio: 1,8 (1,5–2,1)
Abonados y datos personales	2,4 millones de abonados	2,2–2,6 millones	2,1 millones de líneas móviles (70 % prepago), 190 000 hogares con fibra y 6 500 clientes corporativos; identificación, tráfico y localización de cada abonado
Volumen de transacciones	65 millones de registros de uso (CDR) por día	55–75 millones	1,1 millones de facturas al mes; 18 millones de recargas prepago al mes
Pagos con tarjeta	4,2 millones al año por portal, app y tiendas	3,6–4,8 millones	Comercio de nivel 2 de PCI DSS con cuestionario de autoevaluación anual
Costo de notificar a un abonado	USD 0,03	0,02–0,06	SMS propio y correo; carta certificada a clientes corporativos USD 4,50
Costo de reposición de equipos clave	USD 18 M por el core móvil de un centro de datos	15–22 M	Núcleo de paquetes y de voz (EPC, 5G Core e IMS); una radiobase completa USD 150 000 (120 000–190 000)

Operación por proceso

Proceso	Operación y mantenimiento del core de red
Horario	24 horas, todos los días; ventanas de mantenimiento de 0:00 a 4:00

Proceso	Operación y mantenimiento del core de red
Personal en turno y costo	NOC de red con 30 personas por turno y 12 ingenieros de guardia; costo cargado USD 14 por hora (±15 %)
Procedimiento alterno	El core de voz está duplicado en dos centros de datos con conmutación automática; el core de datos se conmuta a mano en 2 a 4 horas según Ingeniería; para el abonado no hay alternativa
Penalizaciones	SLA con clientes corporativos: crédito del 10 % de la mensualidad por cada 4 horas por debajo de la disponibilidad mensual de 99,9 %; compromisos de continuidad del título habilitante ante la SIGET
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: caída de voz y datos regional o nacional; llamadas al 911 afectadas; reclamos masivos y cobertura nacional · 24 h: créditos de SLA a clientes corporativos; comercios sin cobro con terminales inalámbricas; intervención del regulador · 72 h: clientes corporativos negocian migrar a la competencia; recargas prepago perdidas · 1 semana: rescisión de contratos corporativos; proceso sancionatorio · 1 mes: pérdida de participación de mercado que la Dirección Ejecutiva estima recuperar en años

Proceso	Sistemas de facturación y cobro (BSS)
Horario	Mediación y tasación 24 horas; cuatro ciclos de facturación al mes; recargas en línea 24 horas
Personal en turno y costo	55 personas de facturación, cobros y soporte BSS por turno; costo cargado USD 11 por hora (±15 %)
Procedimiento alterno	La mediación retiene los registros de uso hasta 72 horas para tasarlos después; en prepago, la Dirección Ejecutiva decide entre dejar consumir sin descontar saldo o bloquear el servicio; las recargas en línea no tienen alternativa
Penalizaciones	Ninguna contractual; reclamos ante la Defensoría del Consumidor por cobros erróneos
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: recargas detenidas; consumo prepago sin descontar o servicio bloqueado · 24 h: ciclo de facturación retrasado; filas y reclamos en tiendas · 72 h: la mediación se llena y se pierden registros de uso que ya no se cobran · 1 semana: facturas erróneas masivas y reclamos ante la Defensoría del Consumidor · 1 mes: flujo de caja afectado y revisión del regulador

Proceso	Gestión de la infraestructura crítica (radiobases, fibra y centros de datos)
Horario	24 horas, todos los días
Personal en turno y costo	Centro de operaciones de infraestructura con 10 personas por turno y 160 técnicos de campo en tres turnos; costo cargado USD 9 por hora (±15 %)
Procedimiento alterno	Rondas y patrullaje físico de sitios; 60 generadores portátiles para 1 850 radiobases; baterías con autonomía de 4 horas (2–6) en cada radiobase
Penalizaciones	Contratos de compartición de torres con otros operadores: USD 250 por día por sitio caído

Proceso	Gestión de la infraestructura crítica (radiobases, fibra y centros de datos)
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: radiobases sin energía al agotarse las baterías; zonas sin cobertura · 24 h: robo de baterías y cable sin detectar; cortes de fibra sin localizar · 72 h: regiones completas sin servicio · 1 semana: incumplimiento de la cobertura comprometida ante el regulador · 1 mes: reposición costosa de sitios y pérdida de clientes en las zonas afectadas

Tecnología

Elemento	Situación actual
Core de red	Núcleo de paquetes y de voz Ericsson (EPC, 5G Core e IMS) en dos centros de datos; red de acceso de radio Huawei 4G/5G; OLT Huawei para FTTH
BSS/OSS	Facturación convergente y cobro en línea de un proveedor internacional sobre Oracle Database 19c en Oracle Exadata X8M; mediación de registros de uso; OSS de gestión de fallas de cada fabricante
Virtualización y servidores	VMware vSphere 8.0 para los servicios de TI; Red Hat Enterprise Linux 8 y Windows Server 2019
Oficina e identidad	Active Directory en Windows Server 2019; Microsoft 365; estaciones con Windows 11
Red y seguridad	Red IP/MPLS nacional con enrutadores Cisco IOS XR 7; cortafuegos Palo Alto con PAN-OS 11.1 e IPS; tres centros de datos (Santa Tecla, San Salvador y San Miguel)
Aplicaciones propias	Portal de autogestión y app de clientes desarrollados por un equipo interno de 25 personas

Respaldos y continuidad

Sistema	Situación actual
Core de red	Configuraciones respaldadas cada noche en el servidor de gestión de cada fabricante; core de voz duplicado en dos centros de datos
BSS	Oracle Data Guard con réplica al segundo centro de datos cada 5 minutos; respaldo diario a disco y semanal a cinta
Servicios de TI	Respaldo diario de las máquinas virtuales a disco en el mismo centro de datos
Última prueba de recuperación	Conmutación del core de voz en 2025, exitosa en 20 minutos; la recuperación completa del BSS nunca se ha probado

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Corte de fibra troncal por obra pública entre San Salvador y la zona oriental	9 horas	USD 60 000 en créditos de SLA
2024	Robo de baterías y cable en 35 radiobases durante una tormenta	Hasta 3 días por sitio	USD 210 000 en reposición
2025	Toma de una cuenta de administrador del BSS con credenciales filtradas, detectada por consumo anómalo	2 días	USD 45 000 en fraude de recargas

Año	Incidente	Duración	Costo
2026	Denegación de servicio contra el portal de autogestión	6 horas	Sin pérdida económica; reclamos en redes sociales

Organización y presupuesto

Dato	Valor
Organigrama	Dirección Ejecutiva; Unidades de Negocio Móvil y Corporativo; Ingeniería y Operaciones de Red; TI (70 personas); Finanzas, que incluye RR. HH.; Dirección Jurídica y Regulatoria; Auditoría Interna, que reporta al Comité de Auditoría de la Junta Directiva. Un oficial de seguridad de la información en TI, sin equipo propio
Presupuesto aprobado para seguridad	2027: USD 2,1 M (1,3 M de inversión y 0,8 M de operación). 2028 y 2029: +5 % anual, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por la Dirección Ejecutiva para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Ley de Telecomunicaciones y regulación de la SIGET; Ley para la Protección de Datos Personales (datos de tráfico y localización de los abonados); PCI DSS como comercio; SLA con clientes corporativos

Controles que ya existen

Familia	Estado actual
Perímetro	Cortafuegos de nueva generación con IPS en el borde de internet y entre centros de datos
Monitoreo	NOC de 24 horas centrado en la disponibilidad; sin SIEM ni monitoreo de amenazas
Accesos privilegiados	Cuentas de administrador compartidas en el core y en el BSS; sin bóveda de contraseñas ni grabación de sesiones
Aplicaciones	Sin pruebas de seguridad del código del portal ni de la app antes de publicar
Antimalware	Antivirus corporativo en estaciones y servidores Windows
Parches	Mensuales en TI; en el core, según las ventanas que fija el fabricante
Seguridad física	Tarjeta de acceso y video en centros de datos; radiobases con cerca y alarma local, sin monitoreo centralizado

4.4 Energía Nacional S.A. de C.V. (ENSA)

Grupo de Implementación asignado: IG3. Tecnología de operación del sistema eléctrico: la indisponibilidad afecta a terceros ajenos a la empresa.

Datos básicos de la empresa

- **Sector:** Energía y Servicios Públicos.
- **Tamaño:** Mediana (550 empleados).
- **Ubicación:** Centro de operaciones en San Salvador, con subestaciones en todo el territorio.

- **Misión:** Distribuir energía eléctrica de manera segura, confiable y eficiente, contribuyendo al desarrollo sostenible de El Salvador.
- **Visión:** Ser un referente en la modernización del sector energético, integrando redes inteligentes y fuentes de energía renovable.
- **Estructura Organizacional Básica:** Gerencia General, Gerencia de Operaciones de Red, Gerencia Comercial, Gerencia Técnica, Finanzas, TI/TO.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Distribución de energía eléctrica a clientes residenciales e industriales.
- **Clientes:** Población general y sector industrial del país.

Procesos Críticos (4):

  - **1. Operación de la Red de Control (SCADA/OT):** Monitoreo y control en tiempo real de la red de distribución eléctrica.
  - **2. Gestión de Medición Inteligente (AMI):** Recolección y procesamiento de datos de consumo de medidores inteligentes.
  - **3. Sistema de Gestión de Interrupciones (OMS):** Respuesta y restauración del servicio durante apagones.
  - **4. Sistema Comercial y de Facturación:** Procesamiento de lecturas y emisión de facturas a cientos de miles de clientes.

- **Dependencia Tecnológica:** Crítica. Un ciberataque exitoso podría causar un apagón a nivel nacional.

Infraestructura tecnológica inicial

- **Sistemas:** Sistemas SCADA de Siemens, red de tecnología operacional (OT) aislada, sistema de facturación SAP IS-U, plataforma de geolocalización (GIS).
- **Red y Comunicaciones:** Red OT físicamente separada de la red de TI, pero con puntos de conexión inseguros. Red corporativa de TI tradicional.
- **Madurez y Controles Actuales:** Madurez dual. La seguridad en la red OT es reactiva y se basa en el "air gap" (aislamiento), que en la práctica no es real. En la red de TI, tienen controles básicos, pero no existe una estrategia de seguridad unificada que contemple la convergencia TI/OT, representando un riesgo existencial para la operación.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales (venta de energía y cargos de distribución)	USD 360 M	330–390 M	Clientes residenciales 55 %, industriales y comerciales 45 %; la compra de energía en el mercado mayorista se traslada a la tarifa
Margen de la energía que distribuyen las doce subestaciones principales	USD 6,0 M al año	4,5–8,0 M	Margen de distribución después de la compra de energía, según Finanzas; esas doce subestaciones entregan cerca del 92 % de la energía

Dato	Valor probable	Rango	Detalle
Temporada alta	Temporada de lluvias y tormentas eléctricas: mayo a octubre, con picos en junio y septiembre	—	Frente al promedio anual, según Operaciones de Red: fallas simultáneas 2,2; costo de atender una contingencia 1,6; avisos de falla 2,8. Las cifras de costo por hora de esta ficha corresponden a la temporada de lluvias. Demanda máxima diaria de 18:00 a 21:00 en días hábiles, con 1,4 veces los clientes afectados por hora. Mantenimiento mayor de subestaciones de enero a marzo. Cierre de ciclo comercial: 1,9 veces la carga de facturación; cierre diario de lecturas AMI: 1,5
Demanda atendida y tarifa	190 MW de demanda media en las doce subestaciones principales; tarifa media de venta USD 200 por MWh	120–275 MW	Rango de demanda media según la hora y la temporada; la tarifa media la fija el pliego tarifario vigente
Subestaciones con equipo de control conectado al SCADA	12 principales	8–20	Operaciones de Red cuenta doce; el inventario de la red OT está desactualizado y el conteo con las secundarias de telecontrol parcial va de 8 a 20
Clientes y datos personales	420 000 clientes	400 000–440 000	405 000 residenciales y 15 000 industriales y comerciales; nombre, DUI, dirección, consumo y medio de pago en SAP IS-U; 180 000 medidores inteligentes
Pagos con tarjeta	1,3 millones de pagos al año por el portal y la app	1,0–1,6 millones	Una pasarela de pagos externa procesa los datos de tarjeta; comercio de nivel 2 de PCI DSS con cuestionario de autoevaluación anual
Costo de notificar a un cliente	USD 0,25	0,15–0,40	Aviso en la factura, SMS y correo; cotización vigente del proveedor de mensajería
Costo de reposición de la plataforma SCADA	USD 3,0 M	2,0–4,0 M	Servidores, estaciones HMI, licencias e implantación. Otras plataformas: OMS y GIS USD 2,6 M; SAP IS-U y portal de clientes USD 3,1 M; cabecera AMI y concentradores USD 1,2 M
Soporte de emergencia del fabricante del SCADA	USD 3 000 por hora	2 500–3 500	Fuera del contrato anual, incluye consultoría; el fabricante llega a sitio en 8 horas

Operación por proceso

Proceso	Operación de la red de control (SCADA/OT)
Horario	24 horas, los 365 días, sin ventana de detención programada

Proceso	Operación de la red de control (SCADA/OT)
Personal en turno y costo	Centro de control: 8 operadores por turno. En operación manual se movilizan 12 operadores de campo (uno por subestación principal) y 2 coordinadores en horario extraordinario, a USD 25 por hora cada uno (±15 %), y cuadrillas contratistas de apoyo a USD 305 por hora por cuadrilla; en temporada de lluvias salen 30 cuadrillas
Procedimiento alterno	Operación manual: personal en cada subestación principal, maniobras ordenadas por radio troncalizado desde el centro de control y registro en el formulario impreso F-OP-12; costo adicional USD 7 000 por hora (flota, viáticos, equipo de medición portátil y radio). Operaciones de Red lo considera sostenible 12 horas con un solo relevo (8–16); el simulacro de marzo de 2026 lo sostuvo 8 horas con relevo completo
Penalizaciones	Contratos de calidad de suministro con clientes industriales: USD 4 500 por hora de interrupción en conjunto (2 000–9 000, según los clientes afectados). Compensaciones reguladas a los usuarios por interrupciones, según las Normas de Calidad del Servicio de los Sistemas de Distribución de la SIGET
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: operación manual al límite de su relevo; maniobras sin telemetría en subestaciones energizadas; reporte obligatorio de la interrupción; cobertura local · 24 h: procedimiento alterno agotado; la red no se reconfigura ante nuevas fallas; riesgo para cuadrillas y para clientes con equipo de soporte vital; cobertura nacional · 72 h: apagones extendidos con daño a terceros; proceso sancionatorio del regulador · 1 semana: indicadores de continuidad del año incumplidos; reclamos formales de clientes industriales · 1 mes: riesgo sobre la concesión y daño a la reputación que la Gerencia General considera irreversible

Proceso	Gestión de medición inteligente (AMI)
Horario	24 horas, con cierre diario de lecturas y ciclo de facturación mensual
Personal en turno y costo	25 personas de medición y analítica de la Gerencia Técnica por turno; costo cargado USD 10 por hora (±15 %)
Procedimiento alterno	Lectura manual del 15 % de clientes de mayor consumo con 40 lectores contratistas a USD 35 por hora cada uno (vehículo incluido) y estimación del consumo del resto; la Gerencia Técnica lo considera sostenible 15 días antes de comprometer el ciclo de facturación
Penalizaciones	Ninguna contractual. La Gerencia Técnica estima USD 1 250 por hora (800–1 800) en consumo mal facturado por estimación y en fraude que deja de detectarse
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: lecturas del día en cola en los concentradores; sin efecto en clientes · 24 h: lecturas del cierre diario perdidas en parte; arranca la lectura manual · 72 h: consumo estimado en zonas completas; detección de fraude detenida · 1 semana: facturas con consumo estimado; reclamos y queja ante el regulador · 1 mes: ciclo de facturación comprometido y pérdida de ingresos por consumo no medido

Proceso	Sistema de gestión de interrupciones (OMS)
Horario	24 horas, todos los días, con picos en temporada de lluvias
Personal en turno y costo	6 despachadores por turno; en temporada de lluvias hay 40 cuadrillas en turno, propias y contratistas; una cuadrilla detenida o sin despacho cuesta USD 150 por hora (±15 %)

Proceso	Sistema de gestión de interrupciones (OMS)
Procedimiento alterno	Despacho con planillas impresas y radio troncalizado; avisos al cliente por el centro de contacto, reforzado con 30 agentes temporales a un costo adicional de USD 1 500 por hora; sostenible 24 horas con dos relevos
Penalizaciones	Compensaciones reguladas cuando la restauración excede los tiempos de la norma de calidad de la SIGET: Comercial las estima en USD 11 000 por hora de retraso en temporada de lluvias (7 000–16 000)
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: restauración coordinada a ciegas; clientes sin información de su avería; centro de contacto saturado · 24 h: cuadrillas duplicadas o sin despacho; tiempos de restauración fuera de la norma y compensaciones a usuarios · 72 h: proceso sancionatorio por indicadores de calidad; cobertura nacional · 1 semana: reclamos masivos ante el regulador y la Defensoría del Consumidor · 1 mes: indicadores de calidad del año incumplidos

Proceso	Sistema comercial y de facturación (SAP IS-U)
Horario	Lunes a sábado de 6:00 a 22:00; cierre de ciclo el último día hábil del mes; portal y app de pagos 24 horas
Personal en turno y costo	120 personas de la Gerencia Comercial y de agencias por turno; costo cargado USD 10 por hora (±15 %)
Procedimiento alterno	Facturación del ciclo con la lectura estimada del período anterior para todos los clientes regulados y emisión diferida, sin cobro en línea; refuerzo del centro de contacto a USD 1 500 por hora; Comercial lo considera sostenible 7 días antes de afectar el flujo de caja
Penalizaciones	Ninguna contractual. Finanzas estima el costo financiero de facturar y cobrar tarde en USD 4 700 por hora durante el cierre de ciclo (3 500–6 000), por el uso de la línea de crédito de corto plazo
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: pagos en línea y en agencias detenidos; filas y reclamos · 24 h: facturas del ciclo retrasadas; cobro detenido · 72 h: cierre de ciclo fuera de plazo; uso de la línea de crédito · 1 semana: flujo de caja afectado; reclamos ante la Defensoría del Consumidor por cobros estimados · 1 mes: atraso en los pagos de energía del mercado mayorista y observación del regulador

Tecnología

Elemento	Situación actual
Sistema de control (SCADA)	Siemens Spectrum Power 7 en servidores con Windows Server 2019; estaciones HMI con Windows 10 Enterprise LTSC 2019; red OT con conmutadores Siemens RUGGEDCOM; enlaces por fibra y radio con las subestaciones
Medición inteligente (AMI)	Cabecera AMI en Red Hat Enterprise Linux 8 con Oracle Database 19c; 180 000 medidores y un concentrador de datos por zona, con comunicación celular
OMS y GIS	OMS integrado con el SCADA y con Esri ArcGIS Enterprise 11; aplicación móvil de cuadrillas en Android
Sistema comercial	SAP IS-U sobre SAP ERP 6.0 EHP8 con SAP HANA 2.0 en SUSE Linux Enterprise Server 15; portal de clientes y app; un solo enlace con la pasarela de pagos

Elemento	Situación actual
Oficina e identidad	Active Directory en Windows Server 2019; Microsoft 365; estaciones con Windows 11 en el parque nuevo y Windows 10 en el heredado; herramienta de gestión de servicios con el inventario de TI
Red	Red corporativa de TI y red OT separadas físicamente, con puntos de conexión para el intercambio de datos del SCADA con el OMS y el sistema comercial; cortafuegos corporativos Fortinet FortiGate con FortiOS 7.2; radio troncalizado con repetidores en tres cerros
Acceso de terceros	El fabricante del SCADA entra en remoto para mantenimiento con un usuario compartido y acceso permanente

Respaldos y continuidad

Sistema	Situación actual
SCADA	Configuración y base de datos de tiempo real respaldadas en cinta una vez por semana; sin copia aislada ni prueba de restauración documentada
Sistema comercial	Respaldo nocturno de SAP IS-U a disco en el centro de datos corporativo y copia semanal a cinta guardada en el centro de operaciones
AMI y OMS	Respaldo nocturno de las bases de datos a disco local
Centro de control alterno	No existe; hay un puesto de mando móvil sin equipar
Energía y comunicaciones	Planta eléctrica en el centro de control, con prueba trimestral registrada y combustible por contrato con entrega en 6 horas; uno de los tres repetidores de radio no tiene respaldo de energía (hallazgo del simulacro de marzo de 2026)

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Phishing que robó la contraseña de un analista comercial, usada para consultar la base de clientes	2 días hasta cambiar la contraseña	Sin pérdida económica registrada
2024	Malware en la laptop de un contratista conectada a la red OT durante un mantenimiento; el antivirus lo detectó al volver a la red de TI	1 día	Sin afectación de la operación
2025	Caída del enlace con la pasarela de pagos	7 horas	Cobro en línea detenido; reclamos en redes sociales
2026	Tormenta con fallas simultáneas en junio; el centro de contacto se saturó de avisos	14 horas	USD 120 000 en compensaciones y horas extra

Organización y presupuesto

Dato	Valor
Organigrama	Junta Directiva; Gerencia General; Gerencias de Operaciones de Red, Comercial y Técnica; Finanzas, que incluye RR. HH.; TI/TO con 22 personas (16 de TI y 6 de TO). Asesoría legal interna de dos abogados en la Gerencia General; auditoría interna de una persona que reporta a la Junta Directiva. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 480 000 (310 000 de inversión y 170 000 de operación), con tres plazas nuevas: jefatura, analista de seguridad de TI y analista de seguridad de TO, más la dedicación parcial de dos ingenieros de Operaciones de Red. 2028 y 2029: mismo nivel, sujeto a aprobación; la Junta Directiva lo ajustaría entre USD 300 000 y 600 000 según los resultados del primer año
Arranque del programa de seguridad	Aprobado por la Gerencia General para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Ley General de Electricidad y Normas de Calidad del Servicio de los Sistemas de Distribución de la SIGET (indicadores de interrupción, reporte y compensaciones a usuarios); intercambio de información de operación con la Unidad de Transacciones; Ley para la Protección de Datos Personales; PCI DSS por medio de la pasarela de pagos

Controles que ya existen

Familia	Estado actual
Inventario	Inventario de activos y de software de TI en la herramienta de gestión de servicios; no cubre la red OT, el firmware de los equipos de control ni los concentradores AMI
Datos	Listas de control de acceso en el sistema comercial, ausentes en los repositorios de operación; la cabecera AMI cifra la comunicación con los concentradores y las extracciones del sistema comercial viajan sin cifrar; datos de clientes y de operación en sistemas distintos, sin segmentar el almacenamiento
Cuentas y accesos	Cuentas centralizadas en Active Directory con política de contraseñas en TI; el entorno OT usa cuentas locales fuera de esa política; ningún acceso exige segundo factor
Antimalware	Antivirus corporativo con firmas automáticas en servidores y estaciones de TI; en el entorno de control, ausente o con firmas cargadas a mano de forma esporádica
Estaciones y correo	Cortafuegos local activo en el parque nuevo; navegador y cliente de correo soportados con actualización automática; filtro de correo con firmas, sin análisis en entorno aislado
Parches	Mensuales en TI; en OT, cuando el fabricante lo autoriza, sin calendario
Monitoreo	Sin monitoreo de seguridad ni recolección centralizada de bitácoras; en OT las bitácoras quedan en cada equipo
Segmentación	Separación física de TI y OT con puntos de conexión sin filtro documentado

4.5 Dirección General de Identificación Nacional (DGIN)

Grupo de Implementación asignado: IG3. Registro de identidad y datos biométricos de la población, con exposición a adversarios con recursos de Estado.

Datos básicos de la empresa

- **Sector:** Gobierno.

- **Tamaño:** Mediana (450 empleados).
- **Ubicación:** Edificio central en San Salvador y centros de emisión a nivel nacional.
- **Misión:** Garantizar el derecho a la identidad de todos los ciudadanos, administrando el registro nacional de identificación de forma segura, eficiente y transparente.
- **Visión:** Ser una entidad gubernamental modelo en el uso de tecnología para la protección de datos personales y la prestación de servicios de identificación de clase mundial.
- **Estructura Organizacional Básica:** Dirección General, Subdirección de Registro, Subdirección de Tecnología, Subdirección Jurídica, Administración.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Emisión de documentos de identidad, validación de identidad para entidades públicas y privadas.
- **Clientes:** Todos los ciudadanos del país y entidades que requieren validación de identidad.

Procesos Críticos (3):

  - **1. Gestión de la Base de Datos Biográfica y Biométrica:** Almacenamiento y protección de los datos personales (nombres, dirección, huellas, rostro) de toda la población.
  - **2. Proceso de Emisión y Activación de Documentos:** Ciclo de vida de la creación de un nuevo documento de identidad, desde la solicitud hasta la entrega.
  - **3. Servicios de Verificación de Identidad:** Provisión de APIs seguras para que bancos y otras instituciones validen la identidad de una persona.

- **Dependencia Tecnológica:** Crítica. La integridad y confidencialidad de la base de datos es un asunto de seguridad nacional.

Infraestructura tecnológica inicial

- **Sistemas:** Base de datos Oracle Exadata, sistema de gestión biométrica (AFIS), aplicación de registro desarrollada internamente, infraestructura de clave pública (PKI) para los documentos.
- **Red y Comunicaciones:** Centro de datos gubernamental de alta seguridad física, pero con seguridad lógica deficiente.
- **Madurez y Controles Actuales:** Nivel bajo. A pesar de la seguridad física, los controles lógicos son débiles. El desarrollo de software no sigue un ciclo de vida seguro (DevSecOps), hay una gestión de parches deficiente en servidores críticos y el monitoreo de acceso a la base de datos es casi nulo.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Presupuesto operativo anual	USD 38 M	34–42 M	Asignación del Presupuesto General del Estado 70 %; tasas por emisión de documentos y por verificación de identidad 30 %
Ingresos propios (equivalente al margen)	USD 11,4 M al año	10–13 M	Tasas por verificación (USD 0,04 por consulta) y por documento (tasa media USD 8; el primer documento no tiene costo); se trasladan al Fondo General

Dato	Valor probable	Rango	Detalle
Temporada alta	Enero a marzo y los meses previos a un proceso electoral	—	Solicitudes frente al mes promedio: inicio de año 1,5 (1,3–1,8); antes de una elección 2,2 (1,8–2,6)
Personas registradas	5,4 millones	5,2–5,6 millones	Datos biográficos y biométricos (diez huellas y rostro), incluidos salvadoreños en el exterior; el registro tiene teléfono del 60 % de los titulares
Volumen de transacciones	3 000 documentos emitidos por día hábil	2 500–3 800	450 000 consultas de verificación por día (380 000–520 000) de 62 entidades, sobre todo bancos, unos 300 días al año
Costo de notificar a un titular	USD 0,60	0,40–0,90	Carta y SMS; cotización vigente del servicio postal y de mensajería
Costo de reposición de equipos clave	USD 6,5 M	5,5–7,5 M	Oracle Exadata, servidores y licencias del AFIS; un kit de captura biométrica de un centro de emisión USD 18 000

Operación por proceso

Proceso	Gestión de la base de datos biográfica y biométrica
Horario	Consulta 24 horas; registro de lunes a sábado de 7:00 a 17:00
Personal en turno y costo	14 personas de administración de base de datos y operación del AFIS; costo cargado USD 12 por hora (±15 %)
Procedimiento alterno	Sin alternativa para la consulta biométrica; los centros de emisión reciben solicitudes en formulario y las cargan cuando el sistema vuelve
Penalizaciones	Ninguna contractual; la institución responde ante la Presidencia y la Corte de Cuentas
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin validación biométrica en emisión ni en verificación; filas en los centros · 24 h: emisión detenida en todo el país; bancos sin verificar identidad para abrir cuentas · 72 h: trámites notariales, bancarios y migratorios detenidos · 1 semana: cobertura internacional e intervención de la Presidencia · 1 mes: si hubo alteración de registros, pérdida de confianza en el documento nacional que la Dirección considera irreparable

Proceso	Emisión y activación de documentos
Horario	28 centros de emisión, de lunes a sábado de 7:00 a 17:00
Personal en turno y costo	180 personas en los centros de emisión; costo cargado USD 6 por hora (±15 %)
Procedimiento alterno	Recepción de solicitudes y citas, y entrega de documentos ya impresos, sin emisión nueva; sostenible 5 días según la Subdirección de Registro
Penalizaciones	Contrato con el proveedor de tarjetas de policarbonato con compra mínima de 60 000 tarjetas al mes
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: filas y citas reprogramadas · 24 h: 3 000 solicitudes del día sin atender; quejas en medios · 72 h: acumulación de 9 000 solicitudes; personas sin documento para trámites urgentes · 1 semana: inventario de tarjetas acumulado y horas extra para recuperar el atraso · 1 mes: atraso de dos meses en la emisión; observación de la Corte de Cuentas

Proceso	Servicios de verificación de identidad (API)
Horario	24 horas, todos los días
Personal en turno y costo	8 personas de integración y soporte por turno; costo cargado USD 12 por hora (±15 %)
Procedimiento alterno	Verificación por lote nocturno para las entidades que lo piden; en ventanilla, las entidades validan el documento físico
Penalizaciones	Convenios con 62 entidades con disponibilidad mensual de 99,5 %, sin penalización económica; la tasa por consulta deja de cobrarse durante la caída
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: bancos sin verificación en línea; aperturas de cuentas en espera · 24 h: banca digital detiene las altas de clientes; aumenta el riesgo de fraude de identidad · 72 h: entidades financieras reclaman a la Presidencia; cobertura en medios · 1 semana: entidades evalúan validaciones alternativas · 1 mes: pérdida de los ingresos por consultas y de la confianza del sistema financiero en el servicio

Tecnología

Elemento	Situación actual
Base de datos	Oracle Database 19c en Oracle Exadata X9M
Biometría	AFIS de un fabricante internacional en Red Hat Enterprise Linux 7
Aplicación de registro	Desarrollo propio en Java con Apache Tomcat 9 sobre Windows Server 2016
PKI del documento	Autoridad certificadora con Microsoft AD CS en Windows Server 2016 y módulo HSM Thales Luna 7
API de verificación	Servicio REST publicado con NGINX 1.24 sobre Red Hat Enterprise Linux 8; usuario y contraseña por entidad
Oficina e identidad	Active Directory en Windows Server 2016; Microsoft 365; estaciones con Windows 10 y Windows 11
Red	Centro de datos gubernamental con alta seguridad física; enlaces MPLS con los 28 centros de emisión

Respaldos y continuidad

Sistema	Situación actual
Base biográfica	Oracle RMAN diario a disco y semanal a cinta; las cintas se guardan en una bóveda del mismo edificio
AFIS	Respaldo semanal de la base de plantillas biométricas
Sitio alterno	No existe; hay un convenio en trámite con otro centro de datos del Estado
Última prueba de recuperación	Restauración parcial de la base biográfica en 2024; tardó 16 horas

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Consulta masiva no autorizada por la API con las credenciales de una entidad usuaria	Tres semanas hasta detectarla	Sin cuantificar; se revocaron las credenciales
2024	Parche crítico de Oracle aplicado con siete meses de atraso, observado por la Corte de Cuentas	—	Observación de auditoría
2025	Ransomware en estaciones de un centro de emisión regional	3 días	USD 22 000 en reposición y horas extra
2026	Falla del almacenamiento del AFIS	11 horas	Emisión detenida en todo el país

Organización y presupuesto

Dato	Valor
Organigrama	Dirección General; Subdirecciones de Registro, Tecnología (40 personas de TI), Jurídica (asesoría legal) y Administración, que incluye RR. HH.; Unidad de Auditoría Interna que reporta a la Dirección General. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 1,2 M (0,8 M de inversión y 0,4 M de operación) en el presupuesto institucional. 2028 y 2029: mismo nivel, sujeto a la Ley de Presupuesto de cada año
Arranque del programa de seguridad	Aprobado por la Dirección General para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Ley de Ciberseguridad y Seguridad de la Información (institución pública supervisada por la Agencia de Ciberseguridad del Estado); Ley para la Protección de Datos Personales, cuyo alcance sobre el registro de identidad analiza la Subdirección Jurídica; Ley de Acceso a la Información Pública; auditoría de la Corte de Cuentas de la República

Controles que ya existen

Familia	Estado actual
Seguridad física	Control de acceso biométrico, guardias y bóveda en el centro de datos
Parches	Sin calendario; los servidores críticos acumulan meses de atraso
Desarrollo	Sin ciclo de desarrollo seguro ni revisión de código antes de publicar
Monitoreo de la base	Auditoría de Oracle desactivada; el acceso a la base casi no se monitorea
Cuentas y accesos	Cuentas nominales en Active Directory; los administradores de base de datos comparten la cuenta SYS; sin segundo factor
API	Usuario y contraseña por entidad, sin límite de consultas ni alertas de uso anómalo
Antimalware	Antivirus en estaciones y servidores Windows

4.6 LogiPort CA (Puerto Logístico Centroamericano)

Grupo de Implementación asignado: IG3. Nodo de comercio exterior con tecnología de operación portuaria y efectos en cadena sobre la economía.

Datos básicos de la empresa

- **Sector:** Logística y Transporte Marítimo.
- **Tamaño:** Grande (700 empleados).
- **Ubicación:** Principal puerto marítimo de El Salvador.
- **Misión:** Facilitar el comercio internacional de El Salvador, operando un puerto eficiente, seguro y competitivo que conecte al país con el mundo.
- **Visión:** Convertir el puerto en el hub logístico más importante de la costa del Pacífico centroamericano.
- **Estructura Organizacional Básica:** Autoridad Portuaria, Dirección de Operaciones, Dirección de Aduanas (en sitio), TI, Seguridad Física, Finanzas.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Carga y descarga de contenedores, almacenamiento, despacho aduanero.
- **Clientes:** Líneas navieras, importadores y exportadores.

Procesos Críticos (4):

  - **1. Sistema Operativo de la Terminal (TOS):** Gestión de la ubicación y movimiento de cada contenedor en el puerto.
  - **2. Plataforma de Comunidad Portuaria (PCS):** Intercambio de información digital con aduanas, navieras y agentes de carga.
  - **3. Control de Acceso de Carga y Transporte:** Verificación de camiones y carga que entran y salen del puerto.
  - **4. Operación de Grúas y Maquinaria Automatizada:** Control de los equipos industriales conectados a la red.

- **Dependencia Tecnológica:** Crítica. Un fallo en el TOS puede paralizar el puerto por completo, deteniendo una parte significativa del comercio del país.

Infraestructura tecnológica inicial

- **Sistemas:** Sistema TOS Navis, plataforma PCS desarrollada a medida, sistemas de control industrial (ICS) para grúas.
- **Red y Comunicaciones:** Red Wi-Fi industrial para la operación en patio. Red de fibra óptica que conecta todo el puerto. Convergencia de redes TI y OT.
- **Madurez y Controles Actuales:** Nivel muy bajo. La seguridad se ha centrado históricamente en lo físico (guardias, vallas). La ciberseguridad es un concepto nuevo. Las redes TI y OT no están bien segmentadas, los sistemas de control industrial usan contraseñas de fábrica y no hay visibilidad del tráfico de red.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales	USD 120 M	105–135 M	Manejo de contenedores 70 %, almacenaje 20 %, servicios a buques 10 %
Margen operativo	24 %	20–28 %	Sobre ingresos

Dato	Valor probable	Rango	Detalle
Temporada alta	Octubre a diciembre (importaciones de fin de año)	—	Movimientos frente al mes promedio: 1,4 (1,2–1,6)
Volumen de operación	720 movimientos de contenedores por día	600–850	260 000 TEU al año; 1 100 camiones por día en las garitas; 400 contenedores refrigerados conectados en promedio
Datos personales	14 000 transportistas y conductores registrados	12 000–16 000	Nombre, DUI, licencia y fotografía; 3 200 usuarios de agentes de carga y navieras en la PCS
Costo de notificar a un titular	USD 0,50	0,30–0,80	SMS y correo; cotización vigente
Costo de reposición de equipos clave	USD 2,4 M por servidores y licencias del TOS	2,0–2,9 M	Controlador y PLC de una grúa pórtico USD 350 000 (300 000–420 000)
Carga refrigerada	USD 45 000 de valor promedio por contenedor refrigerado	30 000–70 000	El dueño de la carga reclama al puerto si el contenedor pierde la cadena de frío en el patio

Operación por proceso

Proceso	Sistema operativo de la terminal (TOS)
Horario	24 horas, todos los días
Personal en turno y costo	45 personas de planificación y control de patio y 120 operadores de equipo de patio por turno; costo cargado USD 8 por hora (±15 %)
Procedimiento alterno	Planificación en pizarras y hojas de cálculo con la última exportación de posiciones; la productividad cae al 30 %; Operaciones lo considera sostenible 12 horas
Penalizaciones	Las navieras cobran demora de USD 1 800 por hora por buque en muelle (1 200–2 500) cuando no se cumple la productividad contractual de 25 movimientos por hora por grúa
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: buques en muelle con productividad baja; camiones en cola en las garitas · 24 h: buques desviados a puertos vecinos; contenedores refrigerados sin control de posición · 72 h: desabastecimiento de insumos importados; cobertura nacional · 1 semana: navieras cambian la escala; reclamos de importadores · 1 mes: pérdida de líneas navieras que la Autoridad Portuaria considera difícil de recuperar

Proceso	Plataforma de comunidad portuaria (PCS)
Horario	24 horas, todos los días
Personal en turno y costo	12 personas de soporte de la PCS; costo cargado USD 10 por hora (±15 %)
Procedimiento alterno	Manifiestos y autorizaciones por correo y en papel con la aduana; sostenible 24 horas
Penalizaciones	Ninguna contractual; la aduana no libera carga sin la transmisión electrónica

Proceso	Plataforma de comunidad portuaria (PCS)
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: manifiestos y autorizaciones en cola; agentes de carga sin información · 24 h: liberación de carga detenida; contenedores acumulados en patio · 72 h: patio saturado; recargos de almacenaje reclamados por los importadores · 1 semana: navieras y agentes exigen compensaciones · 1 mes: pérdida de confianza de la comunidad portuaria en la plataforma

Proceso	Control de acceso de carga y transporte
Horario	24 horas, todos los días
Personal en turno y costo	30 personas en garitas por turno; costo cargado USD 6 por hora (±15 %)
Procedimiento alterno	Verificación manual en garitas con listas impresas de citas; capacidad al 40 %
Penalizaciones	Los transportistas cobran USD 25 por hora por camión retenido más de 2 horas
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: colas de camiones en la carretera de acceso · 24 h: carga de exportación que no llega al buque; riesgo de ingreso de carga no verificada · 72 h: bloqueo vial y reclamo de las autoridades locales · 1 semana: exportadores pierden cierres de embarque · 1 mes: observación del régimen de protección portuaria

Proceso	Operación de grúas y maquinaria automatizada
Horario	24 horas, todos los días
Personal en turno y costo	6 grúas pórtico y 18 grúas de patio; 24 operadores y 8 técnicos por turno; costo cargado USD 9 por hora (±15 %)
Procedimiento alterno	Operación local de cada grúa, sin integración con el TOS; productividad al 50 %
Penalizaciones	Las mismas demoras de las navieras del TOS
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: grúas en modo local; riesgo de accidente con carga suspendida si el control falla · 24 h: un buque por día sin atender · 72 h: congestión de muelle y desvío de buques · 1 semana: reparación de grúas afectadas por manipulación de su control · 1 mes: pérdida de capacidad del puerto y de navieras

Tecnología

Elemento	Situación actual
TOS	Navis N4 en Windows Server 2019 con Microsoft SQL Server 2019
PCS	Desarrollo a medida en .NET sobre Windows Server 2016 con SQL Server 2016
Control de grúas	PLC Siemens S7-1500 y paneles HMI con Windows Embedded Standard 7
Garitas	Lectoras OCR de placas y de contenedores; videovigilancia IP
Red	Fibra óptica en todo el puerto; Wi-Fi industrial Cisco para terminales de mano y equipos de patio; conmutadores Cisco con IOS XE 16; redes de TI y OT convergentes
Oficina e identidad	Active Directory en Windows Server 2016; Microsoft 365; estaciones con Windows 10

Respaldos y continuidad

Sistema	Situación actual
TOS	Respaldo nocturno de SQL Server a disco en el mismo servidor; sin réplica ni copia fuera del puerto
PCS	Respaldo semanal a un disco externo guardado en la oficina de TI
Grúas	Los programas de los PLC solo existen en la laptop del integrador que los instaló
Sitio alterno	No existe

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Interferencia en la Wi-Fi industrial que dejó sin conexión las terminales de patio	5 horas	Demoras cobradas por dos navieras: USD 16 000
2024	Malware en la laptop de un técnico conectada a la red de grúas	1 día con una grúa pórtico detenida	USD 30 000
2025	Correo que suplantó a una naviera para cambiar la cuenta bancaria de pago	—	USD 85 000 transferidos a un tercero
2026	Corte de fibra en el patio por una obra	3 horas	Colas en garitas; sin penalización

Organización y presupuesto

Dato	Valor
Organigrama	Autoridad Portuaria (dirección superior); Dirección de Operaciones; Dirección de Aduanas en sitio, con personal de la autoridad aduanera; TI (18 personas); Seguridad Física; Finanzas, que incluye RR. HH.; asesoría legal interna de tres abogados; Auditoría Interna que reporta a la Autoridad Portuaria. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 900 000 (600 000 de inversión y 300 000 de operación). 2028 y 2029: USD 700 000 por año, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por la Autoridad Portuaria para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Código PBIP de la OMI para la protección de buques e instalaciones portuarias; regulación de la Autoridad Marítima Portuaria; normativa de la Dirección General de Aduanas; Ley para la Protección de Datos Personales (datos de transportistas)

Controles que ya existen

Familia	Estado actual
Seguridad física	Guardias, vallas, videovigilancia y control de acceso de personas y vehículos
Cuentas y accesos	Los PLC y los paneles HMI de las grúas conservan las contraseñas de fábrica; en TI hay cuentas nominales en Active Directory, sin segundo factor
Segmentación	Redes de TI y OT sin separación; la Wi-Fi industrial alcanza la red de grúas
Monitoreo	Sin visibilidad del tráfico de red ni bitácoras centralizadas

Familia	Estado actual
Antimalware	Antivirus en estaciones Windows de oficina; nada en los paneles HMI
Parches	Sin programa; los paneles HMI usan un sistema operativo sin soporte

4.7 Innovatec Pharma

Grupo de Implementación asignado: IG3. Propiedad intelectual farmacéutica y datos de ensayos sujetos a inspección regulatoria.

Datos básicos de la empresa

- **Sector:** Farmacéutica y Biotecnología.
- **Tamaño:** Mediana (350 empleados, muchos con doctorados).
- **Ubicación:** Campus de investigación y planta de producción en la zona franca de El Salvador.
- **Misión:** Investigar, desarrollar y producir medicamentos innovadores para tratar enfermedades crónicas, cumpliendo con los más altos estándares de calidad y ética.
- **Visión:** Ser un centro de excelencia en investigación farmacéutica en Latinoamérica, generando propiedad intelectual de alto valor.
- **Estructura Organizacional Básica:** CEO, Director de I+D, Director de Operaciones (Planta), Director de Calidad y Cumplimiento, TI.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Investigación y desarrollo (I+D) de nuevas moléculas, manufactura de medicamentos patentados.
- **Clientes:** Grandes distribuidoras farmacéuticas multinacionales.

Procesos Críticos (4):

  - **1. Protección de la Propiedad Intelectual (IP):** Salvaguarda de las fórmulas químicas y los resultados de la investigación.
  - **2. Gestión de Datos de Ensayos Clínicos:** Administración segura y anónima de datos de pacientes en estudios.
  - **3. Sistemas de Control de Manufactura (MES/ICS):** Operación de los sistemas que controlan la producción y garantizan la calidad del lote.
  - **4. Cumplimiento Regulatorio Internacional:** Asegurar que los procesos cumplen con normativas como FDA (21 CFR Part 11).

- **Dependencia Tecnológica:** Crítica. El valor de la empresa reside en su propiedad intelectual digital.

Infraestructura tecnológica inicial

- **Sistemas:** LIMS (Sistema de Gestión de Información de Laboratorio), software de modelado molecular, sistemas de control de producción DeltaV, SAP S/4HANA.
- **Red y Comunicaciones:** Red de laboratorio de alta velocidad. Red de planta para sistemas OT. Uso intensivo de almacenamiento en la nube para datos de investigación.
- **Madurez y Controles Actuales:** Nivel bajo. Los científicos tienen altos privilegios en sus estaciones de trabajo para instalar software, lo que genera riesgos. No hay soluciones de Data Loss Prevention (DLP) para evitar la fuga de IP. La seguridad de los sistemas de producción es casi nula.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ventas anuales	USD 95 M	85–105 M	Tres medicamentos patentados vendidos a dos distribuidoras multinacionales; 80 % de exportación
Margen bruto	62 %	55–68 %	Sobre ventas netas
Temporada alta	Marzo y septiembre, ventanas de compra de los distribuidores	—	Despachos frente al mes promedio: 1,5 (1,3–1,8)
Volumen de producción	180 lotes al año	160–200	Valor promedio de un lote USD 520 000 (400 000–650 000); un lote que pierde su control de proceso se rechaza completo
Investigación	Presupuesto anual de I+D USD 14 M	12–16 M	Inversión acumulada en la molécula en fase II: USD 38 M (32–44 M)
Datos personales	4 200 participantes de ensayos clínicos	3 800–4 600	Datos de salud seudonimizados; la tabla de correspondencia la guarda el equipo de operaciones clínicas
Costo de notificar a un participante	USD 2,50	1,50–4,00	Carta por medio del centro de investigación de cada país
Costo de reposición de equipos clave	USD 2,8 M	2,3–3,4 M	Sistema de control DeltaV y servidores de la planta, con revalidación

Operación por proceso

Proceso	Protección de la propiedad intelectual (datos de investigación y formulaciones)
Horario	Laboratorios de lunes a viernes de 7:00 a 19:00; cómputo de modelado 24 horas
Personal en turno y costo	95 científicos; costo cargado USD 28 por hora (±15 %)
Procedimiento alterno	Trabajo de laboratorio sin acceso a los repositorios; el modelado se detiene
Penalizaciones	Acuerdos de confidencialidad con los distribuidores con penalidad de USD 2 M si se filtra una formulación antes de la patente
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: científicos sin acceso a datos de investigación; cómputo detenido · 24 h: simulaciones de larga duración perdidas · 72 h: retraso del calendario de presentación de la patente · 1 semana: hitos incumplidos con los socios · 1 mes: si hubo robo de datos, pérdida de la ventaja competitiva de la molécula que la Dirección considera irrecuperable

Proceso	Gestión de datos de ensayos clínicos
Horario	Captura en el horario de 12 centros de investigación en cuatro países
Personal en turno y costo	14 personas de operaciones clínicas y bioestadística; costo cargado USD 22 por hora (±15 %)

Proceso	Gestión de datos de ensayos clínicos
Procedimiento alterno	Cuadernos de recolección en papel en los centros, transcritos después con doble verificación; sostenible 5 días
Penalizaciones	Contrato con la organización de investigación por contrato: USD 8 000 por día de retraso en el cierre de la base de datos
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: los centros capturan en papel · 24 h: visitas de monitoreo reprogramadas · 72 h: desviaciones de protocolo reportadas al comité de ética · 1 semana: riesgo de invalidar datos por falta de integridad y trazabilidad · 1 mes: retraso del ensayo y reporte a la autoridad regulatoria

Proceso	Sistemas de control de manufactura (MES/ICS)
Horario	Planta en dos turnos, de lunes a sábado de 6:00 a 22:00
Personal en turno y costo	85 personas de producción por turno; costo cargado USD 9 por hora (±15 %)
Procedimiento alterno	Registro de lote en papel con el expediente de lote impreso, solo para productos con procedimiento validado en papel; capacidad al 40 %
Penalizaciones	Contratos de suministro: 2 % del valor del pedido por semana de retraso
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: lote en proceso en riesgo de rechazo · 24 h: un lote rechazado y producción detenida · 72 h: despachos retrasados · 1 semana: penalidades de suministro · 1 mes: incumplimiento de contratos y observación en la inspección de buenas prácticas de manufactura

Proceso	Cumplimiento regulatorio internacional (21 CFR Part 11)
Horario	Oficina de lunes a viernes de 8:00 a 17:00
Personal en turno y costo	12 personas de Calidad y Cumplimiento; costo cargado USD 20 por hora (±15 %)
Procedimiento alterno	Revisión manual de pistas de auditoría exportadas y firmas en papel
Penalizaciones	Una observación de la FDA en inspección puede detener las exportaciones a Estados Unidos
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin efecto inmediato · 24 h: liberación de lotes detenida por falta de registros firmados · 72 h: despachos retenidos en bodega · 1 semana: auditoría extraordinaria del distribuidor · 1 mes: riesgo de carta de advertencia y de alerta de importación de la FDA

Tecnología

Elemento	Situación actual
LIMS	LabWare LIMS 8 sobre Windows Server 2019 con Microsoft SQL Server 2019
Investigación	Modelado molecular en estaciones Ubuntu 22.04 con GPU; datos de investigación en Microsoft Azure Blob Storage
Planta	Emerson DeltaV 14 con estaciones Windows 10 Enterprise LTSC; MES del mismo fabricante
ERP	SAP S/4HANA 2022 en la nube privada del proveedor
Oficina e identidad	Active Directory en Windows Server 2019; Microsoft 365; estaciones con Windows 11

Elemento	Situación actual
Red	Red de laboratorio de 10 Gbps; red de planta OT; un proveedor de internet en la zona franca

Respaldos y continuidad

Sistema	Situación actual
LIMS	Respaldo diario a disco local y copia a Azure
DeltaV	El integrador respalda la configuración una vez al mes
Datos de investigación	Sincronización a Azure sin versiones inmutables; lo que queda en las estaciones no se respalda
SAP S/4HANA	Respaldo incluido en el contrato del proveedor de la nube privada
Sitio alterno	No existe para la planta

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Un científico que renunció copió datos de modelado a un disco personal	Detectado dos meses después	Sin cuantificar; demanda en curso
2024	Ransomware en una estación de laboratorio con software gratuito instalado por su usuario	2 días	USD 40 000
2025	Auditoría de un distribuidor: pista de auditoría del LIMS desactivada en un módulo	—	Observación mayor con plan de corrección
2026	Falla de la estación de ingeniería del DeltaV	10 horas	Un lote reprocesado: USD 90 000

Organización y presupuesto

Dato	Valor
Organigrama	CEO; Dirección de I+D; Dirección de Operaciones (planta); Dirección de Calidad y Cumplimiento; TI (9 personas); Finanzas, que incluye RR. HH. Asesoría legal y de patentes externa; auditoría interna anual del grupo accionista. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 750 000 (500 000 de inversión y 250 000 de operación). 2028 y 2029: USD 550 000 por año, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por el CEO para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	21 CFR Part 11 de la FDA (registros y firmas electrónicas); buenas prácticas de manufactura de la Dirección Nacional de Medicamentos y de la FDA; buenas prácticas clínicas ICH E6(R3); Ley para la Protección de Datos Personales (datos de salud); régimen de zona franca

Controles que ya existen

Familia	Estado actual
Privilegios	Los científicos son administradores de sus estaciones e instalan software

Familia	Estado actual
Fuga de datos	Sin herramienta de prevención de fuga de datos; puertos USB abiertos
Planta	Sin controles de seguridad en la red OT; el DeltaV no recibe parches desde su validación
Antimalware	Antivirus en estaciones Windows de oficina y laboratorio
Pistas de auditoría	Activas en el LIMS salvo un módulo; revisión manual trimestral
Accesos	Segundo factor solo en Microsoft 365 para directivos

4.8 Aseguradora Confianza Total

Grupo de Implementación asignado: IG3. Datos financieros y de salud de los asegurados, con obligación de reserva y supervisión sectorial.

Datos básicos de la empresa

- **Sector:** Seguros.
- **Tamaño:** Grande (650 empleados).
- **Ubicación:** Torre corporativa en San Salvador.
- **Misión:** Proteger el futuro de nuestros asegurados, ofreciendo pólizas de vida, salud y daños con un servicio humano, rápido y justo.
- **Visión:** Ser la aseguradora más confiable y solvente del mercado, innovando en la gestión de riesgos y la experiencia del cliente.
- **Estructura Organizacional Básica:** Presidencia, Vicepresidencia de Seguros de Personas, VP de Seguros de Daños, VP de Inversiones, VP de Tecnología, Finanzas.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Venta de pólizas de seguro, gestión de reclamos, administración de inversiones.
- **Clientes:** Personas y empresas en El Salvador.

Procesos Críticos (5):

  - **1. Procesamiento y Adjudicación de Reclamos:** Análisis y pago de siniestros.
  - **2. Suscripción y Emisión de Pólizas:** Evaluación de riesgos y creación de nuevos contratos de seguro.
  - **3. Gestión de Datos de Clientes:** Almacenamiento seguro de información personal, financiera y médica de los asegurados.
  - **4. Modelado de Riesgo Actuarial:** Análisis de grandes volúmenes de datos para calcular primas y reservas.
  - **5. Gestión del Portafolio de Inversiones:** Administración de los activos financieros que respaldan las pólizas.

- **Dependencia Tecnológica:** Crítica. La operación se basa en el análisis de datos y la confianza del cliente.

Infraestructura tecnológica inicial

- **Sistemas:** Sistema central de seguros (Core) desarrollado en Java, software de análisis estadístico (SAS), CRM para agentes, plataforma de gestión documental.
- **Red y Comunicaciones:** Centro de datos principal con replicación de datos a un proveedor de DRP. Uso de nubes públicas para análisis de datos no estructurados.

- **Madurez y Controles Actuales:** Nivel intermedio-bajo. Tienen políticas de clasificación de datos en papel, pero no herramientas para forzar su cumplimiento (DLP). La base de datos de clientes es un monolito con controles de acceso deficientes, y los analistas de datos a menudo usan datos de producción en entornos no seguros.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Primas netas anuales	USD 240 M	220–260 M	Seguros de personas 55 % (vida y gastos médicos), daños 45 %
Resultado técnico	9 % de las primas	6–12 %	Utilidad neta 6 % de las primas (4–8 %)
Temporada alta	Diciembre y enero (renovación de pólizas colectivas y de autos) y temporada de lluvias (siniestros de daños)	—	Emisiones en renovación frente al mes promedio: 1,8 (1,5–2,1); reclamos de daños en lluvias: 1,5 (1,3–1,8)
Volumen de transacciones	95 000 reclamos al año	85 000–105 000	70 % de gastos médicos; 380 000 pólizas vigentes; 1 200 autorizaciones hospitalarias por día
Asegurados y datos personales	520 000 asegurados	480 000–560 000	Datos de salud, financieros y de beneficiarios
Pagos con tarjeta	1,6 millones de cargos recurrentes de primas al año	1,4–1,8 millones	Comercio de nivel 2 de PCI DSS con cuestionario de autoevaluación anual
Costo de notificar a un asegurado	USD 0,45	0,30–0,70	Carta, correo y SMS; cotización vigente
Costo de reposición de equipos clave	USD 3,5 M	2,8–4,2 M	Servidores, licencias y migración del core de seguros
Portafolio de inversiones	USD 410 M	390–430 M	Reservas técnicas invertidas en títulos locales y del exterior

Operación por proceso

Proceso	Procesamiento y adjudicación de reclamos
Horario	Lunes a viernes de 8:00 a 18:00 y sábados de 8:00 a 12:00; autorizaciones hospitalarias 24 horas
Personal en turno y costo	140 personas de reclamos y autorizaciones por turno; costo cargado USD 9 por hora (±15 %)
Procedimiento alterno	Autorizaciones por teléfono con verificación de cobertura en listados impresos del día anterior; pagos de siniestros diferidos; sostenible 48 horas
Penalizaciones	Convenios con 45 hospitales: sin respuesta en 30 minutos, el hospital atiende y cobra a tarifa plena, 15 % más alta

Proceso	Procesamiento y adjudicación de reclamos
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: autorizaciones hospitalarias lentas; pacientes en espera · 24 h: hospitales cobran tarifa plena; reclamos en redes · 72 h: pagos de siniestros atrasados; quejas ante la Superintendencia · 1 semana: corredores trasladan cuentas colectivas a la competencia · 1 mes: pérdida de pólizas colectivas y daño a la marca

Proceso	Suscripción y emisión de pólizas
Horario	Lunes a viernes de 8:00 a 17:00
Personal en turno y costo	90 personas de suscripción y emisión; costo cargado USD 10 por hora (±15 %)
Procedimiento alterno	Certificados provisionales manuales y carga posterior al core
Penalizaciones	Ninguna contractual; los bancos del canal de bancaseguros exigen la póliza emitida en 24 horas
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: cotizaciones y emisiones detenidas · 24 h: ventas del canal bancario perdidas del día · 72 h: renovaciones vencidas sin cobertura formal · 1 semana: bancos suspenden la venta de los productos · 1 mes: caída de primas nuevas del trimestre

Proceso	Gestión de datos de clientes
Horario	24 horas, todos los días
Personal en turno y costo	20 personas de datos y atención al asegurado; costo cargado USD 11 por hora (±15 %)
Procedimiento alterno	Consulta de expedientes en el gestor documental
Penalizaciones	Ninguna contractual; una fuga obliga a notificar a los asegurados según la Ley para la Protección de Datos Personales e informar al supervisor
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: agentes sin datos de sus clientes · 24 h: atención al asegurado degradada · 72 h: reclamos formales · 1 semana: pérdida de confianza de corredores · 1 mes: si hubo fuga de datos de salud, sanción y pérdida de clientes que la Presidencia considera grave

Proceso	Modelado de riesgo actuarial
Horario	Oficina; cierre mensual y cálculo de reservas trimestral
Personal en turno y costo	11 actuarios y analistas; costo cargado USD 25 por hora (±15 %)
Procedimiento alterno	Cálculo con la base del cierre anterior en hojas de cálculo
Penalizaciones	Las reservas se entregan al supervisor en plazo fijo; la entrega tardía se multa
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin efecto · 24 h: tarifas nuevas retrasadas · 72 h: cierre mensual en riesgo · 1 semana: cálculo de reservas fuera de plazo · 1 mes: multa del supervisor y decisiones de precio con datos viejos

Proceso	Gestión del portafolio de inversiones
Horario	Días hábiles de 8:00 a 17:00, según los mercados

Proceso	Gestión del portafolio de inversiones
Personal en turno y costo	8 personas de inversiones; costo cargado USD 30 por hora (±15 %)
Procedimiento alterno	Órdenes por teléfono al corredor con confirmación por correo
Penalizaciones	Operaciones no liquidadas a tiempo: costo de oportunidad y cargos del depositario
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: órdenes del día por teléfono · 24 h: vencimientos sin reinvertir · 72 h: incumplimiento de límites de inversión de reservas · 1 semana: observación del supervisor · 1 mes: pérdida de rendimiento y riesgo de insuficiencia de reservas invertidas

Tecnología

Elemento	Situación actual
Core de seguros	Desarrollo propio en Java 11 con Oracle WebLogic 14 y Oracle Database 19c en Red Hat Enterprise Linux 8
Analítica	SAS 9.4 en Windows Server 2019; datos no estructurados en AWS (Amazon S3 y Amazon EMR)
CRM y documentos	Salesforce para agentes y corredores; Microsoft SharePoint Server 2019 como gestor documental
Oficina e identidad	Active Directory en Windows Server 2019; Microsoft 365; estaciones con Windows 11
Red	Centro de datos principal en la torre corporativa; réplica al proveedor de recuperación ante desastres; cortafuegos Fortinet FortiGate con FortiOS 7.4

Respaldos y continuidad

Sistema	Situación actual
Core de seguros	Réplica asíncrona al proveedor de recuperación ante desastres cada 30 minutos; respaldo diario a disco
Gestor documental	Respaldo diario a disco en el centro de datos principal
Analítica en la nube	Copias de datos de producción en Amazon S3, sin enmascarar
Última prueba de recuperación	2025, solo el core de seguros, en el sitio del proveedor; tardó 9 horas

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Correo de un proveedor suplantado con una factura falsa	—	USD 60 000 pagados a un tercero
2024	Un analista subió una extracción de la base de clientes a su nube personal para trabajar desde casa	Detectado un mes después	Sin sanción; no se notificó
2025	Actualización fallida del core de seguros	7 horas	Autorizaciones por teléfono; hospitales cobraron tarifa plena

Año	Incidente	Duración	Costo
2026	Fraude de reclamos con documentos médicos alterados	Cinco meses hasta detectarlo	USD 140 000

Organización y presupuesto

Dato	Valor
Organigrama	Junta Directiva con Comité de Auditoría y Comité de Riesgos; Presidencia; Vicepresidencias de Seguros de Personas, de Daños, de Inversiones y de Tecnología (60 personas de TI); Finanzas; Gerencia Legal; Recursos Humanos; Auditoría Interna; Oficialía de Cumplimiento; Unidad de Riesgos con un oficial de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 1,4 M (0,8 M de inversión y 0,6 M de operación). 2028 y 2029: +5 % anual, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por la Presidencia para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Ley de Sociedades de Seguros y normas técnicas del Banco Central de Reserva, supervisadas por la Superintendencia del Sistema Financiero; Ley para la Protección de Datos Personales (datos de salud); PCI DSS como comercio; prevención de lavado de dinero

Controles que ya existen

Familia	Estado actual
Clasificación de datos	Política escrita en papel, sin herramienta que la haga cumplir
Accesos a la base de clientes	Base monolítica con permisos amplios por área; revisión anual incompleta
Entornos	Los analistas usan datos de producción sin enmascarar en desarrollo y en la nube
Cuentas	Segundo factor en el correo para todo el personal; no en el core ni en los servidores
Antimalware	Antivirus corporativo en estaciones y servidores Windows
Pruebas	Prueba de penetración externa anual del portal de asegurados
Continuidad	Contrato con proveedor de recuperación ante desastres para el core

4.9 Mercado Digital Centroamérica (MerdiCA)

Grupo de Implementación asignado: IG3. Procesamiento de pagos a gran volumen bajo PCI DSS y superficie pública permanente.

Datos básicos de la empresa

- **Sector:** Comercio Electrónico y FinTech.
- **Tamaño:** Grande (1,000 empleados).
- **Ubicación:** Oficinas principales en San Salvador, centros de distribución en las tres ciudades principales del país.
- **Misión:** Ser la plataforma de comercio digital más completa y segura de la región, conectando a compradores y vendedores de manera fácil y eficiente.
- **Visión:** Crear un ecosistema de comercio y pagos digitales que impulse el crecimiento de las PYMES en Centroamérica.

- **Estructura Organizacional Básica:** CEO, CTO, Director de Marketplace, Director de Logística, Director de Pagos (FinTech), Marketing.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Marketplace online (similar a Amazon), pasarela de pagos propia, servicios de logística y fulfillment.
- **Clientes:** Compradores finales (B2C) y empresas vendedoras (B2B).

Procesos Críticos (4):

  - **1. Operación de la Plataforma de E-commerce:** Garantizar la disponibilidad, rendimiento y seguridad del sitio web y la app.
  - **2. Procesamiento de Pagos Digitales:** Procesar de forma segura miles de transacciones con tarjeta de crédito/débito al día.
  - **3. Gestión de Datos de Clientes y Vendedores:** Proteger la información personal y de ventas de millones de usuarios.
  - **4. Operación Logística y de Bodegas (WMS):** Administrar el inventario y coordinar los despachos de los centros de distribución.

- **Dependencia Tecnológica:** Crítica y absoluta. La empresa es su plataforma tecnológica.

Infraestructura tecnológica inicial

- **Sistemas:** Arquitectura de microservicios 100% nativa en la nube (GCP y AWS), usando Kubernetes, bases de datos NoSQL (MongoDB) y relacionales (PostgreSQL), sistema de gestión de bodegas (WMS) Manhattan.
- **Red y Comunicaciones:** Infraestructura totalmente en la nube, gestionada como código (Terraform). Red de distribución de contenido (CDN) para el rendimiento.
- **Madurez y Controles Actuales:** Madurez DevOps alta, pero madurez de seguridad (DevSecOps) baja. El enfoque ha sido la velocidad de despliegue, no la seguridad. Hay secretos (claves de API, contraseñas) expuestos en repositorios de código, no hay análisis de seguridad de contenedores y la respuesta a incidentes es un proceso ad-hoc liderado por desarrolladores.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales	USD 68 M	60–76 M	Sobre un valor bruto de mercancía de USD 380 M (340–420 M): comisiones del marketplace 60 %, logística 25 %, pagos 15 %
Margen de contribución	18 % de los ingresos	14–22 %	Resultado neto cercano al equilibrio
Temporada alta	Noviembre (Black Friday) y diciembre	—	Pedidos frente al mes promedio: 2,6 (2,0–3,2)
Volumen de transacciones	28 000 pedidos por día	24 000–32 000	15 millones de transacciones con tarjeta al año por la pasarela propia

Dato	Valor probable	Rango	Detalle
Pagos con tarjeta	Proveedor de servicios de nivel 1 de PCI DSS	—	ROC anual por un QSA; contracargos por fraude: 0,35 % del volumen con tarjeta (0,25–0,50 %)
Datos personales	3,1 millones de compradores registrados	2,8–3,4 millones	9 500 vendedores con datos bancarios y fiscales
Costo de notificar a un titular	USD 0,04	0,02–0,08	Correo y notificación en la app; SMS solo a vendedores
Costo de reconstruir la plataforma	USD 1,5 M en horas de ingeniería	1,1–2,0 M	La infraestructura se recrea con Terraform; el costo está en datos, pruebas y reconfiguración

Operación por proceso

Proceso	Operación de la plataforma de e-commerce (sitio y app)
Horario	24 horas, todos los días
Personal en turno y costo	18 personas de SRE y soporte por turno; costo cargado USD 18 por hora (±15 %)
Procedimiento alterno	Página de mantenimiento; pedidos por WhatsApp solo para los 50 vendedores más grandes
Penalizaciones	Acuerdos con vendedores destacados: bonificación de comisión si la plataforma cae más de 4 horas en temporada alta
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: ventas del período perdidas; campañas pagadas sin conversión; reclamos en redes · 24 h: vendedores desvían inventario a otros canales · 72 h: compradores migran a la competencia; cobertura en medios · 1 semana: vendedores grandes abandonan el marketplace · 1 mes: la temporada alta se pierde si coincide con ella

Proceso	Procesamiento de pagos digitales (pasarela propia)
Horario	24 horas, todos los días
Personal en turno y costo	10 personas de pagos por turno; costo cargado USD 20 por hora (±15 %)
Procedimiento alterno	Desvío de cobros a un adquirente externo con contrato de respaldo, con comisión 1,2 puntos más alta; pago contra entrega
Penalizaciones	Multas de las marcas de tarjeta y del adquirente si hay incumplimiento de PCI DSS; liquidación a vendedores en dos días hábiles
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: cobros por el adquirente de respaldo, más caros · 24 h: liquidaciones a vendedores atrasadas · 72 h: reclamos de vendedores y del adquirente · 1 semana: revisión del adquirente sobre la continuidad del contrato · 1 mes: si hubo fuga de tarjetas, pérdida de la autorización de las marcas

Proceso	Gestión de datos de clientes y vendedores
Horario	24 horas, todos los días
Personal en turno y costo	8 personas de datos y privacidad; costo cargado USD 18 por hora (±15 %)
Procedimiento alterno	No aplica: los datos viven en la plataforma

Proceso	Gestión de datos de clientes y vendedores
Penalizaciones	Ninguna contractual; una fuga obliga a notificar a los titulares según la Ley para la Protección de Datos Personales
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: compradores sin acceso a su cuenta · 24 h: vendedores sin reportes de ventas · 72 h: reclamos ante la Defensoría del Consumidor · 1 semana: pérdida de confianza de vendedores · 1 mes: si hubo fuga, costo de notificación y bajas de compradores

Proceso	Operación logística y de bodegas (WMS)
Horario	Bodegas de 6:00 a 22:00; despachos de 7:00 a 21:00
Personal en turno y costo	320 personas por turno en tres centros de distribución; costo cargado USD 4 por hora (±15 %)
Procedimiento alterno	Preparación de pedidos con listas impresas del último corte; capacidad al 35 %
Penalizaciones	Cuatro transportistas cobran USD 150 por vehículo que espera más de 1 hora; compensación de USD 2 por pedido tardío a vendedores con fulfillment
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: despachos del día retrasados · 24 h: pedidos acumulados y compensaciones a vendedores · 72 h: centros de distribución saturados · 1 semana: vendedores retiran inventario · 1 mes: pérdida del servicio de fulfillment como línea de negocio

Tecnología

Elemento	Situación actual
Cómputo	Microservicios en Google Kubernetes Engine y Amazon EKS con Kubernetes 1.30
Datos	MongoDB Atlas 7.0 y PostgreSQL 15 en Amazon RDS
Pasarela de pagos	Microservicios propios en una cuenta de AWS separada, con AWS CloudHSM
Logística	Manhattan WMS en modalidad SaaS
Entrega y borde	Terraform 1.8; GitLab CI; CDN y WAF de Cloudflare
Oficina e identidad	Google Workspace; Okta como proveedor de identidad; laptops con macOS 14 y Windows 11

Respaldos y continuidad

Sistema	Situación actual
MongoDB	Instantáneas de MongoDB Atlas cada 6 horas en la misma cuenta del proveedor
PostgreSQL	Instantáneas diarias de Amazon RDS con retención de 7 días, en la misma cuenta de AWS
Infraestructura	Reproducible con Terraform desde el repositorio
Última prueba de recuperación	Nunca se ha restaurado completa la base de pedidos

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Clave de API de AWS expuesta en un repositorio público, usada para minar criptomonedas	2 días	USD 38 000 en consumo de nube
2024	Relleno de credenciales contra cuentas de compradores	10 días	USD 120 000 en contracargos y reembolsos
2025	Caída en Black Friday por un despliegue sin prueba de carga	5 horas	Ventas perdidas estimadas por Marketing: USD 400 000 de valor bruto
2026	Tienda falsa de un vendedor fraudulento	3 semanas	USD 25 000 reembolsados a compradores

Organización y presupuesto

Dato	Valor
Organigrama	CEO; CTO con 180 ingenieros de plataforma; Direcciones de Marketplace, Logística, Pagos (FinTech) y Marketing; Finanzas; Legal y Cumplimiento; Recursos Humanos; auditoría interna contratada a una firma externa. No hay responsable de seguridad de la información; los incidentes los atienden los desarrolladores
Presupuesto aprobado para seguridad	2027: USD 1,8 M (1,0 M de inversión y 0,8 M de operación). 2028 y 2029: +10 % anual, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por el CEO para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	PCI DSS como proveedor de servicios de nivel 1; Ley para la Protección de Datos Personales; Ley de Protección al Consumidor en el comercio electrónico; contratos con adquirentes y marcas de tarjeta

Controles que ya existen

Familia	Estado actual
Entorno de tarjeta	Cuenta de AWS separada para la pasarela, exigida por el QSA; escaneo trimestral por un ASV y prueba de penetración anual solo de ese entorno
Secretos	Claves de API y contraseñas en repositorios de código
Contenedores	Sin análisis de imágenes ni de configuración de Kubernetes
Borde	CDN y WAF de Cloudflare con reglas por defecto
Identidad	Okta con segundo factor para todo el personal; cuentas raíz de la nube sin custodia formal
Bitácoras	En los servicios de bitácoras de cada nube, sin revisión ni correlación
Respuesta a incidentes	Proceso improvisado a cargo de los desarrolladores de guardia

4.10 Universidad Tecnológica de Centroamérica (UNITEC-CA)

Grupo de Implementación asignado: IG3. Datos personales de la comunidad académica y resultados de investigación en una red abierta, con adversarios dirigidos interesados en la producción científica.

Datos básicos de la empresa

- **Sector:** Educación Superior e Investigación.
- **Tamaño:** Grande (1,500 empleados entre personal académico y administrativo; 20,000 estudiantes).
- **Ubicación:** Campus principal en Santa Tecla, con centros regionales en el interior del país.
- **Misión:** Formar profesionales líderes con pensamiento crítico y capacidad de innovación, generando investigación de alto impacto para el desarrollo de la sociedad.
- **Visión:** Ser la universidad líder en la región, reconocida por su excelencia académica, investigación de vanguardia y su ecosistema digital seguro y colaborativo.
- **Estructura Organizacional Básica:** Rectoría, Vicerrectorías (Académica, de Investigación), Decanaturas por Facultad, Dirección de TI, Dirección Financiera, Admisiones.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Programas de grado y posgrado, investigación patrocinada, educación continua.
- **Clientes:** Estudiantes, empresas patrocinadoras de investigación, comunidad académica.

Procesos Críticos (5):

  - **1. Sistema de Información Estudiantil (SIS):** Gestión de matrículas, calificaciones, expedientes académicos y datos personales de miles de estudiantes.
  - **2. Plataforma de Gestión del Aprendizaje (LMS):** Operación de las aulas virtuales, entrega de contenido y evaluación en línea.
  - **3. Gestión de Datos de Investigación:** Almacenamiento y protección de la propiedad intelectual y datos de investigaciones, a menudo confidenciales.
  - **4. Sistema de Gestión Financiera y Becas:** Procesamiento de pagos de colegiatura y administración de datos financieros sensibles de los estudiantes.
  - **5. Operación de la Red del Campus:** Provisión de conectividad a miles de dispositivos (corporativos y BYOD) a través de redes cableadas e inalámbricas.

- **Dependencia Tecnológica:** Crítica. La operación académica y administrativa es totalmente dependiente de sus sistemas de TI.

Infraestructura tecnológica inicial

- **Sistemas:** SIS de Oracle/PeopleSoft, LMS Canvas, repositorios de datos de investigación en servidores locales, Microsoft 365.
- **Red y Comunicaciones:** Extenso campus con una red plana y mal segmentada. Políticas de BYOD muy permisivas. Un centro de datos on-premise que ha crecido sin planificación.
- **Madurez y Controles Actuales:** Nivel muy bajo. La TI está fragmentada, con cada facultad gestionando algunos de sus propios recursos. No hay un inventario de activos centralizado, la gestión de parches es esporádica y la visibilidad sobre el tráfico de la red es casi nula, representando un riesgo enorme para la propiedad intelectual y los datos de los estudiantes.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales (presupuesto operativo)	USD 58 M	53–63 M	Colegiaturas 83 %, investigación patrocinada 10 %, educación continua 7 %
Excedente operativo	5 % de los ingresos	2–8 %	Entidad sin fines de lucro; el excedente se reinvierte
Temporada alta	Inscripciones de enero y julio; semanas de exámenes finales	—	Transacciones del SIS frente a la semana promedio: 3,0 en inscripción (2,5–3,5); uso del LMS en exámenes: 1,8 (1,5–2,1)
Estudiantes y datos personales	20 000 estudiantes activos	19 000–21 000	85 000 exalumnos con expediente; 4 200 becarios con datos socioeconómicos; 1 500 empleados
Pagos con tarjeta	140 000 pagos de cuotas al año	120 000–160 000	Botón de pago del banco recaudador integrado al portal; comercio de nivel 3 de PCI DSS
Investigación patrocinada	USD 6 M al año con 14 empresas y agencias	5–7 M	El contrato mayor, USD 1,2 M, exige devolver el financiamiento si se filtran los datos
Costo de notificar a un titular	USD 0,15	0,10–0,25	Correo institucional y SMS
Costo de reposición de equipos clave	USD 1,6 M	1,3–2,0 M	Servidores y almacenamiento del centro de datos del campus central

Operación por proceso

Proceso	Sistema de información estudiantil (SIS)
Horario	Oficinas de lunes a sábado de 7:00 a 19:00; portal 24 horas
Personal en turno y costo	60 personas de registro académico y servicios estudiantiles; costo cargado USD 8 por hora (±15 %)
Procedimiento alterno	Inscripción presencial con formularios y carga posterior; notas en actas impresas
Penalizaciones	Ninguna contractual; plazos del calendario académico y reportes al Ministerio de Educación, Ciencia y Tecnología
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: filas en registro; estudiantes sin consultar notas · 24 h: inscripción detenida en temporada alta · 72 h: calendario académico desplazado · 1 semana: pérdida de estudiantes de nuevo ingreso hacia otras universidades · 1 mes: si hubo alteración de notas, pérdida de confianza en los títulos que la Rectoría considera grave

Proceso	Plataforma de gestión del aprendizaje (LMS)
Horario	24 horas, todos los días
Personal en turno y costo	12 personas de educación virtual; costo cargado USD 9 por hora (±15 %)

Proceso	Plataforma de gestión del aprendizaje (LMS)
Procedimiento alterno	Clases presenciales y materiales por correo; exámenes en línea reprogramados
Penalizaciones	Contrato SaaS con disponibilidad de 99,9 %; 3 500 estudiantes pagan por la modalidad virtual
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: evaluaciones en línea interrumpidas · 24 h: exámenes reprogramados · 72 h: reclamos de estudiantes de programas virtuales · 1 semana: devoluciones parciales de colegiatura virtual · 1 mes: pérdida de matrícula virtual del ciclo siguiente

Proceso	Gestión de datos de investigación
Horario	Laboratorios de lunes a viernes; servidores 24 horas
Personal en turno y costo	220 investigadores; costo cargado USD 18 por hora (±15 %)
Procedimiento alterno	Trabajo sin acceso a los repositorios
Penalizaciones	Contratos de investigación patrocinada con devolución del financiamiento si los datos se filtran
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: investigadores sin datos · 24 h: experimentos y análisis detenidos · 72 h: entregables de proyectos atrasados · 1 semana: patrocinadores exigen explicaciones · 1 mes: si hubo fuga, devolución de fondos y pérdida de patrocinadores

Proceso	Gestión financiera y de becas
Horario	Oficina de lunes a viernes de 8:00 a 17:00; pagos en línea 24 horas
Personal en turno y costo	45 personas de finanzas y becas; costo cargado USD 10 por hora (±15 %)
Procedimiento alterno	Pago en bancos con referencia impresa y conciliación posterior
Penalizaciones	Convenios con bancos recaudadores; informes a los financiadores de becas
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: pagos en línea detenidos · 24 h: estudiantes sin solvencia para exámenes · 72 h: conciliación atrasada · 1 semana: flujo de caja afectado · 1 mes: becas sin desembolsar e informes a financiadores fuera de plazo

Proceso	Operación de la red del campus
Horario	24 horas, todos los días
Personal en turno y costo	18 técnicos de red y soporte; costo cargado USD 8 por hora (±15 %)
Procedimiento alterno	Ninguno; los laboratorios de cómputo trabajan en local
Penalizaciones	Ninguna contractual
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: clases y oficinas sin conectividad · 24 h: SIS, LMS y pagos inaccesibles desde el campus · 72 h: suspensión de actividades académicas · 1 semana: reprogramación del ciclo · 1 mes: reclamos masivos y pérdida de reputación

Tecnología

Elemento	Situación actual
SIS	Oracle PeopleSoft Campus Solutions 9.2 sobre Oracle Database 19c en Oracle Linux 8
LMS	Canvas LMS en la nube de Instructure, con inicio de sesión de Microsoft 365
Investigación	Servidores de cada facultad con Windows Server 2012 R2 y Ubuntu 20.04
Oficina e identidad	Microsoft 365 A3 para personal y estudiantes; Active Directory en Windows Server 2016; estaciones con Windows 10 y Windows 11
Red	Conmutadores Cisco con IOS 15 y Wi-Fi Aruba; red plana; unos 12 000 dispositivos personales conectados por día

Respaldos y continuidad

Sistema	Situación actual
SIS	Respaldo diario a disco y copia semanal a cinta guardada en el mismo campus
Investigación	Depende de cada facultad; dos de las siete no respaldan sus servidores
Correo y archivos	Retención propia de Microsoft 365, sin respaldo adicional
Sitio alterno y pruebas	No existe sitio alterno; nunca se ha probado una restauración completa del SIS

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Phishing que tomó 300 cuentas de correo de estudiantes para enviar spam	4 días	Dominio en listas de bloqueo durante una semana
2024	Ransomware en un servidor de la Facultad de Ingeniería	5 días	Datos de dos tesis perdidos; USD 15 000 en recuperación
2025	Un estudiante alteró calificaciones con la contraseña de un docente	3 semanas hasta detectarlo	Proceso disciplinario; revisión de 1 200 actas
2026	Saturación de la red y del SIS en la inscripción de enero	2 días intermitentes	Inscripción extendida una semana

Organización y presupuesto

Dato	Valor
Organigrama	Junta de Gobierno de la fundación; Rectoría; Vicerrectorías Académica y de Investigación; Decanaturas; Dirección de TI (35 personas, más técnicos de cada facultad); Dirección Financiera; Admisiones; Dirección Jurídica; Recursos Humanos; Auditoría Interna, que reporta a la Junta de Gobierno. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 650 000 (400 000 de inversión y 250 000 de operación). 2028 y 2029: mismo nivel, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por la Rectoría para el lunes 4 de enero de 2027

Dato	Valor
Cumplimiento que el cliente reconoce	Ley de Educación Superior, bajo la supervisión del Ministerio de Educación, Ciencia y Tecnología; Ley para la Protección de Datos Personales; cláusulas de confidencialidad de la investigación patrocinada; PCI DSS por el botón de pago del banco recaudador

Controles que ya existen

Familia	Estado actual
Inventario	No hay inventario centralizado; cada facultad lleva el suyo o ninguno
Parches	Esporádicos; servidores de facultades con sistemas operativos sin soporte
Red	Red plana; los dispositivos personales entran a la misma red que las oficinas
Cuentas	Segundo factor en Microsoft 365 solo para personal administrativo
Antimalware	Antivirus en equipos institucionales; filtro de correo de Microsoft 365
Monitoreo	Sin visibilidad del tráfico de red ni bitácoras centralizadas

4.11 AeroComponentes de El Salvador (AESA)

Grupo de Implementación asignado: IG3. Cadena de suministro aeroespacial con requisitos de trazabilidad y propiedad intelectual de diseño.

Datos básicos de la empresa

- **Sector:** Manufactura Avanzada (Aeroespacial).
- **Tamaño:** Mediana (600 empleados, alta especialización).
- **Ubicación:** Planta de producción y centro de diseño en el complejo industrial de San Bartolo.
- **Misión:** Diseñar y manufacturar componentes de alta precisión para la industria aeroespacial global, cumpliendo con los más estrictos estándares de calidad y seguridad.
- **Visión:** Ser el proveedor centroamericano de referencia para los gigantes de la industria aeroespacial.
- **Estructura Organizacional Básica:** Dirección General, Ingeniería y Diseño, Producción, Calidad, Cadena de Suministro, TI/OT, Finanzas.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Fabricación de partes para aeroestructuras y motores de avión.
- **Clientes:** Grandes fabricantes de aeronaves (ej. Boeing, Airbus, Embraer) y sus proveedores de primer nivel (Tier 1).

Procesos Críticos (4):

- **1. Gestión del Ciclo de Vida del Producto (PLM):** Protección de los diseños CAD/CAM y especificaciones de ingeniería (propiedad intelectual crítica).
- **2. Sistema de Ejecución de Manufactura (MES):** Control y monitoreo de la producción en la planta a través de maquinaria CNC y sistemas de control industrial (OT/ICS).
- **3. Gestión de la Cadena de Suministro Segura:** Coordinación con proveedores y clientes, sujeta a estrictos controles de seguridad contractuales.

  - **4. Sistema de Gestión de Calidad (QMS):** Documentación y trazabilidad de cada componente producido para cumplir con las certificaciones del sector.
- **Dependencia Tecnológica:** Crítica. La propiedad intelectual y la integridad de los sistemas de producción (OT) son la base del negocio.

Infraestructura tecnológica inicial

- **Sistemas:** Software PLM de Siemens NX, ERP SAP S/4HANA, sistemas MES en la planta, red OT con PLCs.
- **Red y Comunicaciones:** Redes de TI y OT convergentes, pero sin una segmentación o monitoreo de seguridad adecuado entre ellas.
- **Madurez y Controles Actuales:** Nivel bajo. El foco ha sido la producción, no la ciberseguridad. Los ingenieros de diseño a menudo se llevan información sensible en portátiles sin cifrar, y la red OT es vulnerable a ataques que podrían sabotear la producción o robar diseños industriales.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ventas anuales	USD 110 M	95–125 M	Tres clientes concentran el 70 % de las ventas; exportación del 100 %
Margen EBITDA	16 %	13–19 %	Sobre ventas
Temporada alta	Cierre de trimestre de los clientes	—	Despachos del último mes del trimestre frente al mes promedio: 1,3 (1,2–1,5)
Volumen de producción	38 000 piezas despachadas al mes	33 000–43 000	2 400 números de parte activos; valor promedio de una orden de compra USD 180 000
Datos personales	Expedientes de 600 empleados	—	Incluye 150 técnicos con acreditaciones de acceso a datos técnicos de clientes
Costo de notificar a un titular	USD 1,00	0,60–1,50	Carta y correo a empleados
Costo de reposición de equipos clave	USD 1,1 M por un centro de mecanizado CNC de cinco ejes	0,9–1,3 M	Servidores y software del MES USD 900 000 (750 000–1 100 000)
Pieza no conforme en el cliente	USD 25 000 por evento	15 000–40 000	Retiro, inspección en el cliente y penalidad

Operación por proceso

Proceso	Gestión del ciclo de vida del producto (PLM)
Horario	Ingeniería de lunes a viernes de 7:00 a 17:00
Personal en turno y costo	70 ingenieros de diseño; costo cargado USD 22 por hora (±15 %)
Procedimiento alterno	Trabajo con copias locales de los modelos, sin liberar revisiones nuevas

Proceso	Gestión del ciclo de vida del producto (PLM)
Penalizaciones	Acuerdos de confidencialidad y de control de exportaciones con los clientes: una fuga de datos técnicos puede terminar el contrato
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: ingenieros sin acceso a modelos vigentes · 24 h: cambios de ingeniería detenidos · 72 h: órdenes nuevas sin programas CNC liberados · 1 semana: entregas en riesgo; aviso a clientes · 1 mes: si hubo robo de diseños, pérdida del cliente y de su programa

Proceso	Sistema de ejecución de manufactura (MES) y maquinaria CNC
Horario	Planta 24 horas en tres turnos, de lunes a sábado
Personal en turno y costo	150 operarios y técnicos por turno; costo cargado USD 7 por hora (±15 %)
Procedimiento alterno	Programas CNC cargados a mano desde USB por el programador de turno y órdenes impresas; capacidad al 50 %
Penalizaciones	Entregas tardías: 1 % del valor de la orden por día, con tope de 10 %
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: máquinas detenidas o con carga manual de programas · 24 h: producción a la mitad; piezas en proceso sin registro · 72 h: entregas atrasadas y penalidades · 1 semana: clientes activan proveedores alternos · 1 mes: si hubo sabotaje de programas, piezas no conformes en vuelo y retiro de la certificación

Proceso	Gestión de la cadena de suministro segura
Horario	Oficina de 7:00 a 17:00; portales de los clientes 24 horas
Personal en turno y costo	25 personas de compras, planificación y logística; costo cargado USD 12 por hora (±15 %)
Procedimiento alterno	Pedidos y avisos de despacho por correo
Penalizaciones	Evaluación de proveedores de cada cliente: una calificación baja suspende órdenes nuevas; auditoría anual de ciberseguridad por contrato
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin avisos de despacho electrónicos · 24 h: materiales sin pedir y recepciones sin registrar · 72 h: faltantes de materia prima · 1 semana: calificación de proveedor degradada · 1 mes: suspensión de órdenes nuevas

Proceso	Sistema de gestión de calidad (QMS)
Horario	Oficina de lunes a viernes; inspección en los tres turnos
Personal en turno y costo	40 inspectores y personal de calidad; costo cargado USD 11 por hora (±15 %)
Procedimiento alterno	Certificados de conformidad y registros de inspección en papel
Penalizaciones	Sin trazabilidad completa no se despacha; registros incompletos ponen en riesgo la certificación AS9100
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: inspecciones registradas en papel · 24 h: despachos detenidos por falta de certificados · 72 h: acumulación de piezas sin liberar · 1 semana: auditoría extraordinaria del cliente · 1 mes: riesgo de perder la certificación y la condición de proveedor aprobado

Tecnología

Elemento	Situación actual
PLM y CAD	Siemens NX 2306 y Teamcenter 14 en Windows Server 2019 con Microsoft SQL Server 2019
ERP	SAP S/4HANA 2021 en el centro de datos de la planta
Planta	MES de un proveedor local en Windows Server 2016; centros CNC con controladores Fanuc y Siemens Sinumerik; PLC Allen-Bradley
Oficina e identidad	Active Directory en Windows Server 2019; Microsoft 365; laptops con Windows 11 sin cifrado de disco
Red	Redes de TI y OT convergentes con conmutadores Cisco IOS 15; VPN hacia los clientes y sus portales de proveedores

Respaldos y continuidad

Sistema	Situación actual
PLM	Respaldo diario de Teamcenter a un NAS en la planta
ERP	Respaldo nocturno a disco y semanal a cinta guardada en la planta
Programas CNC	En el servidor del MES y en memorias USB de los programadores
Sitio alterno y pruebas	No existe sitio alterno; en 2025 se restauró Teamcenter en 20 horas

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Robo en un viaje de la laptop de un ingeniero con modelos de un cliente, sin cifrar	—	Notificación al cliente y auditoría extraordinaria
2024	Malware en una estación de programación CNC que entró por una memoria USB	2 días	USD 55 000 en producción perdida
2025	Correo dirigido que suplantó a un cliente para pedir planos	Detectado antes de enviar	Sin pérdida
2026	Auditoría de ciberseguridad de un cliente con 11 hallazgos	—	Plan de corrección exigido en 6 meses

Organización y presupuesto

Dato	Valor
Organigrama	Dirección General; Ingeniería y Diseño; Producción; Calidad; Cadena de Suministro; TI/OT (14 personas); Finanzas, que incluye RR. HH. Asesoría legal y de comercio exterior externa; auditoría interna anual del grupo accionista. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 850 000 (550 000 de inversión y 300 000 de operación). 2028 y 2029: USD 600 000 por año, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por la Dirección General para el lunes 4 de enero de 2027

Dato	Valor
Cumplimiento que el cliente reconoce	Certificación AS9100 exigida por los clientes; requisitos contractuales de ciberseguridad de los clientes; controles de exportación de Estados Unidos (ITAR y EAR) sobre datos técnicos recibidos; Ley para la Protección de Datos Personales (empleados)

Controles que ya existen

Familia	Estado actual
Cifrado	Laptops de ingeniería sin cifrado de disco
Segmentación	Sin separación entre TI y OT ni monitoreo del tráfico
Medios removibles	Memorias USB permitidas en planta y en ingeniería
Antimalware	Antivirus en estaciones y servidores de TI; no en las estaciones de programación CNC
Cuentas	Segundo factor solo en la VPN hacia los clientes
Seguridad física	Tarjeta de acceso a la planta y al área de ingeniería

4.12 Supermercados El Ahorro

Grupo de Implementación asignado: IG3. Datos de tarjeta en punto de venta a gran volumen bajo PCI DSS, operación distribuida en decenas de sitios y fraude dirigido como amenaza principal.

Datos básicos de la empresa

- **Sector:** Retail y Consumo Masivo.
- **Tamaño:** Grande (2,500 empleados).
- **Ubicación:** 40 sucursales a nivel nacional y un centro de distribución central.
- **Misión:** Ofrecer a las familias salvadoreñas la mayor variedad de productos de alta calidad a los mejores precios, con un servicio al cliente excepcional.
- **Visión:** Liderar el mercado de retail en El Salvador, innovando en la experiencia de compra tanto física como digital.
- **Estructura Organizacional Básica:** Presidencia, Dirección Comercial, Dirección de Operaciones, Dirección de Logística, TI, Marketing, Finanzas.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Venta de abarrotes, productos frescos y mercancías generales. Plataforma de e-commerce con entrega a domicilio.
- **Clientes:** Consumidor final a nivel nacional.

Procesos Críticos (4):

  - **1. Operación de Puntos de Venta (POS):** Procesamiento seguro de miles de transacciones con tarjeta de crédito/débito por hora (PCI DSS).
  - **2. Gestión de la Cadena de Suministro e Inventario:** Coordinación del centro de distribución con las 40 sucursales para evitar desabastecimiento.
  - **3. Administración de la Plataforma de E-commerce:** Operación y protección del sitio web, la app móvil y los datos de los clientes en línea.

  - **4. Gestión del Programa de Lealtad:** Protección de la base de datos con información personal y hábitos de compra de millones de clientes.
- **Dependencia Tecnológica:** Crítica. Una falla en los sistemas POS o de logística paraliza las ventas. Una brecha de datos de tarjetas destruiría la confianza.

Infraestructura tecnológica inicial

- **Sistemas:** ERP SAP para Retail, sistemas POS de NCR en cada sucursal, plataforma de e- commerce Magento, data warehouse en Azure para analítica.
- **Red y Comunicaciones:** Red WAN que conecta todas las sucursales con el centro de datos. Redes Wi-Fi en tiendas para empleados y clientes.
- **Madurez y Controles Actuales:** Nivel bajo. Cumplen con lo mínimo de PCI DSS por obligación, pero sin un entendimiento real del riesgo. Los sistemas POS son antiguos y difíciles de parchear, y la base de datos del programa de lealtad no está cifrada, siendo un objetivo muy atractivo para los ciberdelincuentes.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ventas anuales	USD 420 M	380–460 M	95 % en tiendas y 5 % en línea
Margen bruto	22 %	20–24 %	Sobre ventas netas
Temporada alta	Noviembre, diciembre y Semana Santa	—	Ventas del período frente al mes promedio: tiendas 1,8 (1,5–2,2); centro de distribución 1,6 (1,3–1,9); en línea 2,5 (2,0–3,0)
Pagos con tarjeta	7,2 millones de transacciones al año	6,5–8,0 millones	48 % de las ventas en tienda (40–55 %); comercio de nivel 1 de PCI DSS con ROC anual por un QSA
Clientes no atendidos que no regresan	50 %	35–65 %	Estimación de la Dirección Comercial cuando falla el cobro
Datos personales en bases propias	1,8 millones de titulares de lealtad	1,5–2,1 millones	Más 220 000 cuentas de clientes en línea
Costo de notificar a un titular	USD 0,35	0,25–0,50	Cotización vigente del proveedor de mensajería (SMS y correo)
Costo de reposición de cajas y controladores	USD 1,9 M	1,6–2,3 M	480 cajas (12 por sucursal) y 40 controladores de tienda

Operación por proceso

Proceso	Operación de puntos de venta (cajas en 40 sucursales)
Horario	7:00 a 21:00 todos los días (el cliente estima entre 13 y 15 horas según la sucursal)
Personal en turno y costo	1 200 personas en turno; costo cargado USD 3,20 por hora (±15 %)
Procedimiento alterno	Cobro en efectivo con registro manual en el 30 % de las cajas (20–40 %); costo adicional USD 1 200 por hora en toda la cadena

Proceso	Operación de puntos de venta (cajas en 40 sucursales)
Penalizaciones	El adquirente no penaliza la indisponibilidad
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: filas largas, solo cobro en efectivo, quejas en redes sociales y ventas de la jornada perdidas en parte · 24 h: se pierde la venta del día; perecederos sin rotación; cobertura en medios nacionales · 72 h: clientes se van a la competencia; reclamos ante la Defensoría del Consumidor por cobros sin comprobante · 1 semana: bajas de afiliados del programa de lealtad; proveedores renegocian entregas · 1 mes: pérdida de participación de mercado que la Dirección Comercial no espera recuperar en el año

Proceso	Cadena de suministro e inventario (centro de distribución y ERP SAP)
Horario	24 horas, todos los días
Personal en turno y costo	300 personas en turno; costo cargado USD 3,50 por hora (±15 %)
Procedimiento alterno	Despacho con listas impresas y conteo manual; costo adicional USD 600 por hora
Penalizaciones	Tres transportistas cobran tiempo de espera: USD 400 por hora en conjunto
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: se retrasan los despachos del día; las sucursales operan con su inventario · 24 h: faltan productos de alta rotación en las sucursales; perecederos en riesgo en el centro de distribución · 72 h: estantes vacíos en la mayoría de las sucursales; pérdida de perecederos · 1 semana: incumplimiento con proveedores y pérdida de acuerdos comerciales · 1 mes: la operación de tiendas no se sostiene sin reposición

Proceso	Plataforma de e-commerce (sitio Magento y app móvil con entrega a domicilio)
Horario	Pedidos 24 horas; despachos de 8:00 a 20:00
Personal en turno y costo	40 personas en turno; costo cargado USD 5,00 por hora (±15 %)
Procedimiento alterno	Pedidos por teléfono y WhatsApp con cobro contra entrega; costo adicional USD 250 por hora
Penalizaciones	Ninguna contractual; reembolsos de pedidos no entregados
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: se pierden los pedidos del período; reclamos en redes · 24 h: clientes cancelan pedidos programados; campañas pagadas sin conversión · 72 h: pérdida de clientes en línea hacia la competencia · 1 semana: daño a la marca digital; revisión del contrato con la agencia de Magento · 1 mes: el canal en línea pierde la temporada alta si coincide con ella

Proceso	Programa de lealtad (base de datos de afiliados y data warehouse en Azure)
Horario	Consultas y acumulación en línea durante el horario de tiendas; campañas en horario de oficina
Personal en turno y costo	12 personas de Marketing; costo cargado USD 6,00 por hora
Procedimiento alterno	Acumulación de puntos diferida: las cajas guardan las transacciones y se cargan después
Penalizaciones	Ninguna contractual

Proceso	Programa de lealtad (base de datos de afiliados y data warehouse en Azure)
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: los afiliados no ven sus puntos; sin efecto en ventas · 24 h: reclamos al centro de atención; campañas en pausa · 72 h: campañas de temporada retrasadas · 1 semana: pérdida de confianza de los afiliados · 1 mes: bajas del programa y pérdida de datos para segmentar campañas. Una fuga de la base, en cambio, tiene efecto inmediato: notificación en 72 horas a la ACE, la FGR y los titulares

Tecnología

Elemento	Situación actual
Cajas y controladores de tienda	480 cajas NCR y 40 controladores de tienda con Windows 10 IoT Enterprise 2016 LTSB; software de caja NCR
ERP	SAP para Retail en el centro de datos de San Salvador
Comercio electrónico	Magento Open Source 2.4 sobre Ubuntu 22.04 con NGINX y MySQL 8.0; una sola instancia con réplica cada 15 minutos en el mismo sitio; app móvil; desarrollo y mantenimiento por una agencia externa
Lealtad y analítica	Base de afiliados en Microsoft SQL Server 2019 en el centro de datos; data warehouse en Microsoft Azure
Identidad y oficina	Active Directory en Windows Server 2022 sincronizado con Microsoft Entra ID; correo y archivos en Microsoft 365; estaciones y laptops con Windows 11 Enterprise
Red	Un enlace WAN por sucursal hacia el centro de datos y el adquirente, sin respaldo; conmutadores Cisco con IOS XE 17; Wi-Fi de empleados y de clientes en cada sucursal; dos proveedores de internet en oficinas centrales
Pagos	Un solo adquirente para tiendas y comercio en línea
Instalaciones	Oficinas centrales y único centro de datos en San Salvador; un centro de distribución; planta eléctrica en sucursales y en el centro de distribución; el centro de distribución tiene enlace de respaldo

Respaldos y continuidad

Sistema	Situación actual
ERP SAP	Respaldo completo cada noche a disco local del centro de datos; nunca se ha probado una restauración completa
Magento y base de clientes	Réplica cada 15 minutos en el mismo centro de datos; sin copia fuera del sitio
Base de lealtad	Respaldo nocturno a disco local, sin cifrar
Cajas y controladores	Sin imagen de respaldo; la reinstalación la hace NCR a pedido
Sitio alterno	No existe

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Ransomware en una laptop de Finanzas, contenido sin cifrar servidores	2 días de trabajo de una persona	USD 3 000

Año	Incidente	Duración	Costo
2024	Corte del enlace WAN en tres sucursales por obra pública	6 horas	Ventas perdidas no cuantificadas; cobro solo en efectivo
2025	Correo de phishing que robó la contraseña de una cuenta de compras; se detectó antes de pagar	1 día	Sin pérdida económica
2026	Falla de un controlador de tienda en temporada de Semana Santa	9 horas hasta que NCR lo reinstaló	Estimación de la sucursal: USD 18 000 en ventas

Organización y presupuesto

Dato	Valor
Organigrama	Presidencia; Direcciones de Operaciones, Logística, Comercial, Marketing y Finanzas; Gerencia de TI (14 personas). RR. HH. depende de Finanzas. No hay áreas propias de Legal ni de Auditoría interna: una firma externa, contratada por la Presidencia, presta la asesoría legal y la auditoría. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 950 000 (600 000 de inversión y 350 000 de operación). 2028 y 2029: mismo nivel, sujeto a la aprobación anual
Arranque del programa de seguridad	Aprobado por la Presidencia para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	PCI DSS por obligación del adquirente, cumplido «en lo mínimo» (ROC anual); Ley para la Protección de Datos Personales; Ley de Protección al Consumidor en la venta en línea y el programa de lealtad

Controles que ya existen

Familia	Estado actual
Inventario	Solo los componentes del entorno de tarjeta, por exigencia de PCI DSS
Configuración segura	Estándares escritos solo para el entorno de tarjeta; contraseñas por defecto cambiadas solo ahí
Antimalware	En cajas y servidores del entorno de tarjeta, con firmas actualizadas; no en el resto de equipos
Cuentas y accesos	Identificadores únicos en el entorno de tarjeta; ningún acceso administrativo exige segundo factor
Bitácoras	Se guardan localmente en el entorno de tarjeta; nadie las revisa de forma centralizada
Respuesta a incidentes	Plan escrito para PCI DSS, nunca ejercitado
Concientización	Capacitación anual general
Proveedores	Lista de proveedores con acceso al entorno de tarjeta; contrato de la agencia de Magento sin cláusulas de seguridad
Pruebas	Escaneo trimestral por un ASV y prueba de penetración anual, externa e interna, solo del entorno de tarjeta

Familia	Estado actual
Segmentación	Las cajas comparten red con la Wi-Fi y la red corporativa de la sucursal

4.13 OmniSource Solutions

Grupo de Implementación asignado: IG3. Custodia y procesamiento de datos regulados de terceros a escala, con riesgo heredado de sus clientes.

Datos básicos de la empresa

- **Sector:** BPO (Business Process Outsourcing) y Centros de Contacto.
- **Tamaño:** Grande (1,800 empleados).
- **Ubicación:** Tres sites de operación en zonas francas de San Salvador.
- **Misión:** Ser el socio estratégico de nuestros clientes globales, ofreciendo servicios de BPO de clase mundial con un enfoque en la seguridad de la información y la calidad operativa.
- **Visión:** Liderar la industria de BPO en la región, siendo reconocidos por nuestra confiabilidad y capacidad para proteger los datos de nuestros clientes.
- **Estructura Organizacional Básica:** Gerencia de País, Directores de Cuentas, Operaciones, Calidad, TI, Seguridad de la Información (rol incipiente).

Modelo de negocio y procesos críticos

- **Servicios Principales:** Soporte técnico, atención al cliente, procesamiento de back-office para empresas de EE.UU. y Europa.
- **Clientes:** Corporaciones internacionales en los sectores de telecomunicaciones, salud y finanzas.

Procesos Críticos (3):

  - **1. Segregación y Protección de Datos de Clientes:** Garantizar que los datos de un cliente (ej. un banco) estén completamente aislados y protegidos de otros.
  - **2. Operación de la Infraestructura de Centro de Contacto:** Disponibilidad de los sistemas de telefonía (VoIP), CRM y estaciones de trabajo de los agentes.
  - **3. Cumplimiento de Requisitos Contractuales y Regulatorios:** Adherirse a las normativas que sus clientes deben cumplir (ej. HIPAA, GDPR, PCI DSS).

- **Dependencia Tecnológica:** Crítica. Su negocio es gestionar la información de otros; una brecha de seguridad significa la pérdida de sus contratos más importantes.

Infraestructura tecnológica inicial

- **Sistemas:** Plataforma de telefonía Avaya, VDI (Virtual Desktop Infrastructure) con VMware Horizon, CRMs de clientes (Salesforce, Zendesk), herramientas de monitoreo de agentes.
- **Red y Comunicaciones:** Entorno multi-tenant. Conexiones dedicadas a los centros de datos de los clientes.
- **Madurez y Controles Actuales:** Nivel bajo. Implementan los controles que los clientes exigen de forma reactiva, pero sin una estrategia integral. El control de amenazas internas es muy débil, y no tienen una solución de DLP para prevenir que los agentes extraigan información sensible.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales	USD 72 M	65–80 M	22 clientes de telecomunicaciones, salud y finanzas de Estados Unidos y Europa; los cinco mayores suman el 60 %
Margen EBITDA	14 %	11–17 %	Sobre ingresos
Temporada alta	Noviembre a enero: temporada navideña de los clientes y período de inscripción de seguros médicos en Estados Unidos	—	Interacciones frente al mes promedio: 1,4 (1,2–1,6)
Volumen de transacciones	95 000 interacciones por día	80 000–110 000	Tarifa facturada al cliente: USD 14 por hora productiva de agente (12–17)
Datos personales a los que se accede	18 millones de clientes finales de sus clientes	15–21 millones	Datos de cuentas, de salud y de tarjetas; los datos viven en los sistemas de cada cliente
Pagos con tarjeta	2,2 millones de pagos por teléfono al año para cuatro clientes	1,9–2,5 millones	Proveedor de servicios de nivel 1 de PCI DSS con ROC anual por un QSA
Costo de notificar a un titular	USD 1,80	1,20–3,00	Lo notifica el cliente; el contrato obliga a OmniSource a reembolsarle el costo
Costo de reposición de equipos clave	USD 2,2 M por la plataforma VDI y la telefonía de un site	1,8–2,6 M	Servidores, licencias y 450 clientes ligeros

Operación por proceso

Proceso	Segregación y protección de datos de clientes
Horario	24 horas, todos los días
Personal en turno y costo	12 personas de TI de cuentas y de seguridad; costo cargado USD 15 por hora (±15 %)
Procedimiento alterno	Suspender el acceso de la cuenta afectada hasta verificar el aislamiento
Penalizaciones	Cláusulas de indemnización: OmniSource paga el costo de la brecha del cliente hasta 12 meses de facturación de esa cuenta; el cliente puede terminar el contrato de inmediato
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: cuenta suspendida; agentes sin trabajo facturable · 24 h: el cliente exige informe de la exposición · 72 h: auditoría forense a cargo de OmniSource · 1 semana: terminación del contrato de la cuenta afectada · 1 mes: otros clientes revisan sus contratos; daño a la marca que la Gerencia de País considera el mayor riesgo del negocio

Proceso	Operación de la infraestructura del centro de contacto
Horario	24 horas; tres sites con 1 400 puestos
Personal en turno y costo	1 350 agentes en el turno pico; costo cargado USD 5,50 por hora (±15 %)

Proceso	Operación de la infraestructura del centro de contacto
Procedimiento alterno	Traslado de colas a otro site, con 20 % de capacidad libre; sin VDI ni telefonía no hay alternativa
Penalizaciones	SLA de nivel de servicio (80 % de llamadas atendidas en 20 segundos): descuento del 5 % de la factura mensual de la cuenta por cada punto por debajo; las horas no atendidas no se facturan
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: llamadas abandonadas; descuentos por SLA · 24 h: horas no facturadas de un site completo · 72 h: clientes desvían colas a otros proveedores · 1 semana: renegociación de contratos · 1 mes: pérdida de cuentas y despidos

Proceso	Cumplimiento de requisitos contractuales y regulatorios
Horario	Oficina de lunes a viernes; auditorías de clientes todo el año
Personal en turno y costo	25 personas de Calidad y Cumplimiento; costo cargado USD 12 por hora (±15 %)
Procedimiento alterno	Evidencias reunidas a mano para cada auditoría
Penalizaciones	Un hallazgo mayor en una auditoría de cliente (PCI DSS, HIPAA o SOC 2) suspende la apertura de colas nuevas
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin efecto · 24 h: evidencias atrasadas · 72 h: auditoría con hallazgos · 1 semana: suspensión de colas nuevas · 1 mes: pérdida de la certificación de PCI DSS y de las cuentas de tarjeta

Tecnología

Elemento	Situación actual
Telefonía	Avaya Aura 10.1 con grabación de llamadas
Escritorios	VMware Horizon 8 sobre vSphere 7.0, con escritorios Windows 10 Enterprise por cuenta
Aplicaciones de clientes	Salesforce y Zendesk de cada cliente, accedidos desde el escritorio virtual
Oficina e identidad	Active Directory en Windows Server 2019; Microsoft 365
Red	Tres sites en zonas francas; enlaces MPLS dedicados a los centros de datos de los clientes; cortafuegos Cisco Firepower con FTD 7.2

Respaldos y continuidad

Sistema	Situación actual
Escritorios virtuales	Imágenes maestras respaldadas cada semana
Grabaciones de llamadas	Almacenamiento local de 90 días, sin copia
Sitio alterno	Los otros dos sites, con 20 % de capacidad libre
Última prueba	Traslado de colas entre sites en 2025; tardó 5 horas

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Un agente fotografió datos de tarjetas con su celular	Dos meses hasta detectarlo	400 tarjetas expuestas; USD 70 000 reembolsados al cliente
2024	Caída de la telefonía de un site	6 horas	USD 45 000 en descuentos por SLA
2025	Configuración errónea de VDI que dejó a agentes de una cuenta ver una carpeta de otra	2 días	Informe al cliente; sin terminación
2026	Phishing con ofertas de empleo falsas dirigido a supervisores	1 día	Dos cuentas comprometidas y bloqueadas

Organización y presupuesto

Dato	Valor
Organigrama	Gerencia de País; Directores de Cuentas; Operaciones; Calidad; TI (40 personas); Seguridad de la Información (rol incipiente, 2 personas); Recursos Humanos; asesoría legal local externa y área legal del grupo; auditoría interna del grupo
Presupuesto aprobado para seguridad	2027: USD 1,1 M (0,6 M de inversión y 0,5 M de operación). 2028 y 2029: +5 % anual, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por la Gerencia de País para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	PCI DSS como proveedor de servicios de nivel 1; HIPAA como asociado de negocio de clientes de salud de Estados Unidos; RGPD como encargado del tratamiento de clientes europeos; informes SOC 2 que exigen los clientes; Ley para la Protección de Datos Personales; Ley de Servicios Internacionales

Controles que ya existen

Familia	Estado actual
Segregación	Escritorio virtual y red lógica por cuenta; pisos sin celulares solo en las cuentas de tarjetas
Fuga de datos	Sin herramienta de prevención de fuga de datos; portapapeles e impresión habilitados en varias cuentas
Monitoreo	Monitoreo de productividad de agentes, sin monitoreo de seguridad ni de amenaza interna
Cuentas	Segundo factor para supervisores y TI; agentes solo con contraseña
Antimalware	Antivirus en escritorios virtuales y servidores
Pruebas	ROC anual de PCI DSS y escaneo trimestral por un ASV, solo en el entorno de tarjeta

4.14 GestioPyme Cloud

Grupo de Implementación asignado: IG3. Custodia multiempresa de datos de clientes: el compromiso de la plataforma se propaga a toda la cartera y hereda el riesgo de cada empresa atendida.

Datos básicos de la empresa

- **Sector:** Software como Servicio (SaaS).
- **Tamaño:** Mediana (220 empleados).
- **Ubicación:** Oficinas de desarrollo en San Salvador.
- **Misión:** Empoderar a las PYMES de Latinoamérica con una plataforma ERP en la nube, asequible, potente y segura para gestionar su negocio.
- **Visión:** Ser la plataforma de gestión empresarial número uno para las PYMES de habla hispana.
- **Estructura Organizacional Básica:** CEO, CTO, Director de Producto, Director de Ventas, Éxito del Cliente, DevOps.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Plataforma SaaS multi-tenant que ofrece módulos de contabilidad, facturación, inventario y CRM.
- **Clientes:** Pequeñas y medianas empresas (PYMES) en toda Latinoamérica.

Procesos Críticos (4):

  - **1. Disponibilidad y Rendimiento de la Plataforma SaaS:** Garantizar el acceso 24/7 a la plataforma para todos sus clientes.
  - **2. Aislamiento Lógico de Datos de Clientes:** Asegurar que una empresa cliente no pueda, bajo ninguna circunstancia, acceder a los datos de otra.
  - **3. Ciclo de Vida de Desarrollo de Software Seguro (DevSecOps):** Integrar la seguridad en el proceso de desarrollo y despliegue continuo (CI/CD).
  - **4. Respaldo y Recuperación ante Desastres:** Capacidad de restaurar los datos de todos sus clientes en caso de una falla catastrófica.

- **Dependencia Tecnológica:** Crítica y absoluta. La empresa es su software.

Infraestructura tecnológica inicial

- **Sistemas:** Arquitectura 100% nativa en la nube (AWS), usando EKS (Kubernetes), Aurora, S3 y una variedad de servicios PaaS.
- **Red y Comunicaciones:** Infraestructura como código (Terraform), pipelines de CI/CD con Jenkins/GitLab.
- **Madurez y Controles Actuales:** Alta madurez en DevOps, pero baja en DevSecOps. La seguridad es una ocurrencia tardía. No realizan análisis estático o dinámico de seguridad del código (SAST/DAST), la gestión de secretos es deficiente y no tienen un programa de gestión de vulnerabilidades para sus contenedores e imágenes.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos recurrentes anuales	USD 21 M	19–23 M	14 000 empresas clientes en nueve países; El Salvador aporta el 40 %
Margen	Margen bruto 74 %; EBITDA 12 %	EBITDA 8–15 %	Sobre ingresos

Dato	Valor probable	Rango	Detalle
Temporada alta	Días 1 a 15 de cada mes (cierres y declaraciones) y cierre fiscal anual	—	Uso de la plataforma frente al día promedio: 2,2 (1,8–2,6)
Volumen de transacciones	3,5 millones de documentos tributarios electrónicos al mes	3,0–4,0 millones	Emitidos por los clientes salvadoreños y transmitidos al Ministerio de Hacienda por la plataforma
Datos personales	2,6 millones de titulares	2,2–3,0 millones	Clientes y empleados de las 14 000 empresas (facturas, planillas y CRM); GestioPyme es encargado del tratamiento
Pagos con tarjeta	150 000 cargos de suscripción al año	130 000–170 000	Los procesa Stripe; comercio de nivel 3 de PCI DSS
Costo de notificar	USD 3 por empresa cliente	2–5	Correo y llamada del equipo de Éxito del Cliente; cada empresa notifica a sus propios titulares
Costo de reconstruir la plataforma	USD 600 000 en horas de ingeniería	450 000–800 000	La infraestructura se recrea con Terraform; el costo está en datos y pruebas

Operación por proceso

Proceso	Disponibilidad y rendimiento de la plataforma SaaS
Horario	24 horas, todos los días
Personal en turno y costo	8 personas de DevOps y soporte por turno; costo cargado USD 16 por hora (±15 %)
Procedimiento alterno	Ninguno; página de estado y comunicación a clientes
Penalizaciones	SLA de 99,9 % mensual en los planes empresariales (1 200 clientes): crédito del 10 % de la mensualidad por cada décima por debajo
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: clientes sin facturar ni cobrar; tickets masivos · 24 h: clientes salvadoreños sin emitir documentos tributarios; ventas detenidas en sus negocios · 72 h: declaraciones de impuestos de clientes en riesgo si coincide con el día 10 a 15 · 1 semana: bajas de clientes y reclamos públicos · 1 mes: pérdida de clientes que el CEO estima en 15 % de la base

Proceso	Aislamiento lógico de datos de clientes
Horario	24 horas, todos los días
Personal en turno y costo	6 ingenieros de plataforma; costo cargado USD 20 por hora (±15 %)
Procedimiento alterno	Desactivar el módulo afectado hasta corregir
Penalizaciones	Cláusula de confidencialidad en el contrato; la empresa afectada puede terminar y reclamar daños
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: módulo desactivado para todos los clientes · 24 h: clientes afectados exigen explicación · 72 h: notificación a las empresas cuyos datos se expusieron · 1 semana: bajas de clientes y cobertura en medios del sector · 1 mes: pérdida de confianza que el CEO considera la amenaza principal del negocio

Proceso	Ciclo de vida de desarrollo seguro (CI/CD)
Horario	Despliegues diarios de lunes a jueves
Personal en turno y costo	90 desarrolladores; costo cargado USD 18 por hora (±15 %)
Procedimiento alterno	Congelar despliegues y corregir a mano en producción
Penalizaciones	Ninguna contractual
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: despliegues detenidos · 24 h: correcciones urgentes sin publicar · 72 h: atraso de funciones comprometidas con clientes · 1 semana: si el pipeline se comprometió, riesgo de código malicioso en producción · 1 mes: hoja de ruta del producto desplazada un trimestre

Proceso	Respaldo y recuperación ante desastres
Horario	24 horas, todos los días
Personal en turno y costo	4 ingenieros de DevOps; costo cargado USD 16 por hora (±15 %)
Procedimiento alterno	No aplica
Penalizaciones	Pérdida de datos contables de clientes: reclamos y posibles demandas
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin efecto si la base sigue operando · 24 h: si hay que restaurar, datos del día perdidos · 72 h: clientes rehacen su contabilidad · 1 semana: demandas de clientes · 1 mes: cierre de cuentas y pérdida de la reputación de la empresa

Tecnología

Elemento	Situación actual
Cómputo	Amazon EKS con Kubernetes 1.29 en una sola región de AWS
Datos	Amazon Aurora PostgreSQL 15 con una base compartida por todos los clientes y separación por identificador de empresa; Amazon S3 para documentos
Aplicación	Interfaz en React y API en Node.js 18
Entrega	Terraform 1.6; Jenkins y GitLab CE 16
Oficina e identidad	Google Workspace; usuarios IAM individuales en AWS; laptops con macOS 14 y Windows 11
Pagos	Stripe para el cobro de suscripciones

Respaldos y continuidad

Sistema	Situación actual
Aurora	Respaldos automáticos con retención de 7 días e instantánea diaria en la misma región y la misma cuenta
Documentos en S3	Dos de los cinco buckets sin versionado
Región alterna	No existe

Sistema	Situación actual
Última prueba de recuperación	Restauración de los datos de un solo cliente en 2025; la restauración completa nunca se ha probado

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Error de autorización en la API que mostró facturas de otra empresa a tres clientes	1 día	Dos clientes cancelaron; sin demanda
2024	Falla parcial de la región de AWS	4 horas	Créditos por SLA: USD 18 000
2025	Contraseña de la base de datos en un repositorio que clonó un exempleado	Detectada tres meses después	Rotación de credenciales; sin evidencia de uso
2026	Imagen de contenedor con una biblioteca vulnerable, explotada para minar criptomonedas	3 días	USD 9 000 en consumo de nube

Organización y presupuesto

Dato	Valor
Organigrama	CEO; CTO; Director de Producto; Director de Ventas; Éxito del Cliente; DevOps (12 personas); Finanzas y Administración, que incluye RR. HH. Asesoría legal externa; sin auditoría interna, con auditoría financiera externa anual. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 420 000 (220 000 de inversión y 200 000 de operación). 2028 y 2029: +10 % anual, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por el CEO para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Ley para la Protección de Datos Personales como encargado del tratamiento y las leyes de datos de los otros ocho países; normativa de documentos tributarios electrónicos del Ministerio de Hacienda; los clientes empresariales piden un informe SOC 2

Controles que ya existen

Familia	Estado actual
Código	Sin análisis estático ni dinámico de seguridad
Secretos	Credenciales en variables de entorno sin gestor de secretos y algunas en repositorios
Contenedores	Sin análisis de vulnerabilidades de imágenes
Cuentas	Segundo factor en AWS solo para administradores; Google Workspace con segundo factor para todos
Borde	AWS WAF con reglas administradas
Detección	Amazon GuardDuty activado, sin revisión de sus alertas

4.15 Alas Centroamericanas (ALACA)

Grupo de Implementación asignado: IG3. Seguridad operacional del transporte aéreo, datos de pasajeros y coordinación con autoridades aeronáuticas.

Datos básicos de la empresa

- **Sector:** Aviación y Transporte.
- **Tamaño:** Grande (1,100 empleados).
- **Ubicación:** Hub de operaciones en el Aeropuerto Internacional de El Salvador.
- **Misión:** Conectar Centroamérica con el mundo, ofreciendo una experiencia de viaje segura, puntual y amigable.
- **Visión:** Ser la aerolínea regional líder, reconocida por su innovación y excelencia operativa.
- **Estructura Organizacional Básica:** Dirección Ejecutiva, Operaciones de Vuelo, Mantenimiento, Servicios en Aeropuerto, Comercial, TI.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Transporte aéreo de pasajeros y carga.
- **Clientes:** Viajeros de negocios y de ocio.

Procesos Críticos (4):

  - **1. Sistema de Reservas y Emisión de Boletos (PSS):** Gestión de inventario de asientos y procesamiento de pagos.
  - **2. Operaciones de Vuelo y Despacho:** Planificación de rutas, peso y balance de aeronaves, y seguimiento de vuelos.
  - **3. Sistema de Control de Salidas (DCS):** Check-in de pasajeros y gestión de embarque en el aeropuerto.
  - **4. Protección de Datos de Pasajeros (PNR):** Manejo seguro de la información personal de los viajeros, sujeta a regulaciones internacionales.

- **Dependencia Tecnológica:** Crítica. Un fallo en los sistemas de operaciones puede dejar aviones en tierra, con un impacto financiero y reputacional masivo.

Infraestructura tecnológica inicial

- **Sistemas:** Dependencia de sistemas GDS/PSS de terceros como Amadeus o Sabre. Sistemas de despacho de vuelo de Jeppesen. Redes operacionales en el aeropuerto.
- **Red y Comunicaciones:** Compleja red de integraciones con sistemas de aeropuertos, control de tráfico aéreo y otros socios.
- **Madurez y Controles Actuales:** Nivel bajo. La seguridad se ha delegado en gran medida a los proveedores de sistemas como Amadeus. Los sistemas internos son legacy y vulnerables. No hay un programa de seguridad de aplicaciones para sus portales web, y la segmentación entre la red corporativa y las redes operacionales del aeropuerto es deficiente.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales	USD 520 M	480–560 M	Pasajeros 88 %, carga 12 %; 2,4 millones de pasajeros al año con 18 aeronaves
Margen operativo	8 %	5–11 %	Sobre ingresos
Temporada alta	Julio y agosto, diciembre y enero, Semana Santa	—	Pasajeros frente al mes promedio: 1,35 (1,2–1,5)
Volumen de operación	95 vuelos diarios	85–105	6 600 pasajeros por día; ingreso promedio por vuelo USD 13 000 (11 000–16 000)
Datos personales	2,4 millones de pasajeros al año	2,2–2,6 millones	900 000 socios del programa de viajero frecuente; datos de pasaporte para el envío previo a autoridades de destino
Pagos con tarjeta	1,9 millones de transacciones al año en sitio web, app y centro de llamadas	1,6–2,2 millones	Comercio de nivel 2 de PCI DSS con cuestionario de autoevaluación anual
Costo de notificar a un pasajero	USD 0,20	0,10–0,35	Correo y SMS; cotización vigente
Compensación por vuelo cancelado	USD 180 por pasajero	120–250	Reembolso, hotel y alimentación según la política de la aerolínea y las normas de los destinos
Costo de reposición de equipos clave	USD 1,4 M	1,1–1,8 M	Centro de control de operaciones, estaciones de mostrador y quioscos

Operación por proceso

Proceso	Sistema de reservas y emisión de boletos (PSS)
Horario	24 horas, todos los días
Personal en turno y costo	60 agentes de ventas y centro de llamadas por turno; costo cargado USD 7 por hora (±15 %)
Procedimiento alterno	Venta solo por agencias de viaje mediante los GDS; la venta directa se detiene
Penalizaciones	El contrato con el proveedor del PSS fija disponibilidad de 99,95 % con créditos menores
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin ventas directas; pasajeros sin cambiar reservas · 24 h: ventas directas del día perdidas; saturación del centro de llamadas · 72 h: pasajeros compran en otras aerolíneas · 1 semana: caída de reservas de la temporada · 1 mes: pérdida de participación en rutas competidas

Proceso	Operaciones de vuelo y despacho
Horario	24 horas; primer vuelo a las 5:30
Personal en turno y costo	Centro de control de operaciones con 25 personas por turno; costo cargado USD 20 por hora (±15 %)
Procedimiento alterno	Planes de vuelo desde el centro de respaldo del proveedor de despacho; peso y balance manual con hojas de carga; operación al 60 %, sostenible 24 horas

Proceso	Operaciones de vuelo y despacho
Penalizaciones	Cancelaciones: USD 180 por pasajero; tripulaciones fuera de su tiempo máximo de servicio obligan a cancelar
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: vuelos retrasados y conexiones perdidas · 24 h: 40 % de los vuelos cancelados; pasajeros varados en el hub · 72 h: tripulaciones y aeronaves fuera de posición; reclamos masivos · 1 semana: investigación de la autoridad aeronáutica · 1 mes: pérdida de confianza y de slots en aeropuertos de destino

Proceso	Sistema de control de salidas (DCS)
Horario	Aeropuerto de 3:30 a 24:00
Personal en turno y costo	90 agentes de aeropuerto por turno; costo cargado USD 6 por hora (±15 %)
Procedimiento alterno	Check-in manual con listas impresas y pases de abordar escritos a mano; capacidad al 40 %, con 45 minutos de retraso promedio por vuelo
Penalizaciones	Cargos del aeropuerto por ocupar posiciones más tiempo; conexiones perdidas a cargo de la aerolínea
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: filas y vuelos retrasados · 24 h: cancelaciones por retrasos acumulados · 72 h: cobertura regional en medios · 1 semana: reclamos ante autoridades de protección al consumidor · 1 mes: daño a la marca en temporada alta

Proceso	Protección de datos de pasajeros (PNR)
Horario	24 horas, todos los días
Personal en turno y costo	6 personas de TI y privacidad; costo cargado USD 16 por hora (±15 %)
Procedimiento alterno	No aplica
Penalizaciones	Envío previo de datos de pasajeros a autoridades de destino obligatorio; una fuga obliga a notificar a titulares de varios países
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin efecto si no hay fuga · 24 h: si hay fuga, notificación a autoridades de varios países · 72 h: notificación a pasajeros y cobertura en medios · 1 semana: investigación de autoridades de datos extranjeras · 1 mes: sanciones y bajas del programa de viajero frecuente

Tecnología

Elemento	Situación actual
Reservas y control de salidas	Amadeus Altéa (reservas, inventario y control de salidas) en la nube del proveedor
Despacho	Jeppesen para planificación de vuelo en la nube del proveedor; aplicación propia de peso y balance en Windows Server 2012 R2
Canales propios	Sitio web y app en PHP 7.4 con MySQL 5.7 en un hosting local
Oficina e identidad	Active Directory en Windows Server 2016; Microsoft 365; estaciones con Windows 10

Elemento	Situación actual
Red	Red corporativa y redes operacionales del aeropuerto (mostradores, quioscos y puertas) con segmentación débil; enlaces con el aeropuerto y con el proveedor del PSS

Respaldos y continuidad

Sistema	Situación actual
Reservas, control de salidas y despacho	Continuidad a cargo de cada proveedor en su nube, según contrato
Peso y balance	Respaldo semanal a un disco externo
Sitio web y app	Respaldo diario en el hosting, en el mismo proveedor
Centro de control alterno	Sala en el hangar, sin equipar

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Inyección SQL en el sitio web que expuso 12 000 registros de socios del programa de viajero frecuente	Detectada un mes después	USD 35 000 en investigación y notificación
2024	Falla mundial de estaciones Windows por una actualización defectuosa de un proveedor de seguridad; afectó quioscos y mostradores	8 horas	22 vuelos retrasados
2025	Toma de cuentas de socios y canje fraudulento de millas	6 semanas	USD 40 000
2026	Caída del enlace con el aeropuerto	3 horas	12 vuelos retrasados

Organización y presupuesto

Dato	Valor
Organigrama	Dirección Ejecutiva; Operaciones de Vuelo; Mantenimiento; Servicios en Aeropuerto; Comercial; TI (45 personas); Finanzas; Legal y Asuntos Regulatorios; Recursos Humanos; Auditoría Interna; Seguridad de la Aviación. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 1,6 M (1,0 M de inversión y 0,6 M de operación). 2028 y 2029: +5 % anual, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por la Dirección Ejecutiva para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Regulación de la Autoridad de Aviación Civil y normas de la OACI; auditoría IOSA de IATA; envío previo de datos de pasajeros a las autoridades de destino; PCI DSS como comercio; Ley para la Protección de Datos Personales y leyes de datos de los países de destino

Controles que ya existen

Familia	Estado actual
Proveedores	La seguridad de reservas, control de salidas y despacho se delega a los proveedores, sin revisión de sus informes

Familia	Estado actual
Aplicaciones	Sin pruebas de seguridad del sitio web ni de la app
Segmentación	Red corporativa y redes operacionales del aeropuerto poco separadas
Antimalware	Protección de estaciones de un proveedor comercial en equipos Windows
Parches	Irregulares; sistemas propios con versiones sin soporte
Cuentas	Segundo factor en el PSS por exigencia del proveedor; no en los sistemas propios

4.16 Capitalia Gestores de Patrimonio

Grupo de Implementación asignado: IG3. Patrimonio de alto valor bajo secreto financiero: tamaño pequeño con amenaza dirigida y sofisticada.

Datos básicos de la empresa

- **Sector:** Gestión de Inversiones y Banca Privada.
- **Tamaño:** Mediana (280 empleados).
- **Ubicación:** Oficinas en un centro financiero exclusivo de San Salvador.
- **Misión:** Preservar y hacer crecer el patrimonio de nuestros clientes a través de estrategias de inversión personalizadas y una gestión de riesgos prudente.
- **Visión:** Ser la firma de gestión de patrimonio más respetada y confiable de la región.
- **Estructura Organizacional Básica:** Socios Directores, Gestores de Portafolio, Analistas de Mercado, Cumplimiento y Riesgo, Operaciones, TI.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Gestión de carteras de inversión, planificación financiera, asesoría patrimonial.
- **Clientes:** Individuos de alto patrimonio (HNWI) y familias institucionales.

Procesos Críticos (4):

  - **1. Plataforma de Gestión de Portafolios y Trading:** Ejecución de operaciones en los mercados financieros.
  - **2. Protección de la Información Financiera del Cliente:** Máxima confidencialidad de los datos de activos y patrimonio de los clientes.
  - **3. Sistema de Gestión de Relaciones con Clientes (CRM):** Almacenamiento de toda la información personal y financiera de clientes muy sensibles.
  - **4. Cumplimiento Regulatorio y de Riesgo:** Monitoreo de operaciones para prevenir el fraude y cumplir con las regulaciones financieras.

- **Dependencia Tecnológica:** Crítica. La integridad de las operaciones de trading y la confidencialidad de los datos del cliente son la base de su existencia.

Infraestructura tecnológica inicial

- **Sistemas:** Software de gestión de portafolios de BlackRock Aladdin, terminales de Bloomberg, CRM Dynamics 365, portal seguro para clientes.
- **Red y Comunicaciones:** Red interna altamente segmentada pero mal administrada. Fuerte dependencia de aplicaciones SaaS.

- **Madurez y Controles Actuales:** Nivel intermedio-bajo. Tienen controles robustos en la plataforma de trading por exigencia del proveedor, pero la seguridad en los endpoints (equipos de los gestores) es débil. Son un objetivo principal para ataques de whaling y Business Email Compromise (BEC), y no tienen defensas avanzadas de correo electrónico ni un programa de concientización efectivo.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales	USD 38 M	34–42 M	Comisiones sobre USD 3 200 M de activos bajo gestión (3 000–3 400 M), con tasa media de 1,2 %
Margen operativo	32 %	27–37 %	Sobre ingresos
Temporada alta	Cierres de trimestre y fin de año, por rebalanceo de carteras	—	Operaciones frente al día promedio: 1,6 (1,3–1,9)
Volumen de transacciones	1 400 operaciones por día	1 100–1 700	300 instrucciones de transferencia de clientes por semana, con monto medio de USD 250 000 (100 000–600 000)
Clientes y datos personales	2 100 clientes de alto patrimonio y 600 familias	—	Datos patrimoniales, fiscales y de beneficiarios; perfiles de riesgo y documentos de identidad
Costo de notificar a un cliente	USD 45	30–70	Llamada o visita del gestor y carta certificada
Costo de reposición de equipos clave	USD 450 000	380 000–520 000	Estaciones de gestores y 30 terminales Bloomberg; la suscripción anual de Aladdin es de USD 1,8 M

Operación por proceso

Proceso	Plataforma de gestión de portafolios y trading
Horario	Días hábiles de 7:00 a 17:00, según los mercados de Estados Unidos y el local
Personal en turno y costo	40 gestores y operadores; costo cargado USD 45 por hora (±15 %)
Procedimiento alterno	Órdenes por teléfono a los corredores, grabadas y confirmadas por escrito, solo para operaciones urgentes
Penalizaciones	Los errores de ejecución y los incumplimientos de los mandatos de inversión corren a cargo de Capitalia
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: operaciones del día por teléfono; rebalanceos detenidos · 24 h: órdenes perdidas en días de volatilidad; errores a cargo de la firma · 72 h: incumplimiento de mandatos; quejas de clientes · 1 semana: clientes trasladan carteras · 1 mes: pérdida de activos bajo gestión que los Socios estiman en 10 %

Proceso	Protección de la información financiera del cliente
Horario	24 horas, todos los días
Personal en turno y costo	6 personas de TI y seguridad; costo cargado USD 25 por hora (±15 %)
Procedimiento alterno	No aplica
Penalizaciones	Contratos de gestión con confidencialidad y responsabilidad por daños; deber de reserva de la actividad bursátil
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin efecto si no hay fuga · 24 h: si hay fuga, clientes expuestos a extorsión y fraude · 72 h: notificación a clientes y al supervisor · 1 semana: salida de clientes y cobertura en medios · 1 mes: pérdida de clientes y de la reputación que sostiene el negocio

Proceso	Sistema de gestión de relaciones con clientes (CRM)
Horario	Lunes a viernes de 7:00 a 19:00
Personal en turno y costo	35 gestores de relación; costo cargado USD 40 por hora (±15 %)
Procedimiento alterno	Consulta de expedientes físicos en archivo
Penalizaciones	Ninguna contractual
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: gestores sin historial de sus clientes · 24 h: reuniones y propuestas atrasadas · 72 h: actualización de perfiles de riesgo detenida · 1 semana: pérdida de oportunidades comerciales · 1 mes: si hubo fuga del CRM, pérdida de clientes

Proceso	Cumplimiento regulatorio y de riesgo
Horario	Oficina de lunes a viernes de 8:00 a 17:00
Personal en turno y costo	12 personas de Cumplimiento y Riesgo; costo cargado USD 30 por hora (±15 %)
Procedimiento alterno	Revisión manual de operaciones y alertas
Penalizaciones	Reportes a la Unidad de Investigación Financiera con plazo fijo; multas del supervisor
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: alertas sin revisar · 24 h: reportes diarios atrasados · 72 h: reportes con plazo vencido · 1 semana: observación del supervisor · 1 mes: sanción y restricción de operaciones

Tecnología

Elemento	Situación actual
Portafolios y mercado	BlackRock Aladdin en modalidad SaaS; 30 terminales Bloomberg
CRM	Microsoft Dynamics 365 Customer Engagement
Portal de clientes	Aplicación en .NET 6 sobre Azure App Service con Azure SQL Database
Correo y oficina	Microsoft 365 E3 con Exchange Online, sin protección avanzada de correo; Microsoft Entra ID; laptops con Windows 11

Elemento	Situación actual
Red	Segmentación por VLAN con cortafuegos Palo Alto PAN-OS 11.1 administrados por un tercero; un proveedor de internet principal y uno de respaldo

Respaldos y continuidad

Sistema	Situación actual
Aladdin y Dynamics 365	A cargo de cada proveedor, según contrato
Archivos	SharePoint Online y OneDrive con la retención propia de Microsoft 365, sin respaldo adicional
Portal de clientes	Respaldo automático de Azure SQL Database con retención de 7 días
Sitio alterno	Acuerdo de oficina temporal en un centro de negocios; nunca se ha usado

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Correo que suplantó a un cliente e instruyó una transferencia, ejecutada sin llamada de verificación	—	USD 180 000 transferidos; se recuperaron 60 000
2024	Correo dirigido a un socio director con una página falsa de inicio de sesión; cuenta comprometida	2 días	Sin pérdida económica; revisión de reglas de reenvío
2025	Robo de la laptop de un gestor, sin cifrado de disco	—	Notificación a 40 clientes
2026	Caída del proveedor de internet principal	5 horas	Operaciones por teléfono

Organización y presupuesto

Dato	Valor
Organigrama	Socios Directores; Gestores de Portafolio; Analistas de Mercado; Cumplimiento y Riesgo, con el oficial de cumplimiento; Operaciones; TI (8 personas); Administración, que incluye RR. HH. Asesoría legal externa; auditoría interna tercerizada. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 700 000 (400 000 de inversión y 300 000 de operación). 2028 y 2029: mismo nivel, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por los Socios Directores para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Ley del Mercado de Valores y normas técnicas del Banco Central de Reserva, supervisadas por la Superintendencia del Sistema Financiero; Ley contra el Lavado de Dinero y de Activos (reportes a la UIF); Ley para la Protección de Datos Personales

Controles que ya existen

Familia	Estado actual
Plataforma de trading	Segundo factor, roles y registro de actividad en Aladdin, por exigencia del proveedor
Estaciones	Gestores con privilegios de administrador; 30 % de las laptops sin cifrado de disco; Microsoft Defender con configuración básica
Correo	Sin análisis en entorno aislado; DMARC solo en modo de monitoreo
Transferencias	Llamada de verificación al cliente solo para montos superiores a USD 500 000
Cortafuegos	Administrados por un tercero, sin revisión periódica de reglas
Cuentas	Segundo factor en Microsoft 365 para todo el personal

4.17 Centro Judicial Digital de El Salvador (CJDES)

Grupo de Implementación asignado: IG3. Expedientes judiciales y cadena de custodia digital del Estado.

Datos básicos de la empresa

- **Sector:** Gobierno / Justicia.
- **Tamaño:** Grande (2,000 empleados a nivel nacional).
- **Ubicación:** Sede central en San Salvador, con juzgados y tribunales en todo el país.
- **Misión:** Administrar justicia de manera pronta, cumplida e imparcial, utilizando la tecnología para garantizar la transparencia y el acceso a los ciudadanos.
- **Visión:** Consolidar un sistema de justicia 100% digital, seguro y eficiente que sea un modelo de modernización para el sector público.
- **Estructura Organizacional Básica:** Presidencia del Órgano Judicial, Salas, Cámaras, Juzgados, Dirección de TI, Administración.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Procesamiento de casos judiciales (penales, civiles, mercantiles, etc.), emisión de sentencias, gestión de archivos.
- **Clientes:** Ciudadanía, abogados, fiscales, y otras entidades del Estado.

Procesos Críticos (4):

  - **1. Sistema de Gestión de Casos Judiciales:** Administración del ciclo de vida completo de un expediente judicial, desde la demanda hasta la sentencia.
  - **2. Plataforma de Presentación Electrónica (E-Filing):** Recepción segura de todos los escritos y pruebas presentados por las partes.
  - **3. Gestión de Evidencia Digital:** Custodia y preservación de la integridad de las pruebas digitales presentadas en juicio.
  - **4. Notificaciones Electrónicas y Publicación de Edictos:** Comunicación segura y fehaciente de las decisiones judiciales a las partes involucradas.

- **Dependencia Tecnológica:** Crítica. La integridad del expediente judicial es un pilar del estado de derecho.

Infraestructura tecnológica inicial

- **Sistemas:** Sistema de gestión de casos desarrollado a medida sobre una base de datos Oracle, sistema de gestión documental Alfresco, infraestructura de firma electrónica.

- **Red y Comunicaciones:** Centro de datos gubernamental on-premise, red WAN que interconecta todos los tribunales del país.
- **Madurez y Controles Actuales:** Nivel muy bajo. Sufren de una enorme deuda técnica con sistemas legacy. El desarrollo de software no ha seguido prácticas seguras, y los sistemas son vulnerables a ataques de inyección SQL y manipulación de datos. No hay un programa de respuesta a incidentes, y la auditoría de acceso a expedientes sensibles es manual e ineficiente.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Presupuesto operativo anual	USD 64 M	58–70 M	Asignación del Órgano Judicial en la Ley de Presupuesto; el CJDES no genera ingresos propios
Ejecución presupuestaria (equivalente al margen)	96 %	92–99 %	Lo no ejecutado regresa al Fondo General
Temporada alta	Semanas siguientes a los períodos de vacación judicial (Semana Santa, agosto y fin de año)	—	Escritos presentados frente a la semana promedio: 1,4 (1,2–1,7)
Volumen de transacciones	26 000 escritos electrónicos por día hábil	22 000–30 000	410 000 expedientes activos; 18 000 notificaciones electrónicas por día
Datos personales	1,9 millones de personas en expedientes	1,7–2,1 millones	Partes, testigos, víctimas y menores; datos de salud y antecedentes en expedientes penales y de familia
Costo de notificar a un titular	USD 1,20	0,80–1,80	Carta certificada; la mitad de las partes no registra correo
Costo de reposición de equipos clave	USD 4,5 M	3,8–5,2 M	Servidores, almacenamiento y licencias del sistema de casos y del gestor documental

Operación por proceso

Proceso	Sistema de gestión de casos judiciales
Horario	Juzgados de lunes a viernes de 8:00 a 16:00; juzgados de turno 24 horas
Personal en turno y costo	1 400 personas de juzgados que dependen del sistema; costo cargado USD 9 por hora (±15 %)
Procedimiento alterno	Libros de registro y actuaciones en papel, con carga posterior; sostenible 3 días hábiles según la Administración
Penalizaciones	Los plazos procesales siguen corriendo; la detención administrativa no puede exceder 72 horas sin ponerse a la orden del juez

Proceso	Sistema de gestión de casos judiciales
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: audiencias suspendidas; juzgados de turno en papel · 24 h: resoluciones sin registrar; riesgo sobre plazos de detenidos · 72 h: nulidades por plazos vencidos; cobertura nacional · 1 semana: suspensión de términos en todo el país · 1 mes: si hubo alteración de expedientes, pérdida de confianza en las resoluciones judiciales

Proceso	Plataforma de presentación electrónica (e-filing)
Horario	24 horas, todos los días
Personal en turno y costo	20 personas de soporte; costo cargado USD 10 por hora (±15 %)
Procedimiento alterno	Recepción física de escritos en ventanilla con sello de fecha y hora
Penalizaciones	Si la caída supera un día hábil, la Presidencia suspende los términos
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: abogados sin presentar escritos; filas en ventanillas · 24 h: escritos con plazo al límite en riesgo · 72 h: suspensión de términos · 1 semana: acumulación de escritos por digitalizar · 1 mes: si hubo manipulación de fechas de presentación, nulidades en serie

Proceso	Gestión de evidencia digital
Horario	Laboratorio de lunes a viernes; custodia 24 horas
Personal en turno y costo	15 peritos y custodios; costo cargado USD 14 por hora (±15 %)
Procedimiento alterno	Custodia física de los soportes en bóveda, con acta
Penalizaciones	La prueba sin cadena de custodia íntegra se excluye del juicio
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin consulta de evidencia para audiencias · 24 h: audiencias reprogramadas · 72 h: plazos de instrucción en riesgo · 1 semana: exclusión de prueba por integridad no demostrable · 1 mes: absoluciones o nulidades por prueba perdida o alterada

Proceso	Notificaciones electrónicas y publicación de edictos
Horario	Envío 24 horas; notificadores de lunes a viernes
Personal en turno y costo	40 notificadores; costo cargado USD 8 por hora (±15 %)
Procedimiento alterno	Notificación personal por notificador y edictos en el Diario Oficial
Penalizaciones	Una notificación inválida anula las actuaciones posteriores
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: notificaciones del día en cola · 24 h: plazos que no empiezan a correr · 72 h: notificaciones personales atrasadas · 1 semana: atraso generalizado de procesos · 1 mes: si hubo notificaciones falsas, nulidades y reclamos

Tecnología

Elemento	Situación actual
Gestión de casos	Desarrollo propio en Java con Oracle Database 12c en Oracle Linux 7

Elemento	Situación actual
Gestor documental	Alfresco Content Services 6.2
Firma electrónica	Autoridad certificadora con Microsoft AD CS en Windows Server 2016 y tokens para jueces y secretarios
Portal de e-filing y consulta	Aplicación en PHP 7.2 con Apache 2.4
Oficina e identidad	Active Directory en Windows Server 2012 R2 y 2016; Exchange Server 2016 en sus instalaciones; estaciones con Windows 10
Red	Centro de datos gubernamental propio; WAN MPLS con 300 sedes judiciales

Respaldos y continuidad

Sistema	Situación actual
Gestión de casos	Respaldo diario de Oracle a cinta; las cintas se guardan en el mismo edificio
Gestor documental	Respaldo semanal completo
Evidencia digital	Copia en un NAS, sin verificación periódica de su huella digital
Sitio alterno y pruebas	No existe sitio alterno; la última restauración de prueba fue en 2022

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Inyección SQL en el portal de consulta de expedientes que expuso datos de partes procesales	Detectada por un periodista	Sin cuantificar; cobertura en medios
2024	Un empleado alteró fechas en un expediente para favorecer a una parte	Detectado cuatro meses después	Proceso disciplinario y penal
2025	Ransomware en estaciones de un centro judicial regional	4 días	USD 35 000 y audiencias reprogramadas
2026	Falla eléctrica en el centro de datos	9 horas	Juzgados en papel; suspensión de términos de un día

Organización y presupuesto

Dato	Valor
Organigrama	Presidencia del Órgano Judicial; Salas; Cámaras; Juzgados; Dirección de TI (90 personas); Administración, que incluye RR. HH.; asesoría jurídica institucional; Auditoría Interna del Órgano Judicial. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 2,2 M (1,5 M de inversión y 0,7 M de operación) en el presupuesto del Órgano Judicial. 2028 y 2029: USD 1,5 M por año, sujeto a la Ley de Presupuesto
Arranque del programa de seguridad	Aprobado por la Presidencia del Órgano Judicial para el lunes 4 de enero de 2027

Dato	Valor
Cumplimiento que el cliente reconoce	Ley de Ciberseguridad y Seguridad de la Información (institución pública supervisada por la Agencia de Ciberseguridad del Estado); Ley para la Protección de Datos Personales; Ley de Acceso a la Información Pública; Ley de Firma Electrónica; normas procesales sobre plazos, notificaciones y prueba; auditoría de la Corte de Cuentas de la República

Controles que ya existen

Familia	Estado actual
Respuesta a incidentes	No existe un plan ni un equipo designado
Acceso a expedientes	Sin registro auditable de consultas y cambios; usuarios genéricos por juzgado en el sistema de casos
Desarrollo	Sin prácticas de desarrollo seguro ni pruebas antes de publicar
Parches	Irregulares; varios sistemas con versiones sin soporte
Antimalware	Antivirus en estaciones y servidores Windows
Seguridad física	Control de acceso y vigilancia en el centro de datos

4.18 GeoExplora El Salvador

Grupo de Implementación asignado: IG3. Datos geológicos propietarios de alto valor económico y tecnología de operación en sitio, con exposición a espionaje industrial.

Datos básicos de la empresa

- **Sector:** Minería y Recursos Naturales.
- **Tamaño:** Mediana (400 empleados).
- **Ubicación:** Oficinas corporativas en San Salvador, operaciones de exploración y explotación en zonas rurales.
- **Misión:** Identificar y desarrollar de manera responsable los recursos minerales del país, generando valor económico y social en armonía con el medio ambiente.
- **Visión:** Ser la empresa minera líder en la región, reconocida por su eficiencia operativa y su compromiso con la sostenibilidad y la seguridad.
- **Estructura Organizacional Básica:** Dirección General, Geología y Exploración, Operaciones de Mina, Sostenibilidad y Medio Ambiente, TI/OT, Finanzas.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Exploración geológica, extracción y procesamiento de minerales (ej. oro, plata).
- **Clientes:** Mercados internacionales de materias primas.

Procesos Críticos (4):

  - **1. Gestión de Datos Geológicos y de Exploración:** Protección de mapas geofísicos y datos de perforación, que son propiedad intelectual de alto valor.
  - **2. Sistemas de Control Industrial (ICS) de la Planta de Procesamiento:** Operación de la maquinaria para moler la roca y separar los minerales.
  - **3. Monitoreo Ambiental y de Seguridad Industrial:** Sistemas que controlan la estabilidad de presas de relaves y la calidad del aire/agua.

  - **4. Logística y Cadena de Custodia del Producto Final:** Asegurar el transporte seguro del mineral procesado desde la mina hasta el punto de exportación.
- **Dependencia Tecnológica:** Crítica. Un ataque a los sistemas OT podría causar un desastre ambiental o un accidente laboral grave.

Infraestructura tecnológica inicial

- **Sistemas:** Software especializado de modelado geológico (Vulcan, Leapfrog), sistemas de control SCADA en la planta, ERP para finanzas.
- **Red y Comunicaciones:** Conectividad satelital en los sitios remotos de la mina. Convergencia de redes TI y OT sin la debida segmentación.
- **Madurez y Controles Actuales:** Nivel nulo. La ciberseguridad no ha sido una prioridad. Los sistemas OT son operados por ingenieros de minas sin conocimiento de seguridad, utilizando contraseñas por defecto. No hay visibilidad del tráfico en la red de la planta, y los datos de exploración se almacenan en estaciones de trabajo sin cifrado ni controles de acceso adecuados.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ventas anuales	USD 190 M	150–230 M	Oro 90 % y plata 10 %; 55 000 onzas de oro equivalente al año (45 000–65 000); el rango sigue el precio internacional del oro
Margen EBITDA	38 %	30–45 %	Sobre ventas
Temporada alta	Época seca (noviembre a abril), cuando la mina opera a plena capacidad	—	En lluvias (mayo a octubre) la producción baja a 0,8 (0,7–0,9) del promedio y sube el riesgo en la presa de relaves
Volumen de operación	2 000 toneladas de roca procesadas por día	1 700–2 300	Un día de planta detenida equivale a unas 150 onzas de oro
Inversión en exploración	USD 30 M acumulados en la base de datos geológica	25–35 M	Perforaciones, geofísica y modelos del yacimiento
Datos personales	Expedientes de 400 empleados y 350 contratistas	—	Registros de 1 100 personas de comunidades vecinas en programas sociales
Costo de notificar a un titular	USD 2,00	1,20–3,00	Carta y visita comunitaria
Costo de reposición de equipos clave	USD 2,5 M	2,0–3,0 M	Sistema de control de la planta: SCADA, PLC y servidores

Operación por proceso

Proceso	Gestión de datos geológicos y de exploración
Horario	Oficinas de lunes a viernes; campo de lunes a sábado

Proceso	Gestión de datos geológicos y de exploración
Personal en turno y costo	30 geólogos y técnicos; costo cargado USD 25 por hora (±15 %)
Procedimiento alterno	Trabajo con copias locales parciales
Penalizaciones	Acuerdo de confidencialidad con el socio estatal; los datos sostienen el valor del proyecto
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: geólogos sin modelos actualizados · 24 h: planificación de perforación detenida · 72 h: plan de minado del mes sin actualizar · 1 semana: extracción en zonas de menor ley · 1 mes: si hubo robo de datos, pérdida de ventaja en nuevas concesiones

Proceso	Sistemas de control industrial de la planta de procesamiento
Horario	24 horas, todos los días
Personal en turno y costo	70 operadores y técnicos por turno; costo cargado USD 7 por hora (±15 %)
Procedimiento alterno	Operación local de equipos con paradas controladas; capacidad al 30 %
Penalizaciones	Contrato con la refinería: 0,5 % del valor por semana de retraso en la entrega
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: producción reducida; riesgo de error en la dosificación de reactivos · 24 h: planta detenida; 150 onzas perdidas · 72 h: entrega a la refinería atrasada · 1 semana: penalidades y revisión del contrato · 1 mes: si hubo manipulación del control, riesgo ambiental y suspensión del permiso

Proceso	Monitoreo ambiental y de seguridad industrial (presa de relaves, aire y agua)
Horario	24 horas, todos los días
Personal en turno y costo	10 técnicos ambientales y de seguridad por turno; costo cargado USD 9 por hora (±15 %)
Procedimiento alterno	Inspección visual de la presa cada 2 horas y muestreo manual de agua; sostenible 7 días en época seca y 48 horas en lluvias
Penalizaciones	El permiso ambiental exige reportar la calidad del agua; un incumplimiento puede suspender la operación
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin alarmas automáticas de la presa · 24 h: reportes ambientales atrasados · 72 h: en lluvias, riesgo de no detectar a tiempo una filtración · 1 semana: suspensión de la operación por la autoridad · 1 mes: si hay falla de la presa, daño ambiental y a comunidades que la Dirección considera irreversible

Proceso	Logística y cadena de custodia del producto final
Horario	Despachos semanales con escolta
Personal en turno y costo	20 personas de seguridad y logística; costo cargado USD 10 por hora (±15 %)
Procedimiento alterno	Custodia física en la bóveda de la mina y despacho diferido
Penalizaciones	La póliza de seguro de tránsito exige rastreo GPS; sin él no hay cobertura

Proceso	Logística y cadena de custodia del producto final
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: despacho en espera · 24 h: producto acumulado en bóveda · 72 h: entrega a la refinería atrasada · 1 semana: exposición a robo por acumulación · 1 mes: si hubo manipulación del rastreo, pérdida del cargamento sin seguro

Tecnología

Elemento	Situación actual
Modelado geológico	Maptek Vulcan 2023 y Seequent Leapfrog Geo en estaciones Windows 10
Planta	AVEVA System Platform 2020 (Wonderware) con PLC Allen-Bradley ControlLogix; estaciones de ingeniería con Windows 10
Monitoreo de la presa	Piezómetros e inclinómetros con enlace de radio al cuarto de control
ERP y oficina	Microsoft Dynamics 365 Business Central; Microsoft 365, sin directorio local
Red	Enlace satelital en la mina; redes de TI y OT convergentes; Wi-Fi en el campamento

Respaldos y continuidad

Sistema	Situación actual
Datos geológicos	En las estaciones de los geólogos; copia parcial y manual en un disco externo
Planta	Sin respaldo de la configuración del SCADA ni de los programas de los PLC
ERP	En la nube del proveedor, con su respaldo
Sitio alterno	No existe

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Robo de una laptop con datos de perforación durante un traslado	—	Sin cuantificar; datos sin cifrar
2024	Caída del enlace satelital por una tormenta	20 horas	Monitoreo de la presa solo local
2025	Malware en la estación de ingeniería del SCADA que entró por una memoria USB	12 horas de planta detenida	Unas 75 onzas de producción perdida
2026	Sensor de un piezómetro fallido sin alarma	3 días hasta detectarlo	Sin daño; observación de la autoridad ambiental

Organización y presupuesto

Dato	Valor
Organigrama	Dirección General; Geología y Exploración; Operaciones de Mina; Sostenibilidad y Medio Ambiente; TI/OT (6 personas); Finanzas, que incluye RR. HH.; Legal y Relaciones Institucionales. Auditoría del socio estatal y auditoría externa anual. No existe una unidad de seguridad de la información

Dato	Valor
Presupuesto aprobado para seguridad	2027: USD 800 000 (550 000 de inversión y 250 000 de operación). 2028 y 2029: USD 500 000 por año, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por la Dirección General para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Ley General de Minería Metálica (diciembre de 2024), bajo la cual opera como sociedad de economía mixta con participación del Estado; regulación de la Dirección General de Energía, Hidrocarburos y Minas; permiso ambiental del Ministerio de Medio Ambiente y Recursos Naturales; Ley para la Protección de Datos Personales

Controles que ya existen

Familia	Estado actual
Planta	Los equipos de control usan contraseñas por defecto; sin visibilidad del tráfico de red
Datos	Datos de exploración en estaciones sin cifrado ni control de acceso
Antimalware	Antivirus solo en las laptops de oficina
Seguridad física	Guardias y control de acceso en planta y bóveda
Transporte	Rastreo GPS de los vehículos de despacho

4.19 Global Media Group (GMG) - División El Salvador

Grupo de Implementación asignado: IG3. Continuidad de la emisión nacional y exposición a adversarios con motivación política: la interrupción y la manipulación del contenido alcanzan a terceros.

Datos básicos de la empresa

- **Sector:** Medios y Entretenimiento.
- **Tamaño:** Grande (750 empleados).
- **Ubicación:** Edificio de noticias y estudios de producción en San Salvador.
- **Misión:** Informar y entretener a la audiencia salvadoreña con contenido veraz, relevante y de alta calidad a través de nuestras plataformas de televisión, radio y digitales.
- **Visión:** Ser el grupo de medios líder y más confiable del país, adaptándonos a la era digital sin comprometer la integridad periodística.
- **Estructura Organizacional Básica:** Dirección General, Dirección de Noticias, Dirección de Producción, Dirección Digital, Ventas, TI y Broadcast Engineering.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Transmisión de noticieros, programas de entretenimiento, radio y una plataforma de streaming de contenido digital.
- **Clientes:** Audiencia masiva y anunciantes.

Procesos Críticos (4):

  - **1. Sistema de Gestión de Contenidos y Redacción (CMS/NCS):** Creación, aprobación y programación de todo el contenido periodístico. La integridad de las noticias es fundamental.

  - **2. Operación de la Sala de Control Maestra (MCR):** Garantizar la transmisión continua (24/7) de las señales de televisión y radio.
  - **3. Plataforma de Transmisión Digital (OTT/Streaming):** Disponibilidad y seguridad de la plataforma de streaming y la protección de los datos de suscriptores.
  - **4. Protección de Fuentes y Material de Investigación:** Salvaguarda de la información confidencial obtenida por los periodistas de investigación.
- **Dependencia Tecnológica:** Crítica. Un ciberataque podría sacar del aire al medio, manipular noticias o exponer fuentes confidenciales.

Infraestructura tecnológica inicial

- **Sistemas:** Sistemas de redacción Avid iNews, servidores de video Omneon, sistemas de automatización de transmisión. Infraestructura de TI tradicional para el corporativo y una plataforma en la nube (AWS) para el streaming.
- **Red y Comunicaciones:** Red de broadcast especializada y red de TI corporativa, las cuales están interconectadas de manera insegura.
- **Madurez y Controles Actuales:** Nivel muy bajo. La seguridad se ha enfocado en la disponibilidad de la transmisión, ignorando la ciberseguridad. Son vulnerables a ataques de ransomware dirigidos a los servidores de video y a ataques de desinformación si su CMS es comprometido. No hay monitoreo de seguridad en la red de broadcast.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales	USD 85 M	75–95 M	Publicidad en TV 60 %, radio 15 %, digital 15 %, suscripciones a la plataforma de streaming 10 %
Margen EBITDA	15 %	11–19 %	Sobre ingresos
Temporada alta	Noviembre y diciembre, grandes eventos deportivos y noches electorales	—	Ingresos de pauta frente al mes promedio: 1,6 (1,3–1,9)
Pauta en horario estelar	Spot de 30 segundos a USD 1 200	900–1 600	16 spots por hora de 19:00 a 22:00; 1 900 spots de TV por día en total
Suscriptores y datos personales	140 000 suscriptores de streaming	120 000–160 000	Tarifa USD 5,99 al mes; 600 000 usuarios registrados sin pago
Pagos con tarjeta	1,7 millones de cargos de suscripción al año	1,4–1,9 millones	Procesador de pagos externo; comercio de nivel 2 de PCI DSS
Costo de notificar a un titular	USD 0,05	0,03–0,10	Correo y notificación en la app
Costo de reposición de equipos clave	USD 3,2 M	2,7–3,8 M	Servidores de video y sistema de automatización de la sala de control maestra

Operación por proceso

Proceso	Sistema de gestión de contenidos y redacción (CMS/NCS)
Horario	24 horas; noticieros a las 6:00, 12:00 y 19:00
Personal en turno y costo	120 periodistas y editores; costo cargado USD 10 por hora (±15 %)
Procedimiento alterno	Guiones en documentos locales y teleprompter manual; sin publicación web
Penalizaciones	Ninguna contractual
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: noticiero armado a mano; sitio web sin actualizar · 24 h: pérdida de audiencia digital del día · 72 h: si hubo alteración de contenido, noticias falsas publicadas con la marca · 1 semana: rectificaciones públicas y pérdida de credibilidad · 1 mes: anunciantes retiran pauta; daño a la marca que la Dirección considera grave

Proceso	Operación de la sala de control maestra (MCR)
Horario	24 horas, todos los días
Personal en turno y costo	8 operadores de continuidad por turno; costo cargado USD 9 por hora (±15 %)
Procedimiento alterno	Emisión desde el servidor de respaldo con una lista fija de 6 horas; en vivo por conmutación manual
Penalizaciones	Spot no emitido: reposición o reembolso más bonificación del 20 %; la concesión de frecuencias exige continuidad
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: pantalla con programación fija; spots de horario estelar sin emitir · 24 h: reembolsos a anunciantes; cobertura en otros medios · 72 h: pérdida de audiencia hacia la competencia · 1 semana: anunciantes trasladan campañas · 1 mes: revisión de la concesión si la señal se interrumpe

Proceso	Plataforma de transmisión digital (OTT/streaming) y datos de suscriptores
Horario	24 horas, todos los días
Personal en turno y costo	10 personas de la plataforma digital; costo cargado USD 14 por hora (±15 %)
Procedimiento alterno	Transmisión en vivo por redes sociales, sin cobro
Penalizaciones	Los contratos de derechos deportivos exigen protección anticopia; los suscriptores reclaman reembolso
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: evento en vivo perdido para suscriptores; reclamos · 24 h: reembolsos y cancelaciones · 72 h: titulares de derechos exigen explicación · 1 semana: pérdida de suscriptores · 1 mes: si hubo fuga de datos, notificación a suscriptores y bajas masivas

Proceso	Protección de fuentes y material de investigación
Horario	Unidad de investigación de lunes a sábado
Personal en turno y costo	12 periodistas de investigación; costo cargado USD 14 por hora (±15 %)
Procedimiento alterno	Trabajo fuera de línea con equipos aislados

Proceso	Protección de fuentes y material de investigación
Penalizaciones	Deber de reserva de la fuente; una fuga expone a personas a represalias
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin efecto · 24 h: investigaciones atrasadas · 72 h: si hubo acceso no autorizado, fuentes expuestas · 1 semana: fuentes dejan de colaborar · 1 mes: pérdida del periodismo de investigación que distingue a la marca

Tecnología

Elemento	Situación actual
Redacción	Avid iNews 5 en Windows Server 2012 R2
Emisión	Servidores de video Harmonic Spectrum (Omneon); automatización de emisión en Windows 10 Enterprise LTSC 2019
Streaming	AWS Elemental MediaLive y Amazon CloudFront; base de suscriptores en Amazon RDS for MySQL 8.0; app propia
Oficina e identidad	Active Directory en Windows Server 2016; Microsoft 365; estaciones con Windows 10 y macOS 13 en edición
Red	Red de broadcast y red corporativa interconectadas sin cortafuegos interno

Respaldos y continuidad

Sistema	Situación actual
Redacción	Respaldo nocturno del NCS a disco en el mismo edificio
Archivo de video	Cintas LTO guardadas en el mismo edificio
Emisión	Servidor de respaldo en el mismo cuarto de la MCR; la planta transmisora del cerro puede emitir una lista fija
Streaming	Instantáneas diarias de Amazon RDS con retención de 7 días

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Toma de la cuenta de redes sociales del noticiero con publicación falsa	3 horas	Rectificación pública
2024	Phishing a un editor que dio acceso al NCS	2 días	Sin publicación alterada; cambio de contraseñas
2025	Ransomware en el archivo de video	5 días	USD 70 000 en recuperación y material perdido
2026	Falla de la automatización de emisión	2 horas	USD 25 000 en reembolsos a anunciantes

Organización y presupuesto

Dato	Valor
Organigrama	Dirección General; Direcciones de Noticias, Producción, Digital y Ventas; TI y Broadcast Engineering (35 personas); Finanzas y Administración, que incluye RR. HH.; Legal, con dos abogados de asuntos regulatorios y de contenido; auditoría interna del grupo regional. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 750 000 (450 000 de inversión y 300 000 de operación). 2028 y 2029: USD 600 000 por año, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por la Dirección General para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Ley de Telecomunicaciones y concesión de frecuencias ante la SIGET; Ley para la Protección de Datos Personales (suscriptores); PCI DSS por medio del procesador de pagos; contratos de derechos de contenido con protección anticopia; Ley de Propiedad Intelectual

Controles que ya existen

Familia	Estado actual
Enfoque	La seguridad se limita a la disponibilidad de la transmisión
Monitoreo	Sin monitoreo de seguridad en la red de broadcast ni en la corporativa
Antimalware	Antivirus en estaciones corporativas; nada en servidores de video ni en la automatización
Cuentas	Cuentas compartidas en la MCR; segundo factor solo en 2 de 9 cuentas de redes sociales
Nube	Cuenta raíz de AWS con segundo factor; sin revisión de permisos

4.20 Constructora Horizonte

Grupo de Implementación asignado: IG3. Información contractual y de obra, pagos de alto monto y suplantación dirigida en la cadena de proveedores, con efectos sobre terceros.

Datos básicos de la empresa

- **Sector:** Construcción e Ingeniería Civil.
- **Tamaño:** Grande (900 empleados, incluyendo personal de proyecto).
- **Ubicación:** Oficinas centrales en San Salvador, con múltiples proyectos de gran escala a nivel nacional.
- **Misión:** Construir la infraestructura que impulsa el progreso de El Salvador, ejecutando proyectos complejos con seguridad, calidad y en tiempo.
- **Visión:** Ser la constructora líder en innovación, adoptando tecnologías como BIM y la gestión de proyectos digital para transformar la industria.
- **Estructura Organizacional Básica:** Presidencia, Dirección de Proyectos, Dirección de Ingeniería, Compras y Logística, Maquinaria, Finanzas, TI.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Construcción de proyectos de infraestructura pública (carreteras, puentes) y desarrollos inmobiliarios privados (complejos de apartamentos, centros comerciales).
- **Clientes:** Gobierno, desarrolladores inmobiliarios.

Procesos Críticos (4):

  - **1. Plataforma de Modelado de Información de Construcción (BIM):** Gestión de los modelos 3D y los planos que contienen toda la propiedad intelectual del diseño de los proyectos.
  - **2. Sistema de Planificación de Recursos Empresariales (ERP):** Control de costos del proyecto, gestión de compras, nómina y la cadena de suministro.
  - **3. Plataforma de Gestión de Proyectos:** Colaboración y comunicación entre la oficina central y los equipos en los sitios de construcción.
  - **4. Operación de Maquinaria Pesada Conectada:** Gestión de la telemática de la flota de maquinaria para mantenimiento y eficiencia (IoT).
- **Dependencia Tecnológica:** Crítica. La pérdida o alteración de los planos (BIM) podría causar errores catastróficos en la construcción. Un fallo en el ERP podría paralizar financieramente los proyectos.

Infraestructura tecnológica inicial

- **Sistemas:** Autodesk BIM 360, SAP S/4HANA, Microsoft Project Server, plataformas telemáticas de Caterpillar/Komatsu.
- **Red y Comunicaciones:** Conectividad a internet deficiente en los sitios de construcción, a menudo a través de módems 4G inseguros.
- **Madurez y Controles Actuales:** Nivel nulo. Los datos de los proyectos (planos, costos) se comparten a través de métodos inseguros. Los ingenieros y arquitectos acceden a los sistemas desde redes no confiables. No hay un programa de seguridad para los dispositivos IoT de la maquinaria, haciéndolos vulnerables.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales	USD 230 M	200–260 M	Obra pública 55 %, desarrollos privados 45 %; 14 proyectos activos
Margen	Margen bruto 12 %; margen neto 4 %	Neto 2–6 %	Sobre ingresos
Temporada alta	Época seca, de noviembre a abril	—	Avance de obra frente al mes promedio: 1,4 (1,2–1,6)
Volumen de transacciones	3 200 órdenes de compra al mes	2 800–3 600	Planilla quincenal de 900 empleados más 1 400 trabajadores de subcontratistas
Datos personales	900 empleados y 1 600 compradores de vivienda	—	Datos de crédito y de identidad de los compradores; expedientes laborales
Costo de notificar a un titular	USD 1,00	0,60–1,50	Carta y correo
Costo de reposición de equipos clave	USD 350 000 por excavadora	300 000–420 000	Flota de 180 máquinas pesadas; servidores del ERP USD 600 000
Atraso en obra pública	Multa diaria fijada en cada contrato	—	El contrato vigente de mayor monto, una carretera de USD 48 M, fija 0,1 % del monto por día de atraso

Operación por proceso

Proceso	Plataforma de modelado de información de construcción (BIM)
Horario	Oficina de lunes a viernes; sitios de lunes a sábado
Personal en turno y costo	60 ingenieros y arquitectos; costo cargado USD 18 por hora (±15 %)
Procedimiento alterno	Planos en PDF descargados en cada sitio
Penalizaciones	Confidencialidad de los diseños de clientes privados
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sitios con la última versión descargada · 24 h: cambios de diseño sin distribuir · 72 h: riesgo de construir con planos desactualizados · 1 semana: retrabajo en obra · 1 mes: si hubo robo de diseños, reclamo de clientes y pérdida de licitaciones

Proceso	Sistema de planificación de recursos empresariales (ERP)
Horario	Oficina de lunes a viernes; planilla quincenal
Personal en turno y costo	70 personas de finanzas, compras y RR. HH.; costo cargado USD 9 por hora (±15 %)
Procedimiento alterno	Órdenes de compra manuales para lo urgente; planilla en hojas de cálculo con el último período
Penalizaciones	Pago tardío de la planilla: sanciones laborales; los proveedores suspenden entregas a los 30 días de atraso
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: compras detenidas · 24 h: materiales sin pedir; costos sin registrar · 72 h: riesgo de pagar la planilla tarde · 1 semana: proveedores suspenden entregas · 1 mes: control de costos perdido y estimaciones de obra sin respaldo

Proceso	Plataforma de gestión de proyectos
Horario	Lunes a sábado de 6:00 a 18:00
Personal en turno y costo	85 residentes y supervisores; costo cargado USD 14 por hora (±15 %)
Procedimiento alterno	Informes diarios por mensajería y hojas de cálculo
Penalizaciones	Informes de avance a la supervisión de obra pública con plazo; sin ellos se atrasa el cobro de estimaciones
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: coordinación por teléfono · 24 h: informes diarios incompletos · 72 h: estimaciones de pago atrasadas · 1 semana: flujo de caja afectado · 1 mes: atrasos y multas en obra pública

Proceso	Operación de maquinaria pesada conectada (telemática)
Horario	Obra de lunes a sábado de 6:00 a 18:00
Personal en turno y costo	180 operadores; costo cargado USD 5 por hora (±15 %)
Procedimiento alterno	Mantenimiento por lectura manual del horómetro
Penalizaciones	El contrato de mantenimiento del fabricante exige los datos telemáticos para la garantía

Proceso	Operación de maquinaria pesada conectada (telemática)
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin ubicación de la flota · 24 h: consumo de combustible sin control · 72 h: mantenimientos vencidos · 1 semana: riesgo de robo de maquinaria sin rastreo · 1 mes: pérdida de la garantía y averías mayores

Tecnología

Elemento	Situación actual
BIM	Autodesk Construction Cloud (BIM 360) y Revit 2024 en estaciones Windows 11
ERP	SAP S/4HANA 2020 en servidores propios con SUSE Linux Enterprise Server 15
Proyectos	Microsoft Project Server 2016 en Windows Server 2016
Maquinaria	Cat Product Link y Komatsu KOMTRAX, con portales web del fabricante
Oficina e identidad	Active Directory en Windows Server 2016; Microsoft 365; laptops con Windows 10 y Windows 11
Red	Oficina central con un proveedor de internet; sitios de obra con módems 4G que conservan su configuración de fábrica

Respaldos y continuidad

Sistema	Situación actual
ERP	Respaldo nocturno a disco en el mismo servidor
Proyectos y archivos	Respaldo semanal de Project Server y del servidor de archivos a un NAS en la oficina central
BIM	En la nube de Autodesk; los modelos también circulan por correo y memorias USB
Sitio alterno	No existe

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Correo de un proveedor suplantado que cambió la cuenta bancaria de pago	—	USD 210 000 transferidos a un tercero
2024	Robo de la laptop de un ingeniero con planos de un centro comercial	—	Reclamo del cliente privado
2025	Ransomware en el servidor de archivos de proyectos	6 días	USD 80 000 y dos semanas de atraso en una estimación
2026	Acceso no autorizado al portal telemático de una excavadora; se modificó su geocerca	Detectado en 1 día	Sin robo; cambio de contraseñas

Organización y presupuesto

Dato	Valor
Organigrama	Presidencia; Direcciones de Proyectos, Ingeniería, Compras y Logística, y Maquinaria; Finanzas, que incluye RR. HH. y planillas; TI (10 personas); Gerencia Legal; auditoría interna de una persona que reporta a la Presidencia. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 650 000 (400 000 de inversión y 250 000 de operación). 2028 y 2029: USD 450 000 por año, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por la Presidencia para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Ley de Compras Públicas (2023) en los contratos con el Estado; Ley para la Protección de Datos Personales (empleados y compradores); Ley contra el Lavado de Dinero y de Activos en la venta de inmuebles; Código de Trabajo en la planilla

Controles que ya existen

Familia	Estado actual
Intercambio de datos	Planos y costos compartidos por correo personal y memorias USB
Acceso remoto	Ingenieros y arquitectos entran a los sistemas desde redes no confiables, sin VPN
Sitios de obra	Módems 4G con contraseña de fábrica
Maquinaria conectada	Sin programa de seguridad para la telemática; cuentas compartidas en los portales
Cuentas	Sin segundo factor en ningún sistema
Antimalware	Antivirus en las computadoras de la oficina central

4.21 Central Azucarera El Gigante (CENAZU)

Grupo de Implementación asignado: IG3. Tecnología de operación del ingenio y picos estacionales: la indisponibilidad afecta a productores y a la cadena agroindustrial ajenos a la empresa.

Datos básicos de la empresa

- **Sector:** Agroindustria (Producción de Azúcar).
- **Tamaño:** Grande (1,800 empleados, con picos estacionales).
- **Ubicación:** Ingenio y plantaciones en la región costera de El Salvador. Oficinas administrativas en San Salvador.
- **Misión:** Producir azúcar y derivados de alta calidad de manera sostenible, generando desarrollo para nuestros colaboradores y las comunidades locales.
- **Visión:** Ser el ingenio azucarero más eficiente y tecnológicamente avanzado de Centroamérica.
- **Estructura Organizacional Básica:** Gerencia General, Gerencia Agrícola, Gerencia de Fábrica, Gerencia de Calidad, Logística, Finanzas, TI/OT.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Producción de azúcar cruda y refinada, melaza y generación de energía a partir de bagazo.
- **Clientes:** Distribuidoras de alimentos, empresas de bebidas, mercados de exportación.

Procesos Críticos (3):

  - **1. Sistema de Control de Procesos del Ingenio (ICS/OT):** Operación 24/7 de los molinos, calderas, evaporadores y centrífugas durante la zafra (temporada de cosecha).
  - **2. Sistema de Gestión de Laboratorio y Calidad (LIMS):** Aseguramiento de la calidad del producto en cada etapa del proceso.
  - **3. Logística de Cosecha y Transporte:** Coordinación de miles de camiones para transportar la caña de azúcar desde el campo hasta el ingenio.
- **Dependencia Tecnológica:** Crítica. Un ciberataque al sistema de control industrial durante la zafra podría detener toda la producción, resultando en pérdidas millonarias.

Infraestructura tecnológica inicial

- **Sistemas:** Sistemas de control distribuido (DCS) de Rockwell y Siemens, historiadores de datos de planta (OSIsoft PI), ERP para finanzas.
- **Red y Comunicaciones:** Red OT antigua y plana que opera los procesos de fábrica. Conexiones inseguras entre la red OT y la red de TI corporativa.
- **Madurez y Controles Actuales:** Nivel muy bajo. La ciberseguridad en el entorno OT es inexistente. Los sistemas de control son antiguos, sin parches y accesibles con credenciales genéricas. Los ingenieros de planta a menudo conectan laptops personales a la red OT, introduciendo un riesgo significativo de malware.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ventas anuales	USD 150 M	130–170 M	Azúcar 80 % (precio medio USD 600 por tonelada, 520–680), melaza 8 %, energía eléctrica de bagazo 12 %
Margen EBITDA	17 %	13–21 %	Sobre ventas
Temporada alta	Zafra de noviembre a abril: unos 150 días de molienda continua	—	Toda la producción de azúcar ocurre en la zafra; fuera de ella solo hay mantenimiento y venta de inventario
Volumen de operación	13 000 toneladas de caña molidas por día	11 500–14 500	Rendimiento de 100 kg de azúcar por tonelada de caña (95–110); 30 MW exportados a la red durante la zafra
Caña cortada	Pierde 5 % de su valor si pasa 24 horas sin moler	3–8 %	La caña de un día equivale a unos USD 780 000 de azúcar
Datos personales	1 800 trabajadores de planilla de zafra y 1 100 productores de caña	—	Cuentas bancarias de productores y datos de planilla
Costo de notificar a un titular	USD 1,50	1,00–2,20	Carta y llamada

Dato	Valor probable	Rango	Detalle
Costo de reposición de equipos clave	USD 3,8 M	3,2–4,5 M	Controladores del DCS y servidores de fábrica; una caldera dañada por una falla de control costaría USD 6 M

Operación por proceso

Proceso	Sistema de control de procesos del ingenio (ICS/OT)
Horario	24 horas, todos los días durante la zafra
Personal en turno y costo	160 operadores y técnicos por turno; costo cargado USD 6 por hora (±15 %)
Procedimiento alterno	Operación manual local de molinos y calderas; capacidad al 40 %, sostenible 12 horas según la Gerencia de Fábrica
Penalizaciones	Contrato de venta de 30 MW con una distribuidora: penalidad por energía comprometida no entregada; los productores cobran la caña cortada que no se recibe
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: molienda reducida; caña acumulada en patio · 24 h: caña cortada pierde sacarosa; riesgo en calderas por control manual · 72 h: productores detienen el corte; reclamos formales · 1 semana: zafra atrasada y energía no entregada · 1 mes: pérdida de una parte de la zafra que la Gerencia General estima en 20 %

Proceso	Sistema de gestión de laboratorio y calidad (LIMS)
Horario	24 horas durante la zafra
Personal en turno y costo	25 analistas por turno; costo cargado USD 7 por hora (±15 %)
Procedimiento alterno	Análisis anotados en cuadernos y liberación manual de lotes
Penalizaciones	Clientes de bebidas rechazan lotes sin certificado de análisis; el pago a productores depende del análisis de sacarosa
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: resultados en papel · 24 h: lotes sin certificado; despachos detenidos · 72 h: pago a productores atrasado · 1 semana: reclamos ante el regulador del sector · 1 mes: pérdida de clientes industriales

Proceso	Logística de cosecha y transporte
Horario	24 horas durante la zafra
Personal en turno y costo	90 despachadores y operadores de báscula por turno; costo cargado USD 5 por hora (±15 %); 900 camiones contratados
Procedimiento alterno	Despacho por radio y boletas de báscula en papel
Penalizaciones	Transportistas cobran USD 20 por hora por camión que espera más de 3 horas
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: colas de camiones en la báscula · 24 h: caña envejecida y cobros de espera · 72 h: frentes de corte detenidos · 1 semana: pago de caña con boletas en disputa · 1 mes: productores trasladan su caña a otros ingenios

Tecnología

Elemento	Situación actual
Control de procesos	DCS Rockwell PlantPAx 4.1 y Siemens SIMATIC PCS 7 8.2; estaciones de operación con Windows 7
Historiador	AVEVA PI Server 2018 (OSIsoft) en Windows Server 2012 R2, con conexión a la red de TI
Laboratorio	LabVantage 8 en Windows Server 2016
ERP y básculas	Microsoft Dynamics AX 2012 R3; aplicación de básculas propia en Access con SQL Server 2014
Oficina e identidad	Active Directory en Windows Server 2016; Microsoft 365; estaciones con Windows 10
Red	Red OT antigua y plana en la fábrica; conexiones con la red de TI por el historiador y por acceso remoto de integradores

Respaldos y continuidad

Sistema	Situación actual
Control de procesos	El integrador respalda la configuración del DCS al inicio de cada zafra
Historiador	Respaldo mensual a disco
ERP y básculas	Respaldo nocturno a disco en el mismo servidor
Sitio alterno	No existe

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Malware en la red OT desde la laptop personal de un ingeniero de planta	2 días de molienda parcial	USD 180 000
2024	Falla del disco del historiador; se perdieron dos semanas de datos de proceso	—	Sin evidencia para una reclamación de garantía
2025	Alteración de boletas de báscula por un empleado	Una zafra	USD 60 000
2026	Caída de la red OT por un conmutador saturado	5 horas	Molienda reducida; caña envejecida

Organización y presupuesto

Dato	Valor
Organigrama	Junta Directiva; Gerencia General; Gerencias Agrícola, de Fábrica y de Calidad; Logística; Finanzas, que incluye RR. HH.; TI/OT (12 personas); asesoría legal externa; auditoría interna de dos personas que reporta a la Junta Directiva. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 900 000 (650 000 de inversión y 250 000 de operación), a ejecutar antes de la zafra 2027-2028. 2028 y 2029: USD 500 000 por año, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por la Gerencia General para el lunes 4 de enero de 2027

Dato	Valor
Cumplimiento que el cliente reconoce	Ley de la Producción, Industrialización y Comercialización de la Agroindustria Azucarera y regulación del CONSAA (pago de la caña por calidad); normas de inocuidad del azúcar de consumo; contrato de venta de energía en el mercado que administra la Unidad de Transacciones; Ley para la Protección de Datos Personales

Controles que ya existen

Familia	Estado actual
Planta	Sistemas de control antiguos, sin parches, con credenciales genéricas
Medios y equipos externos	Los ingenieros conectan laptops personales a la red OT
Segmentación	Conexiones sin filtro entre la red OT y la red de TI
Antimalware	Antivirus en las estaciones de oficina; nada en el entorno OT
Acceso remoto	Los integradores entran por software de escritorio remoto sin segundo factor

4.22 Express Logistics International (ELI)

Grupo de Implementación asignado: IG3. Trazabilidad de carga internacional y datos de clientes corporativos, con operación distribuida y fraude dirigido en la cadena logística.

Datos básicos de la empresa

- **Sector:** Logística y Transporte de Carga.
- **Tamaño:** Grande (850 empleados).
- **Ubicación:** Centro de distribución principal cerca del aeropuerto, oficinas aduaneras y bodegas en puntos estratégicos.
- **Misión:** Ofrecer soluciones logísticas integrales y confiables para el comercio internacional, manejando la carga de nuestros clientes con la máxima seguridad y eficiencia.
- **Visión:** Ser el operador logístico 3PL/4PL líder en la región, impulsado por la visibilidad y la automatización de la cadena de suministro.
- **Estructura Organizacional Básica:** Dirección General, Gerencia de Carga Aérea, Gerencia de Carga Marítima, Gerencia de Aduanas, Almacenamiento, TI.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Agenciamiento de carga internacional, trámites aduanales, almacenamiento y distribución.
- **Clientes:** Importadores y exportadores de diversos sectores (retail, manufactura, farmacéutica).

Procesos Críticos (4):

  - **1. Sistema de Gestión de Transporte (TMS):** Planificación y seguimiento de todos los embarques.
  - **2. Sistema de Gestión de Almacenes (WMS):** Control de inventario de los clientes en las bodegas.
  - **3. Plataforma de Gestión Aduanal:** Creación y transmisión de declaraciones de importación/exportación a la autoridad aduanera.
  - **4. Plataforma de Visibilidad para Clientes:** Portal web que permite a los clientes rastrear su carga en tiempo real.

- **Dependencia Tecnológica:** Crítica. La integridad de los datos de los manifiestos de carga es vital. Un error o manipulación puede resultar en multas, retrasos o pérdida de mercancía.

Infraestructura tecnológica inicial

- **Sistemas:** TMS y WMS de Manhattan Associates, sistema aduanal de desarrollo propio, portal de clientes en Azure.
- **Red y Comunicaciones:** Extensa integración con sistemas de aerolíneas, navieras y la Dirección General de Aduanas.
- **Madurez y Controles Actuales:** Nivel bajo. El desarrollo del sistema aduanal se hizo sin considerar la seguridad, haciéndolo vulnerable a inyección de datos. La autenticación en el portal de clientes es débil, y los datos de rastreo podrían ser interceptados o manipulados. No tienen un plan de respuesta a incidentes.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales	USD 95 M	85–105 M	Carga aérea 40 %, carga marítima 35 %, almacenaje y distribución 15 %, trámites aduanales 10 %
Margen operativo	7 %	5–9 %	Sobre ingresos
Temporada alta	Septiembre a noviembre, importaciones para fin de año	—	Embarques frente al mes promedio: 1,5 (1,3–1,7)
Volumen de transacciones	650 declaraciones aduaneras por día	550–750	2 400 embarques activos; USD 180 M de inventario de clientes en bodegas (150–210 M)
Datos personales	60 000 destinatarios de paquetería con dirección y teléfono	50 000–70 000	4 800 clientes empresariales con datos fiscales y de contacto
Costo de notificar a un titular	USD 0,30	0,20–0,45	Correo y SMS
Costo de reposición de equipos clave	USD 900 000	750 000–1 100 000	Servidores del sistema aduanal, del TMS y del WMS
Contenedor retenido en puerto	USD 150 por día por contenedor	100–220	Almacenaje y demora que cobran el puerto y la naviera

Operación por proceso

Proceso	Sistema de gestión de transporte (TMS)
Horario	24 horas, todos los días
Personal en turno y costo	110 coordinadores de carga por turno; costo cargado USD 8 por hora (±15 %)
Procedimiento alterno	Seguimiento por correo y hojas de cálculo con navieras y aerolíneas
Penalizaciones	Almacenaje y demora de contenedores en puerto: USD 150 por día por contenedor

Proceso	Sistema de gestión de transporte (TMS)
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: embarques sin seguimiento; clientes llaman · 24 h: reservas de espacio perdidas · 72 h: contenedores retenidos en puerto con cargos · 1 semana: clientes trasladan cuentas · 1 mes: pérdida de clientes grandes

Proceso	Sistema de gestión de almacenes (WMS)
Horario	Bodegas de lunes a sábado de 6:00 a 22:00
Personal en turno y costo	260 bodegueros por turno; costo cargado USD 4,50 por hora (±15 %)
Procedimiento alterno	Preparación de pedidos con listas impresas y conteo manual; capacidad al 40 %
Penalizaciones	SLA con clientes farmacéuticos: despacho en 24 horas; crédito del 5 % de la factura mensual si se incumple
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: despachos atrasados · 24 h: incumplimiento del SLA farmacéutico · 72 h: inventario sin control; riesgo de robo · 1 semana: diferencias de inventario reclamadas · 1 mes: pérdida de clientes farmacéuticos

Proceso	Plataforma de gestión aduanal
Horario	Lunes a sábado de 7:00 a 20:00; aduana aérea 24 horas
Personal en turno y costo	45 tramitadores; costo cargado USD 9 por hora (±15 %)
Procedimiento alterno	Digitación directa en el sistema de la Dirección General de Aduanas; capacidad al 30 %
Penalizaciones	Multas aduaneras por declaraciones tardías o erróneas; una manipulación de declaraciones pone en riesgo la licencia de agente aduanero y la certificación de Operador Económico Autorizado
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: declaraciones en cola · 24 h: carga retenida en aduana · 72 h: cargos de almacenaje y multas · 1 semana: reclamos de clientes · 1 mes: si hubo manipulación de datos, suspensión de la licencia

Proceso	Plataforma de visibilidad para clientes (portal de rastreo)
Horario	24 horas, todos los días
Personal en turno y costo	8 personas de soporte digital; costo cargado USD 10 por hora (±15 %)
Procedimiento alterno	Estado de la carga por correo a solicitud
Penalizaciones	Ninguna contractual; los clientes grandes exigen el portal en su contrato
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: consultas por teléfono y correo · 24 h: centro de atención saturado · 72 h: quejas de clientes grandes · 1 semana: renegociación de contratos · 1 mes: si se filtró el rastreo, robo de carga de alto valor

Tecnología

Elemento	Situación actual
Transporte y almacenes	Manhattan TMS y WMS en sus instalaciones, sobre Windows Server 2019 con Microsoft SQL Server 2019
Sistema aduanal	Desarrollo propio en PHP 7.4 con MySQL 5.7
Portal de clientes	Azure App Service con .NET 6 y Azure SQL Database; usuario y contraseña propios
Integraciones	EDI con aerolíneas y navieras por SFTP; transmisión a la aduana por internet
Oficina e identidad	Active Directory en Windows Server 2016; Microsoft 365; estaciones con Windows 10 y Windows 11
Red	Centro de distribución y dos bodegas unidas por MPLS

Respaldos y continuidad

Sistema	Situación actual
TMS y WMS	Respaldo nocturno a disco y copia semanal a cinta guardada en el centro de distribución
Sistema aduanal	Respaldo diario en el mismo servidor
Portal	Respaldo automático de Azure SQL Database con retención de 7 días
Sitio alterno	No existe

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Robo de un contenedor de electrónicos tras consultas de rastreo con credenciales de un cliente reutilizadas	—	USD 240 000 cubiertos en parte por el seguro
2024	Errores del sistema aduanal ante entradas manipuladas en un formulario; se detectó al revisar bitácoras	Semanas	Sin declaraciones alteradas confirmadas
2025	Ransomware en estaciones de tramitadores	3 días	USD 50 000 en multas y almacenaje
2026	Caída del enlace de internet con la aduana	7 horas	Carga retenida un día

Organización y presupuesto

Dato	Valor
Organigrama	Dirección General; Gerencias de Carga Aérea, Carga Marítima, Aduanas y Almacenamiento; TI (22 personas); Finanzas, que incluye RR. HH.; Legal y Cumplimiento Aduanero; auditoría interna de una persona. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 700 000 (450 000 de inversión y 250 000 de operación). 2028 y 2029: USD 500 000 por año, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por la Dirección General para el lunes 4 de enero de 2027

Dato	Valor
Cumplimiento que el cliente reconoce	Código Aduanero Uniforme Centroamericano y su reglamento; normativa de la Dirección General de Aduanas; certificación de Operador Económico Autorizado; Ley para la Protección de Datos Personales; buenas prácticas de almacenamiento exigidas por clientes farmacéuticos

Controles que ya existen

Familia	Estado actual
Desarrollo	El sistema aduanal se construyó sin validación de entradas ni revisión de seguridad
Portal	Autenticación solo con usuario y contraseña; sin bloqueo por intentos fallidos
Respuesta a incidentes	No existe un plan
Antimalware	Antivirus en estaciones y servidores Windows
Seguridad física	Videovigilancia y guardias en bodegas, exigidos por la certificación aduanera

4.23 Raíces Bienes Raíces

Grupo de Implementación asignado: IG3. Datos personales y financieros de compradores y transferencias de alto monto, blanco habitual de fraude por suplantación en el cierre de operaciones.

Datos básicos de la empresa

- **Sector:** Inmobiliario y Desarrollo.
- **Tamaño:** Mediana (300 empleados).
- **Ubicación:** Oficinas corporativas en San Salvador y salas de ventas en sus proyectos.
- **Misión:** Crear comunidades y espacios de vida excepcionales que mejoren la calidad de vida de nuestros clientes y generen valor a largo plazo.
- **Visión:** Ser la desarrolladora inmobiliaria más innovadora y confiable de El Salvador.
- **Estructura Organizacional Básica:** Junta Directiva, Gerencia General, Gerencia de Proyectos, Gerencia Comercial, Finanzas, Legal, TI.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Desarrollo y venta de proyectos residenciales y comerciales.
- **Clientes:** Compradores de vivienda, inversionistas y empresas.

Procesos Críticos (3):

  - **1. Sistema de Gestión de Relaciones con Clientes (CRM):** Almacenamiento de datos personales y financieros de miles de prospectos y clientes.
  - **2. Plataforma de Transacciones y Legal:** Gestión de contratos de promesa de venta, escrituración y datos financieros sensibles relacionados con créditos hipotecarios.
  - **3. Sistema de Gestión de Proyectos y Presupuestos:** Control financiero detallado de los proyectos de construcción.

- **Dependencia Tecnológica:** Crítica. Son un objetivo principal para ataques de fraude, como el Business Email Compromise (BEC), para interceptar los pagos de prima de los clientes.

Infraestructura tecnológica inicial

- **Sistemas:** CRM de Salesforce, ERP financiero de NetSuite, gestor documental en SharePoint/Microsoft 365.
- **Red y Comunicaciones:** Red corporativa tradicional. Los agentes de ventas utilizan dispositivos personales (BYOD) para acceder al CRM desde cualquier lugar.
- **Madurez y Controles Actuales:** Nivel muy bajo. La cultura de seguridad es nula. No hay autenticación multifactor (MFA) en el correo electrónico ni en el CRM. El personal no está capacitado para identificar correos de phishing, lo que los hace extremadamente vulnerables a fraudes de transferencia de fondos.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ventas anuales	USD 80 M	65–95 M	420 unidades residenciales al año con precio medio de USD 160 000, más locales comerciales
Margen	Margen bruto 24 %; margen neto 9 %	Neto 6–12 %	Sobre ventas
Temporada alta	Ferias de vivienda de marzo y septiembre, y cierre de año	—	Reservas frente al mes promedio: 1,6 (1,3–1,9)
Volumen de transacciones	35 escrituras por mes	28–42	1 800 pagos de reservas y primas al mes; monto medio de un pago de prima USD 45 000 (20 000 –120 000)
Datos personales	38 000 prospectos y 6 500 clientes	—	Datos de ingresos, crédito hipotecario, identidad y cuentas bancarias
Pagos con tarjeta	9 000 reservas al año con tarjeta	7 000–11 000	Comercio de nivel 4 de PCI DSS; los datos de tarjeta los procesa un proveedor externo
Costo de notificar a un titular	USD 0,40	0,25–0,60	Correo y SMS
Costo de reposición de equipos clave	USD 250 000	200 000–300 000	Laptops y equipos de oficina y salas de venta; los sistemas son de pago por suscripción

Operación por proceso

Proceso	Sistema de gestión de relaciones con clientes (CRM)
Horario	Salas de venta de lunes a domingo de 9:00 a 18:00
Personal en turno y costo	90 asesores de venta; costo cargado USD 8 por hora (±15 %)
Procedimiento alterno	Registro en hojas de cálculo y cuadernos, con carga posterior
Penalizaciones	Ninguna contractual
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: asesores sin historial de prospectos · 24 h: citas y seguimientos perdidos · 72 h: reservas del fin de semana sin registrar · 1 semana: ventas perdidas en feria de vivienda · 1 mes: si hubo fuga de la base, prospectos captados por la competencia y notificación a titulares

Proceso	Plataforma de transacciones y legal (promesas de venta y escrituración)
Horario	Oficina de lunes a sábado de 8:00 a 17:00
Personal en turno y costo	25 abogados y gestores; costo cargado USD 16 por hora (±15 %)
Procedimiento alterno	Expedientes físicos en archivo
Penalizaciones	Promesas de venta con penalidad del 1 % mensual sobre lo pagado si la escritura se atrasa por causa de la empresa; plazos de desembolso de los bancos hipotecarios
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: escrituras del día reprogramadas · 24 h: desembolsos hipotecarios atrasados · 72 h: penalidades con compradores · 1 semana: bancos reprograman créditos · 1 mes: si hubo fraude en instrucciones de pago, pérdidas de compradores y demandas

Proceso	Sistema de gestión de proyectos y presupuestos
Horario	Oficina de lunes a viernes de 8:00 a 17:00
Personal en turno y costo	40 personas de proyectos y finanzas; costo cargado USD 12 por hora (±15 %)
Procedimiento alterno	Hojas de cálculo con el último cierre
Penalizaciones	Contratistas cobran intereses por pagos tardíos; los bancos que financian obra exigen informes mensuales
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin efecto · 24 h: pagos a contratistas atrasados · 72 h: control de costos sin actualizar · 1 semana: informe al banco fuera de plazo · 1 mes: desembolsos del financiamiento de obra suspendidos

Tecnología

Elemento	Situación actual
CRM	Salesforce Sales Cloud, con app en celulares personales de los asesores
ERP financiero	Oracle NetSuite
Documentos y correo	Microsoft 365 Business Premium con SharePoint Online y Exchange Online
Estaciones	Laptops con Windows 11; sin gestión de dispositivos móviles
Red	Oficina central y seis salas de venta con internet comercial; Wi-Fi compartido con visitantes

Respaldos y continuidad

Sistema	Situación actual
Salesforce y NetSuite	Retención propia de cada proveedor, sin respaldo adicional
Microsoft 365	Retención propia de Microsoft 365, sin respaldo adicional
Expedientes	Originales en papel en el archivo de Legal
Sitio alterno	No aplica: los sistemas son de pago por suscripción

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Correo que suplantó a la empresa e instruyó a un comprador depositar su prima en otra cuenta	—	USD 38 000 perdidos por el comprador; reclamo a la empresa
2024	Un asesor que renunció se llevó la lista de prospectos a la competencia	—	Sin cuantificar
2025	Cuenta de correo de Finanzas comprometida; pago a un contratista desviado	—	USD 95 000
2026	Pérdida de una laptop de Legal sin cifrado de disco	—	Expedientes de 120 compradores expuestos

Organización y presupuesto

Dato	Valor
Organigrama	Junta Directiva; Gerencia General; Gerencias de Proyectos y Comercial; Finanzas, que incluye RR. HH.; Legal (8 abogados); TI (5 personas); auditoría interna tercerizada. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 300 000 (170 000 de inversión y 130 000 de operación). 2028 y 2029: USD 200 000 por año, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por la Gerencia General para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Ley contra el Lavado de Dinero y de Activos, como sujeto obligado por la venta de inmuebles (reportes a la UIF); Ley para la Protección de Datos Personales; Ley de Protección al Consumidor; requisitos de los bancos hipotecarios; PCI DSS por medio del procesador

Controles que ya existen

Familia	Estado actual
Cuentas	Sin segundo factor en el correo ni en el CRM
Concientización	Sin capacitación sobre phishing
Dispositivos	Los asesores usan celulares personales sin gestión; laptops sin cifrado de disco
Pagos	Cambios de cuenta bancaria de proveedores aceptados por correo, sin llamada de verificación
Antimalware	Microsoft Defender con la configuración de fábrica en las laptops

4.24 Cacao del Sol

Grupo de Implementación asignado: IG3. Producción de alimentos con trazabilidad exigida por los compradores de exportación y dependencia de terceros en la cadena de suministro.

Datos básicos de la empresa

- **Sector:** Alimentos y Bebidas (Chocolate Premium).
- **Tamaño:** Mediana (250 empleados).

- **Ubicación:** Planta de procesamiento en las afueras de San Salvador y tiendas concepto en zonas turísticas.
- **Misión:** Producir el chocolate más fino de El Salvador, utilizando cacao de origen único y procesos artesanales, para deleitar a los paladares más exigentes del mundo.
- **Visión:** Posicionar el chocolate salvadoreño como una marca de lujo a nivel internacional.
- **Estructura Organizacional Básica:** Fundador/CEO, Maestro Chocolatero, Operaciones de Planta, Marketing y Ventas, E-commerce, Finanzas.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Manufactura y venta de chocolate gourmet, operación de tiendas y un sitio de e-commerce internacional.
- **Clientes:** Mercado local de alto poder adquisitivo y mercado internacional a través de e- commerce (B2C).

Procesos Críticos (4):

  - **1. Protección de Recetas y Procesos:** La propiedad intelectual de sus formulaciones de chocolate es su activo más valioso.
  - **2. Operación de la Plataforma de E-commerce:** Procesamiento seguro de pagos internacionales y protección de los datos de los clientes (cumplimiento de PCI DSS y GDPR).
  - **3. Sistema de Control de Calidad y Trazabilidad:** Seguimiento del lote de cacao desde la finca hasta la barra de chocolate final.
  - **4. Gestión de la Cadena de Suministro:** Compra de materia prima de alta calidad y logística de exportación.

- **Dependencia Tecnológica:** Crítica. El robo de sus recetas o una brecha de datos en su sitio de e-commerce podría destruir la marca.

Infraestructura tecnológica inicial

- **Sistemas:** Plataforma de e-commerce Shopify Advanced, ERP de Odoo para producción y finanzas.
- **Red y Comunicaciones:** Red de planta para la maquinaria y red corporativa separadas de forma básica.
- **Madurez y Controles Actuales:** Nivel bajo. Confían excesivamente en la seguridad de Shopify. Las recetas se almacenan en servidores de archivos locales sin controles de acceso adecuados. No realizan escaneos de vulnerabilidades en su infraestructura y son vulnerables a ransomware.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ventas anuales	USD 18 M	16–20 M	Tiendas concepto 35 %, e-commerce 30 % (70 % al exterior), mayoristas 35 %
Margen bruto	55 %	50–60 %	Sobre ventas netas
Temporada alta	San Valentín, Día de la Madre y diciembre	—	Pedidos en línea frente al mes promedio: 2,4 (1,9–2,9)
Volumen de transacciones	95 000 pedidos en línea al año	80 000–110 000	60 000 ventas con tarjeta en tiendas; 140 lotes de producción al mes

Dato	Valor probable	Rango	Detalle
Datos personales	210 000 clientes del e-commerce	190 000–230 000	60 % en Estados Unidos y la Unión Europea
Pagos con tarjeta	155 000 transacciones al año entre tienda en línea y tiendas	130 000–180 000	Shopify Payments y terminales del adquirente; comercio de nivel 3 de PCI DSS
Recetas	40 formulaciones que la Dirección valora en USD 6 M	4–8 M	Son el activo principal de la marca
Costo de notificar a un titular	USD 0,05	0,03–0,10	Correo desde la plataforma de e-commerce
Costo de reposición de equipos clave	USD 1,4 M	1,2–1,7 M	Línea de conchado y templado con su control; el servidor de archivos cuesta USD 15 000

Operación por proceso

Proceso	Protección de recetas y procesos
Horario	Planta y desarrollo de lunes a sábado
Personal en turno y costo	Maestro chocolatero y 6 técnicos de desarrollo; costo cargado USD 20 por hora (±15 %)
Procedimiento alterno	Fichas impresas guardadas en caja fuerte
Penalizaciones	Ninguna contractual; acuerdos de confidencialidad con empleados
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin acceso a fichas de formulación digitales · 24 h: desarrollo de productos detenido · 72 h: lotes especiales atrasados · 1 semana: lanzamiento de temporada en riesgo · 1 mes: si hubo robo de recetas, copia por la competencia y pérdida del diferencial de la marca

Proceso	Operación de la plataforma de e-commerce
Horario	24 horas, todos los días
Personal en turno y costo	8 personas de e-commerce y atención; costo cargado USD 9 por hora (±15 %)
Procedimiento alterno	Venta por redes sociales y mensajería con enlaces de pago
Penalizaciones	Shopify y el adquirente pueden suspender la tienda por fraude o incumplimiento de PCI DSS; clientes europeos protegidos por el RGPD
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: ventas en línea perdidas del período · 24 h: pedidos de temporada sin atender · 72 h: clientes internacionales compran a otras marcas · 1 semana: pérdida de posicionamiento en buscadores y campañas · 1 mes: si hubo fuga o fraude, suspensión de la tienda y notificación a clientes de varios países

Proceso	Sistema de control de calidad y trazabilidad
Horario	Planta de lunes a sábado de 6:00 a 18:00
Personal en turno y costo	12 inspectores de calidad; costo cargado USD 6 por hora (±15 %)

Proceso	Sistema de control de calidad y trazabilidad
Procedimiento alterno	Registros de lote en papel
Penalizaciones	La certificación orgánica y la exportación a Estados Unidos exigen trazabilidad; un retiro sin trazabilidad obliga a retirar toda la producción del período
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: registros en papel · 24 h: lotes sin liberar · 72 h: despachos de exportación detenidos · 1 semana: auditoría de la certificadora · 1 mes: riesgo de perder la certificación orgánica

Proceso	Gestión de la cadena de suministro y exportación
Horario	Oficina de lunes a viernes
Personal en turno y costo	10 personas de compras y exportación; costo cargado USD 9 por hora (±15 %)
Procedimiento alterno	Pedidos y documentos de exportación por correo
Penalizaciones	Dos distribuidores de Estados Unidos aplican 3 % por pedido tardío; contratos de compra anticipada con 120 fincas
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin efecto · 24 h: documentos de exportación atrasados · 72 h: embarques perdidos · 1 semana: penalidades de distribuidores · 1 mes: faltante de cacao para la temporada

Tecnología

Elemento	Situación actual
E-commerce	Shopify Advanced con aplicaciones de terceros
ERP	Odoo 16 Community en un servidor Ubuntu 22.04 en la planta
Archivos	Servidor de archivos con Windows Server 2016, donde se guardan las recetas
Planta	PLC Siemens S7-1200 en las líneas de conchado y templado
Oficina e identidad	Google Workspace; laptops con Windows 11
Red	Red de planta y red corporativa separadas por VLAN en un solo enrutador, con la contraseña que dejó el proveedor de internet

Respaldos y continuidad

Sistema	Situación actual
ERP	Respaldo diario de Odoo a un disco externo conectado al servidor
Recetas	Sin respaldo; solo las copias impresas de la caja fuerte
E-commerce	Retención propia de Shopify
Sitio alterno	No existe

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Toma de la cuenta de Instagram de la marca	3 días	Campaña de temporada perdida
2024	Pedidos internacionales pagados con tarjetas robadas	2 meses	USD 22 000 en contracargos
2025	Ransomware en el servidor de archivos; recetas reconstruidas con las copias impresas	4 días	USD 30 000
2026	Un exempleado de desarrollo ofreció una receta a un competidor	—	Demanda en curso

Organización y presupuesto

Dato	Valor
Organigrama	Fundador y CEO; Maestro Chocolatero; Operaciones de Planta; Marketing y Ventas; E-commerce; Finanzas, que incluye RR. HH. y TI (3 personas). Asesoría legal externa; sin auditoría interna. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 180 000 (110 000 de inversión y 70 000 de operación). 2028 y 2029: USD 120 000 por año, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por el CEO para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	PCI DSS como comercio; RGPD para clientes de la Unión Europea; Ley para la Protección de Datos Personales; registro de instalación alimentaria ante la FDA para exportar a Estados Unidos; certificación orgánica

Controles que ya existen

Familia	Estado actual
E-commerce	Confianza en la seguridad de Shopify; administradores de la tienda sin segundo factor
Recetas	Carpetas del servidor de archivos abiertas a todo el personal
Vulnerabilidades	Sin escaneos de vulnerabilidades
Antimalware	Microsoft Defender en las laptops; nada en el servidor de archivos
Segmentación	VLAN básica entre planta y oficina

4.25 CrediRápido S.A.

Grupo de Implementación asignado: IG3. Crédito regulado con datos financieros de personas y fraude dirigido como amenaza principal.

Datos básicos de la empresa

- **Sector:** FinTech (Microcréditos).
- **Tamaño:** Mediana (400 empleados).
- **Ubicación:** Centro de operaciones en San Salvador.

- **Misión:** Ofrecer acceso a crédito rápido y justo a personas excluidas del sistema bancario tradicional a través de una plataforma digital innovadora.
- **Visión:** Ser la FinTech líder en inclusión financiera en Centroamérica.
- **Estructura Organizacional Básica:** CEO, Director de Riesgos, Director de Tecnología, Operaciones, Cobros, Marketing Digital.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Otorgamiento de microcréditos a través de una aplicación móvil.
- **Clientes:** Personas no bancarizadas o con historial de crédito limitado.

Procesos Críticos (4):

  - **1. Motor de Decisión de Crédito (Scoring):** Algoritmo que analiza datos alternativos para aprobar o denegar préstamos en segundos. La integridad de este sistema es vital.
  - **2. Plataforma de Préstamos y Desembolsos:** Operación segura de la aplicación móvil, desde la solicitud hasta la transferencia del dinero.
  - **3. Protección de Datos Personales y Financieros:** Manejo de información extremadamente sensible de los solicitantes.
  - **4. Sistema de Gestión de Cobranza:** Administración del proceso de recuperación de la cartera de préstamos.

- **Dependencia Tecnológica:** Crítica y absoluta. La empresa es su algoritmo y su plataforma digital.

Infraestructura tecnológica inicial

- **Sistemas:** Plataforma 100% en la nube (Google Cloud Platform), usando Cloud Functions, BigQuery para el análisis de datos, y Kubernetes Engine.
- **Red y Comunicaciones:** Infraestructura como código, despliegue continuo.
- **Madurez y Controles Actuales:** Nivel bajo en seguridad. Han priorizado el "time-to- market" sobre la seguridad. La seguridad de las APIs que exponen a la app móvil es deficiente, el motor de scoring podría ser manipulado y no tienen un programa de respuesta a incidentes para una posible brecha de datos masiva.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales	USD 46 M	40–52 M	Intereses y comisiones sobre una cartera de USD 85 M
Margen neto	11 %	7–15 %	Sobre ingresos; morosidad de la cartera 9 % (7–12 %)
Temporada alta	Quincenas, inicio del año escolar (enero y febrero) y diciembre	—	Solicitudes frente al día promedio: 1,7 (1,4–2,0)
Volumen de transacciones	12 000 solicitudes por día	10 000–14 000	3 800 préstamos desembolsados por día, con monto medio de USD 180 (80–450)

Dato	Valor probable	Rango	Detalle
Datos personales	1,2 millones de solicitantes registrados	1,0–1,4 millones	DUI, fotografía del rostro, ingresos, cuentas bancarias y datos alternativos del teléfono con consentimiento
Pagos con tarjeta	2,8 millones de cobros con tarjeta de débito al año	2,4–3,2 millones	Por medio de un procesador externo; comercio de nivel 2 de PCI DSS
Fraude de identidad	1,2 % de los desembolsos	0,8–1,8 %	Préstamos otorgados con identidades suplantadas
Costo de notificar a un titular	USD 0,03	0,02–0,06	SMS y notificación en la app
Costo de reconstruir la plataforma	USD 700 000 en horas de ingeniería	500 000–900 000	La infraestructura se recrea con Terraform; el costo está en datos, modelo y pruebas

Operación por proceso

Proceso	Motor de decisión de crédito (scoring)
Horario	24 horas, todos los días
Personal en turno y costo	10 científicos de datos y analistas de riesgo; costo cargado USD 25 por hora (±15 %)
Procedimiento alterno	Aprobación manual con reglas simples, hasta 300 solicitudes por día
Penalizaciones	Ninguna contractual; un motor manipulado aprueba préstamos que no se recuperan
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: solicitudes en espera; clientes van a otras apps · 24 h: colocación del día perdida en más del 90 % · 72 h: pérdida de clientes recurrentes · 1 semana: caída de ingresos del mes · 1 mes: si el modelo fue manipulado, cartera morosa que Riesgos estima en USD 2 M

Proceso	Plataforma de préstamos y desembolsos (app y API)
Horario	24 horas, todos los días
Personal en turno y costo	20 personas de operaciones y soporte por turno; costo cargado USD 10 por hora (±15 %)
Procedimiento alterno	Ninguno para la solicitud; los desembolsos se detienen
Penalizaciones	Contrato con el banco que dispersa los fondos: tarifa mínima mensual y reintegro de desembolsos duplicados
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin solicitudes ni desembolsos · 24 h: reclamos masivos en tiendas de apps y redes · 72 h: calificación de la app en caída · 1 semana: pérdida de clientes · 1 mes: si hubo desvío de desembolsos, pérdida directa y revisión del banco dispersor

Proceso	Protección de datos personales y financieros
Horario	24 horas, todos los días
Personal en turno y costo	5 personas de datos; costo cargado USD 20 por hora (±15 %)
Procedimiento alterno	No aplica

Proceso	Protección de datos personales y financieros
Penalizaciones	Una fuga obliga a notificar a los titulares; reclamos ante la Defensoría del Consumidor
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin efecto si no hay fuga · 24 h: si hay fuga, extorsión a clientes con sus datos · 72 h: notificación a titulares y cobertura en medios · 1 semana: investigación de autoridades · 1 mes: pérdida de confianza que la Dirección considera fatal para el negocio

Proceso	Sistema de gestión de cobranza
Horario	Lunes a sábado de 8:00 a 19:00
Personal en turno y costo	120 gestores de cobro; costo cargado USD 5 por hora (±15 %)
Procedimiento alterno	Llamadas con listas exportadas del día anterior
Penalizaciones	Reclamos y sanciones por cobrar a clientes que ya pagaron
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: gestiones con datos del día anterior · 24 h: cobros a clientes que ya pagaron · 72 h: aumento de la morosidad temprana · 1 semana: reclamos ante la Defensoría del Consumidor · 1 mes: morosidad de la cartera por encima del 12 %

Tecnología

Elemento	Situación actual
Cómputo y datos	Google Kubernetes Engine con Kubernetes 1.29; Cloud Functions; BigQuery; Cloud SQL for PostgreSQL 14
App y API	Apps Android e iOS; API REST publicada por un balanceador de carga, sin gateway de API
Modelo de scoring	Modelo en Python entrenado con datos de BigQuery y desplegado como servicio en GKE
Entrega	Terraform y Cloud Build con despliegue continuo
Oficina e identidad	Google Workspace; laptops con macOS 14 y Windows 11

Respaldos y continuidad

Sistema	Situación actual
Cloud SQL	Respaldo automático diario con retención de 7 días, en la misma región
BigQuery	Solo la recuperación de 7 días propia del servicio
Región alterna	No existe
Última prueba de recuperación	Nunca se ha probado una restauración

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	API sin control de autorización: un usuario consultó datos de otros cambiando el identificador en la petición	3 semanas	40 000 registros expuestos; notificación a titulares

Año	Incidente	Duración	Costo
2024	Red de fraude con identidades suplantadas y fotografías falsificadas	4 meses	USD 310 000 en préstamos incobrables
2025	Caída de la API del banco dispersor	9 horas	Desembolsos del día atrasados
2026	Un gestor de cobro filtró listas de deudores	—	Reclamos ante la Defensoría del Consumidor

Organización y presupuesto

Dato	Valor
Organigrama	CEO; Direcciones de Riesgos y de Tecnología (60 personas); Operaciones; Cobros; Marketing Digital; Finanzas, que incluye RR. HH.; Legal y Cumplimiento, con el oficial de cumplimiento; auditoría interna de una persona. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 550 000 (300 000 de inversión y 250 000 de operación). 2028 y 2029: +10 % anual, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por el CEO para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Ley contra la Usura (tasas máximas que publica el Banco Central de Reserva); Ley de Protección al Consumidor en el crédito y la gestión de cobro; Ley contra el Lavado de Dinero y de Activos; Ley para la Protección de Datos Personales; PCI DSS por medio del procesador

Controles que ya existen

Familia	Estado actual
API	Autenticación por token sin control de autorización por recurso ni límite de peticiones
Modelo de scoring	Sin control de cambios del modelo ni monitoreo de su comportamiento
Respuesta a incidentes	No existe un plan para una fuga masiva de datos
Identidad de clientes	Validación por fotografía sin prueba de vida
Cuentas	Segundo factor en Google Workspace; cuentas de servicio de la nube con permisos amplios

4.26 Consultores Legales Corpolex

Grupo de Implementación asignado: IG3. Secreto profesional sobre información de clientes corporativos y expedientes en litigio, con adversarios dirigidos interesados en la estrategia legal.

Datos básicos de la empresa

- **Sector:** Servicios Legales Corporativos.
- **Tamaño:** Mediana (150 empleados).
- **Ubicación:** Oficinas en un prestigioso centro de negocios de San Salvador.
- **Misión:** Brindar asesoría legal estratégica y de alta calidad a las principales corporaciones del país, protegiendo sus intereses en fusiones, adquisiciones y litigios complejos.

- **Visión:** Ser el bufete de abogados corporativos más influyente y respetado de El Salvador.
- **Estructura Organizacional Básica:** Socios Directores, Jefes de Departamento (M&A, Litigios, Fiscal), Abogados Asociados, TI, Administración.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Asesoría en fusiones y adquisiciones (M&A), litigios de alto perfil, derecho corporativo y fiscal.
- **Clientes:** Las empresas más grandes de El Salvador y firmas multinacionales.

Procesos Críticos (3):

  - **1. Gestión de la Información de Casos Confidenciales:** Protección absoluta de la información de sus clientes, que a menudo es material no público y sensible al mercado.
  - **2. Operación de "Data Rooms" Virtuales:** Creación de espacios seguros para el due diligence en transacciones de M&A.
  - **3. Comunicaciones Seguras:** Garantizar la confidencialidad de la comunicación entre abogados y clientes.

- **Dependencia Tecnológica:** Crítica. Una brecha de datos no solo destruiría su reputación, sino que podría tener implicaciones legales y financieras masivas para sus clientes (insider trading, etc.).

Infraestructura tecnológica inicial

- **Sistemas:** Sistema de gestión de prácticas legales de Thomson Reuters, plataforma de data room de Intralinks, Microsoft 365 E5.
- **Red y Comunicaciones:** Fuerte dependencia de la seguridad de sus proveedores de SaaS.
- **Madurez y Controles Actuales:** Nivel bajo. Los abogados tienen una cultura de trabajo muy independiente y son reacios a los controles de seguridad. A menudo manejan documentos ultrasensibles en dispositivos personales y redes Wi-Fi públicas. No tienen controles de DLP ni una respuesta a incidentes formal.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Ingresos anuales	USD 24 M	21–27 M	Fusiones y adquisiciones 40 %, litigios 30 %, corporativo y fiscal 30 %
Margen	Utilidad antes de distribución a socios: 38 %	33–43 %	Sobre ingresos
Temporada alta	Enero a abril (cierre fiscal) y diciembre (cierres de transacciones)	—	Horas facturables frente al mes promedio: 1,5 (1,3–1,7)
Volumen de trabajo	1 100 asuntos activos	1 000–1 200	12 data rooms activas; tarifa media USD 180 por hora facturable (120–450); transacciones asesoradas en 2025 por USD 1 400 M
Datos personales	9 000 personas en expedientes	—	Accionistas, empleados de clientes y contrapartes; datos patrimoniales y judiciales

Dato	Valor probable	Rango	Detalle
Costo de notificar a un titular	USD 25	15–40	Carta y llamada del socio responsable
Costo de reposición de equipos clave	USD 220 000	180 000–260 000	Laptops, equipos de oficina y red
Póliza de responsabilidad profesional	Cobertura de USD 5 M	—	La aseguradora exige controles mínimos de seguridad para renovar

Operación por proceso

Proceso	Gestión de la información de casos confidenciales
Horario	Lunes a viernes de 8:00 a 19:00, con noches de cierre
Personal en turno y costo	95 abogados; costo cargado USD 60 por hora (±15 %)
Procedimiento alterno	Expedientes físicos y copias locales
Penalizaciones	Secreto profesional y responsabilidad civil ante el cliente; la póliza puede negar cobertura si faltan controles
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: abogados sin expedientes digitales · 24 h: plazos judiciales en riesgo · 72 h: escritos fuera de plazo · 1 semana: reclamos de clientes · 1 mes: si hubo fuga de información, pérdida de clientes que los Socios consideran irreparable

Proceso	Operación de data rooms virtuales
Horario	24 horas mientras dura una transacción
Personal en turno y costo	12 abogados y asistentes de fusiones y adquisiciones; costo cargado USD 45 por hora (±15 %)
Procedimiento alterno	Intercambio por el SFTP del cliente o entrega física
Penalizaciones	Cláusulas de confidencialidad de cada transacción; un atraso del cierre puede costar la operación al cliente
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: revisión de due diligence detenida · 24 h: calendario de la transacción desplazado · 72 h: contraparte exige explicaciones · 1 semana: riesgo de que la operación se caiga · 1 mes: si hubo fuga, información sensible al mercado expuesta y responsabilidad frente al cliente

Proceso	Comunicaciones seguras con clientes
Horario	24 horas, todos los días
Personal en turno y costo	150 usuarios; 6 personas de TI; costo cargado de TI USD 15 por hora (±15 %)
Procedimiento alterno	Llamadas y reuniones presenciales
Penalizaciones	Una fuga de información privilegiada expone al despacho a responsabilidad e investigaciones

Proceso	Comunicaciones seguras con clientes
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: comunicación por teléfono · 24 h: documentos sin enviar a clientes · 72 h: negociaciones atrasadas · 1 semana: clientes piden garantías de seguridad · 1 mes: si hubo interceptación, pérdida de clientes multinacionales

Tecnología

Elemento	Situación actual
Gestión de prácticas	Sistema de gestión de prácticas legales de Thomson Reuters en la nube del proveedor
Data rooms	Intralinks VDRPro
Oficina e identidad	Microsoft 365 E5 con Purview y Defender incluidos pero sin configurar; Microsoft Entra ID
Estaciones	Laptops con Windows 11 y macOS 14; muchos abogados usan equipos personales
Red	Oficina con Wi-Fi corporativo y cortafuegos Fortinet FortiGate con FortiOS 7.2

Respaldos y continuidad

Sistema	Situación actual
Correo y archivos	Retención propia de Microsoft 365, sin respaldo adicional
Gestión de prácticas y data rooms	A cargo de cada proveedor
Copias locales	Documentos en laptops personales, sin respaldo
Sitio alterno	No aplica: los sistemas están en la nube

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Un abogado envió el borrador de un contrato de fusión a un destinatario equivocado	—	Aviso al cliente; sin reclamo
2024	Correo suplantado de un socio que pidió transferir un fondo en custodia	—	USD 70 000
2025	Laptop personal de un asociado con malware que sincronizaba OneDrive	2 semanas	Revisión forense de USD 18 000
2026	Una transacción se filtró a la prensa antes del anuncio; el origen no se determinó	—	Queja formal del cliente

Organización y presupuesto

Dato	Valor
Organigrama	Socios Directores (comité de dirección); Jefes de Departamento de Fusiones y Adquisiciones, Litigios y Fiscal; abogados asociados; TI (6 personas); Administración, que incluye RR. HH. y finanzas; comité interno de ética y riesgo profesional; auditoría externa anual. No existe una unidad de seguridad de la información

Dato	Valor
Presupuesto aprobado para seguridad	2027: USD 250 000 (130 000 de inversión y 120 000 de operación). 2028 y 2029: USD 180 000 por año, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por los Socios Directores para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Secreto profesional del abogado; Ley para la Protección de Datos Personales; prevención de lavado de dinero en los servicios notariales y de constitución de sociedades; cuestionarios de seguridad de clientes multinacionales; condiciones de la póliza de responsabilidad profesional

Controles que ya existen

Familia	Estado actual
Dispositivos	Documentos ultrasensibles en equipos personales y redes Wi-Fi públicas
Fuga de datos	Sin reglas de prevención de fuga de datos, aunque la licencia E5 las incluye
Cuentas	Segundo factor en Microsoft 365 solo para socios
Respuesta a incidentes	Sin plan formal
Data rooms	Permisos por documento y marcas de agua en Intralinks

4.27 Instituto Salvadoreño de Investigación Genómica

Grupo de Implementación asignado: IG3. Datos genómicos identificables y resultados de investigación de alto valor para adversarios sofisticados.

Datos básicos de la empresa

- **Sector:** Investigación Científica y Biotecnología.
- **Tamaño:** Mediana (200 empleados, mayoría científicos).
- **Ubicación:** Campus de investigación afiliado a una universidad local.
- **Misión:** Liderar la investigación genómica en la región para avanzar en el diagnóstico y tratamiento de enfermedades prevalentes en nuestra población.
- **Visión:** Ser un centro de investigación genómica de clase mundial, generando conocimiento y propiedad intelectual valiosa.
- **Estructura Organizacional Básica:** Director Científico, Jefes de Laboratorio, Bioinformáticos, Administración, TI de Investigación.

Modelo de negocio y procesos críticos

- **Servicios Principales:** Secuenciación de ADN, análisis bioinformático, investigación patrocinada.
- **Clientes:** Hospitales, farmacéutica y otras instituciones de investigación.

Procesos Críticos (3):

  - **1. Gestión y Protección de Datos Genómicos:** Almacenamiento y procesamiento seguro de secuencias de ADN humano, la información más personal e inmutable que existe.
  - **2. Operación del Clúster de Computación de Alto Rendimiento (HPC):** Disponibilidad de la infraestructura de supercómputo para el análisis bioinformático.

  - **3. Protección de la Propiedad Intelectual de la Investigación:** Salvaguarda de los descubrimientos y algoritmos desarrollados.
- **Dependencia Tecnológica:** Crítica. La confidencialidad e integridad de los datos genómicos es una responsabilidad ética y legal masiva.

Infraestructura tecnológica inicial

- **Sistemas:** Secuenciadores Illumina, clúster HPC con Linux, almacenamiento masivo en red (NAS), software de análisis bioinformático especializado.
- **Red y Comunicaciones:** Red de investigación de 10Gbps, grandes transferencias de datos a colaboradores internacionales.
- **Madurez y Controles Actuales:** Nivel muy bajo. La TI está dirigida por científicos, no por profesionales de seguridad. Los conjuntos de datos genómicos se almacenan en servidores sin cifrado robusto, los controles de acceso son deficientes y los científicos a menudo comparten datos a través de FTPs inseguros. Son un objetivo para el espionaje industrial y el robo de datos genéticos.

Ficha de datos del cliente (entregada en la reunión de arranque)

Datos que el cliente entrega al equipo, con el valor probable y el rango mínimo–máximo que considera posible. Con ellos el equipo calcula el BIA y los análisis siguientes; ningún dato de esta ficha se reemplaza por un supuesto.

Economía

Dato	Valor probable	Rango	Detalle
Presupuesto operativo anual	USD 16 M	14–18 M	Servicios de secuenciación 55 %, investigación patrocinada 30 %, subvenciones 15 %
Excedente operativo	4 % del presupuesto	1–7 %	Entidad sin fines de lucro afiliada a una universidad
Temporada alta	Junio y diciembre, por entregas de proyectos y cierres de convocatorias	—	Muestras procesadas frente al mes promedio: 1,5 (1,3–1,8)
Volumen de operación	2 400 muestras secuenciadas al mes	2 000–2 800	180 TB de datos nuevos al mes; 2 PB almacenados
Datos personales	Genomas y datos clínicos de 48 000 personas	42 000–54 000	Datos genéticos y de salud con consentimiento informado
Costo de notificar a un titular	USD 3,00	2,00–5,00	Carta por medio del hospital o del proyecto de origen
Costo de reposición de equipos clave	USD 1,2 M por un secuenciador de alto rendimiento	1,0–1,4 M	Clúster HPC USD 2,0 M (1,7–2,4 M)

Operación por proceso

Proceso	Gestión y protección de datos genómicos
Horario	Laboratorio de lunes a sábado; datos 24 horas
Personal en turno y costo	40 técnicos de laboratorio y bioinformáticos; costo cargado USD 15 por hora (±15 %)
Procedimiento alterno	Los secuenciadores guardan los datos localmente hasta 72 horas

Proceso	Gestión y protección de datos genómicos
Penalizaciones	Contratos con hospitales y farmacéuticas con confidencialidad y responsabilidad; el consentimiento informado limita los usos de cada dato
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: datos nuevos retenidos en los secuenciadores · 24 h: corridas pausadas · 72 h: pérdida de datos crudos si no se transfieren · 1 semana: muestras que deben repetirse · 1 mes: si hubo fuga, exposición permanente de datos genéticos que la Dirección considera irreparable

Proceso	Operación del clúster de computación de alto rendimiento (HPC)
Horario	24 horas, todos los días
Personal en turno y costo	6 administradores de TI de investigación; costo cargado USD 18 por hora (±15 %)
Procedimiento alterno	Análisis urgentes en la nube con créditos académicos, en volumen limitado
Penalizaciones	Resultados en 10 días hábiles por contrato; si se atrasan, descuento del 10 % del servicio
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: trabajos en cola · 24 h: análisis de hospitales atrasados · 72 h: incumplimiento de plazos contractuales · 1 semana: descuentos y reclamos · 1 mes: pérdida de clientes de secuenciación

Proceso	Protección de la propiedad intelectual de la investigación
Horario	Oficina de lunes a viernes
Personal en turno y costo	60 investigadores; costo cargado USD 22 por hora (±15 %)
Procedimiento alterno	Trabajo sin acceso a datos ni algoritmos
Penalizaciones	Acuerdos con patrocinadores: devolución de fondos si se filtran resultados antes de publicar o patentar
Consecuencias que describe el dueño (4 h · 24 h · 72 h · 1 semana · 1 mes)	4 h: sin efecto · 24 h: análisis detenidos · 72 h: entregables atrasados · 1 semana: patrocinadores piden explicaciones · 1 mes: si hubo robo, pérdida de prioridad de publicación o de patente

Tecnología

Elemento	Situación actual
Secuenciación	Secuenciadores Illumina NovaSeq X y MiSeq con su software de control en Windows 10
Cómputo	Clúster HPC con Rocky Linux 8 y Slurm 23; 1 200 núcleos
Almacenamiento	NAS de 2 PB compartido por NFS, sin cifrado
Transferencias	Servidor FTP y Globus para colaboradores internacionales
Oficina e identidad	Microsoft 365 de la universidad; laptops con macOS 14 y Ubuntu 22.04
Red	Red de investigación de 10 Gbps enlazada con la red de la universidad

Respaldos y continuidad

Sistema	Situación actual
NAS	Copia parcial a cintas LTO una vez al mes
Datos crudos	Se borran del secuenciador a los 30 días
Sitio alterno	No existe
Última prueba de recuperación	En 2025 se recuperaron 40 TB de cinta en 9 días tras una falla del NAS

Incidentes de los últimos años

Año	Incidente	Duración	Costo
2023	Servidor FTP expuesto a internet con conjuntos de datos de un proyecto	Detectado por un colaborador externo	Notificación a 1 200 participantes
2024	Minería de criptomonedas en el clúster con la cuenta comprometida de un colaborador	5 días	USD 12 000 en tiempo de cómputo y energía
2025	Falla de un arreglo del NAS	9 días para recuperar 40 TB de cinta	Dos proyectos atrasados
2026	Phishing a un jefe de laboratorio	1 día	Cuenta bloqueada; sin acceso a datos confirmado

Organización y presupuesto

Dato	Valor
Organigrama	Director Científico; Jefes de Laboratorio; Bioinformática; Administración, que incluye RR. HH. y finanzas; TI de Investigación (6 personas); comité de ética de investigación; asesoría legal y de patentes de la universidad; auditoría interna de la universidad. No existe una unidad de seguridad de la información
Presupuesto aprobado para seguridad	2027: USD 350 000 (220 000 de inversión y 130 000 de operación). 2028 y 2029: USD 250 000 por año, sujeto a aprobación
Arranque del programa de seguridad	Aprobado por el Director Científico para el lunes 4 de enero de 2027
Cumplimiento que el cliente reconoce	Ley para la Protección de Datos Personales (datos genéticos y de salud); consentimiento informado y aprobación del comité de ética; RGPD y HIPAA en proyectos con colaboradores de la Unión Europea y de Estados Unidos; acuerdos de transferencia de datos

Controles que ya existen

Familia	Estado actual
Datos	Conjuntos genómicos en servidores sin cifrado robusto
Accesos	Permisos amplios en el NAS; cuentas de colaboradores externos sin fecha de vencimiento
Transferencias	Datos compartidos por FTP sin cifrar
Cuentas	Segundo factor en Microsoft 365 de la universidad; no en el clúster
Antimalware	Antivirus en estaciones Windows de los secuenciadores y en laptops institucionales

5. Reglas de selección y bloqueo de duplicados

Cada equipo trabaja una sola organización del catálogo durante todo el ciclo. La selección se cierra en la primera semana del curso, junto con la conformación de los equipos, porque la Fase 0 del Proyecto Final —compromiso de la dirección y alcance del SGSI— se redacta sobre la organización elegida.

Procedimiento de selección

1. El equipo revisa los perfiles de la sección 4 y define tres opciones en orden de preferencia.
2. El representante del equipo registra la elección en el aula virtual del curso. La primera solicitud válida asigna la organización a ese equipo.
3. La organización asignada queda bloqueada: sale de la oferta y las solicitudes posteriores pasan a su segunda o tercera opción.
4. El docente publica el registro de asignaciones —equipo, organización y Grupo de Implementación— el lunes 28 de septiembre; es la referencia para el resto del ciclo, y el acta E.01 se actualiza a la versión 1.1 con esa asignación.
5. El equipo que omite el registro dentro del plazo recibe una organización asignada por el docente entre las que siguen disponibles.

Bloqueo de duplicados y su única excepción

La regla general es una organización por equipo. Dos equipos comparten organización únicamente con autorización expresa del docente; en ese caso cada equipo desarrolla y entrega su proyecto de forma independiente, con sus propios documentos, y cada entrega se evalúa por sí misma.

Qué queda fijo y qué construye el equipo

- **El perfil es fijo.** Sector, tamaño, procesos críticos, infraestructura y madurez actual se toman tal como los describe el catálogo.
- **El Grupo de Implementación es el objetivo.** El baseline y el roadmap se construyen hacia el IG asignado; el análisis del equipo lo justifica desde el BIA y la matriz de riesgos.
- **Los supuestos cubren solo lo que falta.** Un dato que la ficha de datos del cliente trae nunca se sustituye por un supuesto. Lo que ni el perfil ni la ficha traen se registra como supuesto, con identificador global S-nn, su fundamento y coherente con ambos, en la sección «Supuestos declarados en este entregable» de cada plantilla.
- **El cambio de organización es excepcional.** Después de la primera semana requiere autorización del docente, y el equipo conserva el calendario vigente de hitos.

6. Glosario

Término	Definición
Activo de información	Recurso con valor para la organización que interviene en el tratamiento de la información: datos, sistemas, aplicaciones, equipos, servicios y personas.
Baseline de seguridad	Conjunto fundamental de políticas, procedimientos y controles que protege los procesos críticos de la organización; es el entregable central del Proyecto Final.
BIA	Análisis de impacto al negocio: proceso que analiza el impacto de una interrupción a lo largo del tiempo para fijar prioridades de continuidad y recuperación (ISO/TS 22317:2021).

Término	Definición
Control CIS	Cada uno de los 18 controles de los CIS Critical Security Controls v8.1 (2024); agrupa salvaguardas con un mismo objetivo de defensa.
Salvaguarda	Acción específica y verificable dentro de un control CIS. La versión 8.1 define 153.
Grupo de Implementación (IG)	Subconjunto acumulativo de salvaguardas que el CIS recomienda según el perfil de la organización: IG1 reúne 56, IG2 llega a 130 e IG3 abarca las 153.
Perfil de riesgo inherente	Nivel de riesgo que la organización enfrenta por su sector, sus datos, su tamaño, su dependencia tecnológica y sus adversarios, antes de considerar los controles existentes.
Madurez	Grado en que los controles de seguridad están definidos, implementados y medidos en la organización.
Proceso crítico	Actividad cuya interrupción produce un impacto inaceptable para la organización o para terceros dentro de un plazo definido.
Punto único de falla (SPOF)	Componente cuya falla detiene por sí sola un proceso crítico, por ausencia de redundancia o de una alternativa operativa.
Tecnología de operación (OT)	Hardware y software que supervisan y controlan procesos físicos, como la generación y distribución eléctrica o la producción industrial.
IoMT	Internet de las cosas médicas: equipo médico conectado a la red, como monitores de signos vitales, bombas de infusión y equipos de diagnóstico.
SGSI	Sistema de gestión de seguridad de la información conforme a ISO/IEC 27001:2022: contexto, liderazgo, evaluación del riesgo, controles y mejora continua.
SIEM	Plataforma que centraliza, correlaciona y conserva eventos de seguridad de múltiples fuentes para su detección, investigación y reporte.
Segmentación de red	División de la red en zonas con controles de tráfico entre ellas, que limita la propagación y el alcance de un incidente de seguridad.
Supuesto documentado	Dato que el equipo adopta para completar su análisis cuando el perfil lo omite, registrado con su justificación y coherente con el perfil.

7. Referencias

1. Center for Internet Security (2024). **CIS Critical Security Controls, versión 8.1.** Controles, salvaguardas, Grupos de Implementación y factores de asignación.
2. ISO/IEC 27001:2022. **Seguridad de la información, ciberseguridad y protección de la privacidad — Sistemas de gestión de seguridad de la información — Requisitos.**
3. ISO/IEC 27002:2022. **Controles de seguridad de la información.**
4. NIST (2024). **The NIST Cybersecurity Framework (CSF) 2.0.**
5. ISO/TS 22317:2021. **Seguridad y resiliencia — Sistemas de gestión de la continuidad del negocio — Directrices para el análisis de impacto al negocio.**
6. NIST SP 800-30 Rev. 1 (2012). **Guide for Conducting Risk Assessments.**
7. ESEN (2025). **Catálogo de Empresas IG3 para implementar controles CIS v8.1.** Fuente de los veintisiete perfiles; copia de trazabilidad en Proyecto_Final/_Fuente_2025/.

8. ESEN (2026). **Guía Maestra del Proyecto Final, v6.** Fases, hitos, plantillas y rúbricas del proyecto.